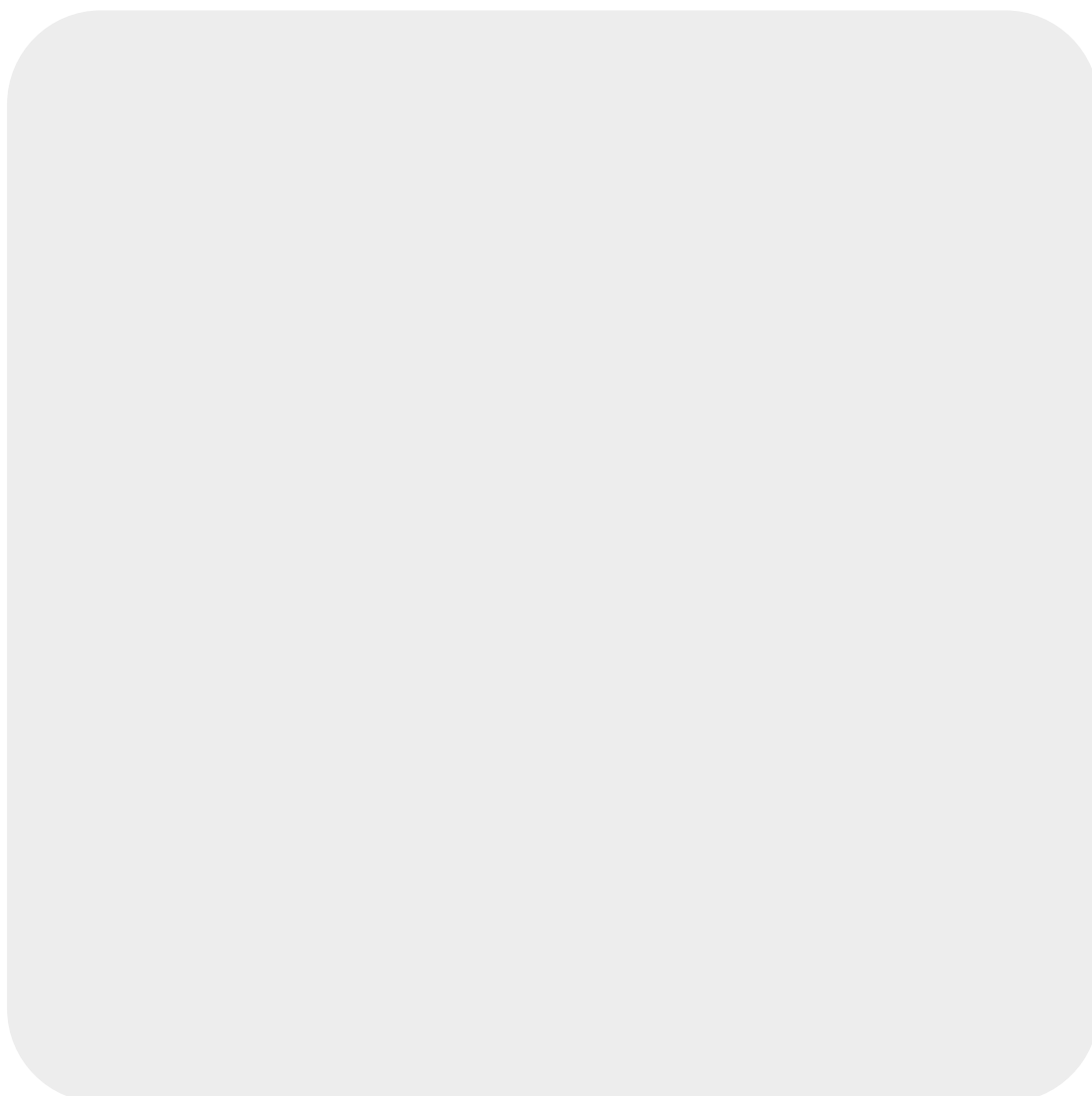


CISSP

Fiches de révision

03/06/2026

2026 Clément Wencker. Tous droits réservés.



Disclaimer

J'ai écrit ces fiches pour une raison simple : les concepts de gouvernance et de sécurité s'assimilent bien mieux en prenant de la hauteur et en vulgarisant. Ce document est le fruit de mon travail personnel, rédigé dans le cadre de mes propres révisions qui m'ont permis d'obtenir le CISSP durant mon année de Master 2.

Ancien militaire, j'ai quitté l'armée française pour me spécialiser en cybersécurité via un cursus de BAC à BAC+5. J'ai d'abord consacré mes quatre premières années d'études à l'informatique technique et à la sécurité offensive, en décrochant plusieurs certifications (eJPT, eCPPT, CRTP). J'ai ensuite dédié ma dernière année **d'études** à la GRC, en validant les certifications ISO 27001 Lead Implementer, ISO 27005 Risk Manager, le CISSP, et prochainement le CISM.

Durant ces cinq ans, j'ai évolué dans des environnements variés : l'industrie agroalimentaire, une ESN orientée développement, et une autre spécialisée en DevOps et Cybersécurité. De Helpdesk à Pentester, en passant par Administrateur Systèmes & Réseaux ou Ingénieur Cyber, mon parcours est avant tout technique.

C'est précisément pour cela que j'ai créé ces fiches de révision. Il est taillé pour les profils ingénieurs et techniciens qui souhaitent appréhender et décortiquer les notions parfois trop abstraites du CISSP. J'ai structuré ces notes de manière simplifiée pour mon propre usage, en synthétisant différents supports de formation pour aller droit au but.

Avertissement : La cybersécurité étant un domaine complexe et dépendant de contextes spécifiques, je décline toute responsabilité quant aux éventuelles erreurs, omissions ou conséquences (directes, indirectes, techniques ou financières) résultant de l'utilisation de ces informations

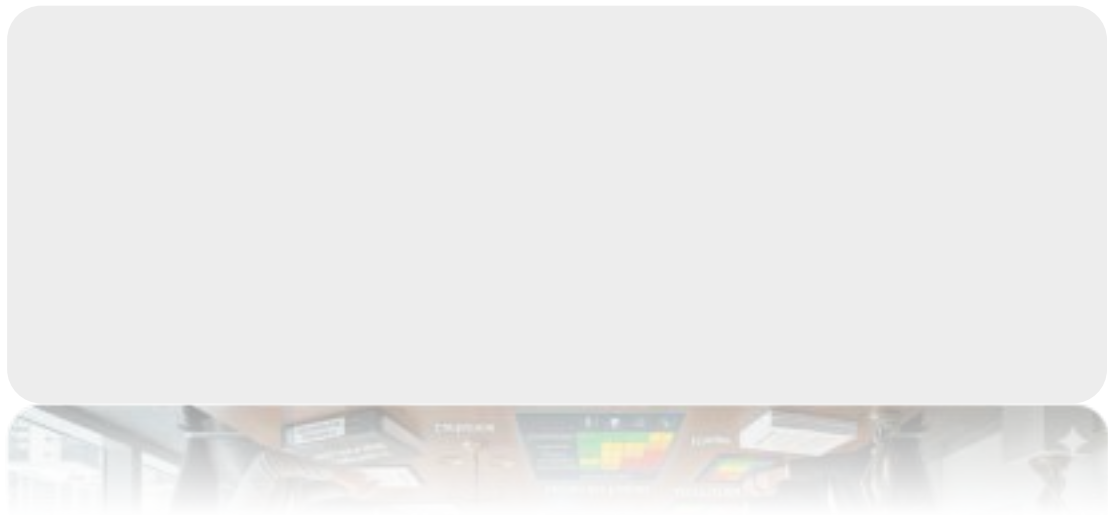
TABLE DES MATIERES

CISSP.....	1
Domaine 1 : Sécurité et gestion des risques	6
1.1 - Éthique professionnelle	7
1.2 - Concepts fondamentaux de sécurité	9
1.3 - Gouvernance de la sécurité.....	12
1.4 - Conformité, lois et réglementations	15
1.5 - Types d'investigations.....	18
1.6 - Gouvernance Documentaire.....	20
1.7 - Continuité des activités.....	22
1.8 - Sécurité du personnel	24
1.9 - Concepts de gestion des risques	26
1.10 - Modélisation des menaces	30
1.11 - Gestion des risques de la chaîne d'approvisionnement.....	33
1.12 - Sensibilisation, éducation et formation à la sécurité.....	35
Domaine 2 : Sécurité des Actifs	38
2.1 - Sécurité des actifs et Données sensibles.....	39
2.2 - Établir les exigences de manipulation de l'information et des actifs	42
2.3 - Provisionnement sécurisé de l'information et des actifs	44
2.4 - Gestion du cycle de vie des données	47
2.5 - Rétention appropriée des actifs - EOL & EOS.....	50
2.6 - Contrôles de sécurité des données et conformité.....	52
Domaine 3 : Architecture et Ingénierie de la Sécurité	55
3.1 - Principes de conception sécurisée.....	56
3.2 - Modèles de sécurité – Biba & Bell-LaPadula	59
3.3 - Sélection des contrôles basée sur les exigences du système	64
3.4 - Capacités de sécurité des systèmes d'information	66
3.5 - vulnérabilités des architectures et conceptions.....	69

3.6 - Sélection et détermination des solutions cryptographiques	74
3.7 - Comprendre les méthodes d'attaques cryptanalytiques	80
3.8 - Principes de sécurité pour la conception des sites et installations	82
3.9 - Conception des contrôles de sécurité des sites et installations	85
3.10 - Gestion du cycle de vie des systèmes d'information.....	89
Domaine 4 : Sécurité des communications et des réseaux	91
4.1 – Principes des architectures réseau et sécurité.....	92
4.2 - Composants réseaux sécurisés.....	99
4.3 - Implémenter des canaux de communication sécurisés	102
Domaine 5 : Gestion des identités et des accès (IAM).....	105
5.1 - Contrôle de l'accès physique et logique aux actifs	106
5.2 - Stratégie d'identification et d'authentification	109
5.3 - Identité fédérée avec un service.....	113
5.4 - Implémenter et gérer les mécanismes d'autorisation.....	116
5.5 - Gérer le cycle de vie du provisionnement des identités et des accès	119
5.6 - Implémenter des systèmes d'authentification	121
Domaine 6 : Évaluation et tests de la sécurité.....	124
6.1 - Concevoir et valider les stratégies d'évaluation, de test et d'audit.....	125
6.2 - Mener des tests de sécurité et gestion des vulnérabilités	127
6.3 - Collecter les données des processus de sécurité	130
6.4 - Analyser les résultats des tests et générer des rapports	133
6.5 - Mener ou faciliter les audits de sécurité.....	135
Domaine 7 : Opérations de sécurité	139
7.1 - Investigations et enquêtes	140
7.2 - Journalisation et surveillance.....	143
7.3 - Gestion des configurations	146
7.4 - Concepts fondamentaux des opérations de sécurité.....	148
7.5 - Protection des ressources.....	150
7.6 - Gestion des incidents.....	153

7.7 - Implémenter des mesures de détection et de prévention	155
7.8 - Gestion des vulnérabilités et des correctifs	158
7.9 - Processus de gestion des changements.....	160
7.10 - Stratégies de récupération	163
7.11 - Processus de reprise après sinistre	166
7.12 - Tests du plan de reprise après sinistre.....	168
7.13 - Maintenance du plan.....	170
7.14 - Mettre en oeuvre et gérer la sécurité physique	172
7.15 - Sécurité du personnel.....	175
Domaine 8 : Sécurité du développement logiciel.....	178
8.1 - Sécurité dans le SDLC	179
8.2 - Contrôles de sécurité dans l'écosystème de développement.....	182
8.3 - Évaluer l'efficacité de la sécurité logicielle	184
8.4 - Évaluer l'impact des logiciels acquis sur la sécurité	187
8.5 - Directives et standards de codage sécurisé.....	190
BONUS : Fiches de dernière minute	193
BONUS 1 - Penser comme un Manager	194
BONUS 2 - Le Code d'Éthique de l'ISC2.....	196
BONUS 3 - Stratégie de l'Examen	198
BONUS 4 - Formules et Métriques	200
BONUS 5 - Loi, Réglementations et Propriété Intellectuelle.....	202
BONUS 6 - Cadres de Gouvernance	204
BONUS 7 - Le Dictionnaire des Acronymes "Pièges"	206
BONUS 8 - Les Modèles de Sécurité.....	208
BONUS 9 - Le Modèle OSI	210
BONUS 10 - L'Ordre des Processus Chronologiques	212

DOMAINE 1 : SECURITE ET GESTION DES RISQUES



1.1 - ÉTHIQUE PROFESSIONNELLE

Résumé Général

L'objectif de ce sous-domaine est de garantir que les professionnels de la cybersécurité agissent avec intégrité, en priorisant la sécurité du public et en respectant les lois et politiques de leur organisation.

Concepts Clés à retenir

- Code d'éthique de l'ISC : Tout candidat et membre doit s'y conformer. Il est structuré en 4 canons obligatoires.

Les 4 Canons de l'ISC dans l'ordre de priorité :

1. Protéger la société, le bien commun, la confiance nécessaire du public et les infrastructures.
2. Agir de manière honorable, honnête, juste, responsable et légale.
3. Fournir un service diligent et compétent au service de la direction.
4. Faire progresser et protéger la profession.

- Code d'éthique organisationnel : Définit les valeurs, standards et comportements attendus dans l'entreprise. Il couvre les conflits d'intérêts (éviter de s'avantager soi-même), la confidentialité, la conformité légale et le respect sur le lieu de travail (anti-harcèlement).
- Résolution de conflits éthiques : Un CISSP doit équilibrer l'éthique de l'ISC avec les exigences de son organisation. En cas de conflit, il faut toujours suivre le standard le plus strict.

Ne pas confondre

- Ordre des Canons : L'ordre n'est pas aléatoire, il définit la priorité. Si le Canon 3 (fidélité) entre en conflit avec le Canon 1 (protéger la société), c'est le Canon 1 qui gagne. La société et les vies humaines priment sur le secret professionnel.
- Éthique vs Légalité : Une action peut être légale mais contraire à l'éthique de l'ISC. Il est nécessaire d'agir de manière "honorable" et "juste", au-delà de la simple légalité.

Moyens Mnémotechniques

- **PAPA** (Pour retenir l'ordre des Canons) :
 - a. **Protéger** la société.
 - b. **Agir** légalement/honnêtement.
 - c. **Pourvoir** un service compétent.
 - d. **Avancer** la profession.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Priorité absolue à la vie humaine : Si une situation met en danger la vie des personnes (par exemple, un feu dans un data center), la bonne réponse est toujours de sauver les vies humaines avant les actifs matériels ou les données.
- Dénonciation (Whistleblowing) : L'examen teste souvent le respect des procédures. Si tu découvres une activité illégale de ton employeur, tu dois alerter le management ou suivre les canaux internes de l'entreprise avant d'alerter les autorités externes (à moins d'un danger de mort immédiat).

1.2 - CONCEPTS FONDAMENTAUX DE SECURITE

Résumé Général

La sécurité repose sur l'équilibre entre la protection des données (Confidentialité, Intégrité, Disponibilité) et le contrôle rigoureux des entités qui tentent d'y accéder (Identification, Authentification, Autorisation, Audit) pour protéger les missions de l'entreprise.

Concepts Clés à retenir

- La Triade **CIA** (Le cœur de la sécurité) :
 - **Confidentialité** : S'assurer que seules les personnes autorisées y accèdent (Chiffrement, Contrôle d'accès).
 - **Intégrité** : Garantir l'exactitude, la cohérence et la fiabilité des données. Empêcher les modifications non autorisées (Hashes, Signatures numériques).
 - **Disponibilité** (Availability) : S'assurer que les données et les systèmes sont accessibles en cas de besoin (Tolérance aux pannes, Sauvegardes).
- La Triade **DAD** (L'inverse de la CIA) : Les attaques visent la **Divulgarion** (Disclosure), **l'Altération** (Alteration) et le **Déni/Destruction** (Denial).
- Le cycle **IAAA** :
 - a. **Identification** : Fournir une identité unique (ex : un nom d'utilisateur).
 - b. **Authentification** : Prouver cette identité (ex : mot de passe, biométrie, token).
 - c. **Autorisation** : Déterminer ce que le sujet a le droit de faire en fonction de ses privilèges (ex : listes de contrôle d'accès - ACLs).
 - d. **Audit** (et Accounting/Accountability) : Enregistrer et surveiller les actions de manière traçable pour garantir la responsabilité (Accountability) d'un sujet.

- **Non-répudiation** : Garantit l'intégrité et l'origine des données, empêchant une personne de nier avoir participé à une transaction (réalisé via signatures numériques).

Protocoles, Cadres ou Technologies

- Confidentialité : Utilise le chiffrement (Encryption).
- Intégrité : Utilise les Checksums, fonctions de hachage (Hash) et signatures numériques.
- Accountability : Le MFA (Authentification multi-facteurs) renforce la vérification d'identité et réduit les risques d'usurpation, rendant les preuves défendables au tribunal.

Ne pas confondre

- Identification vs Authentification : L'identification est une étiquette (reconnaître l'utilisateur), l'authentification est la preuve de cette étiquette (vérifier l'identité).
- Auditing vs Accountability : L'audit est l'acte technique d'enregistrer les événements. L'Accountability est la conséquence : le fait qu'une personne doive répondre juridiquement ou administrativement de ses actes documentés.

Moyens Mnémotechniques

- CIA = Confidentialité, Intégrité, Availability.
- IAAA = Identification Authentification Autorisation Audit / Accountability.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Le piège de la Confidentialité par défaut : Pour le CISSP, la Confidentialité n'est pas toujours le plus important ! Pour une banque ou un hôpital, l'Intégrité et la Disponibilité sont souvent prioritaires.
- Penser comme un Manager : Un technicien se demande "Quel outil règle ça ?" (Ex : un pare-feu). Le CISSP se demande "Quelle politique ou processus réduit le mieux le risque ?".
- La sécurité est un équilibre : Il ne faut pas chercher la sécurité "parfaite", mais la sécurité qui équilibre le risque, le coût, la conformité et la continuité des affaires.

1.3 - GOUVERNANCE DE LA SECURITE

Résumé Général

La sécurité de l'information doit être alignée sur la stratégie et la mission de l'entreprise. Ce domaine couvre la gouvernance descendante (Top-Down), les responsabilités strictes des acteurs de l'entreprise et les cadres normatifs utilisés pour structurer la sécurité.

Concepts Clés à retenir

- **Alignement sur la stratégie d'entreprise** : La sécurité est un "Business Enabler" (facilitateur métier), pas un centre de coûts. Elle doit s'aligner sur la mission et les objectifs de l'entreprise.
- **Approche Top-Down** : La gouvernance de la sécurité doit venir de la haute direction (Senior Management). Elle ne doit jamais être "Bottom-up" (gérée uniquement par les techniciens).
- Processus organisationnels :
 - **Acquisitions** : Intégrer de nouveaux systèmes et personnels crée des risques. Exige une Due Diligence et des évaluations de sécurité rapides.
 - **Cessions** (Divestitures) : Séparer les systèmes. Le risque majeur est la fuite de données et l'accès résiduel. Il faut révoquer les accès et assurer la conformité.
- Rôles et Responsabilités de Sécurité :
 - **Senior / Executive Management** : A la responsabilité ultime (Accountability) de la sécurité. Peut déléguer l'autorité, mais jamais la responsabilité finale.
 - **Security Professional** : Traducteur entre l'entreprise et l'IT. Développe les politiques, standards, lignes directrices et procédures.
 - **Asset Owner** (Propriétaire de la donnée) : Un dirigeant métier qui classe la donnée et définit qui a un "Besoin d'en connaître" (Need-to-Know).

- **Custodian** (Dépositaire/Gardien) : Rôle technique (Sysadmin). Implémente les contrôles (sauvegardes, droits) au nom du Owner. Ne décide PAS du Need-to-Know.
- **Auditor** (Auditeur) : Valide la conformité de manière indépendante.
- **User** (Utilisateur) : Maillon faible. Doit suivre les politiques et comprendre les menaces (Phishing, Ransomware).

Protocoles, Cadres ou Technologies (Frameworks)

- **ISO/IEC 27000 / 27001** : Standard international pour établir un Système de Management de la Sécurité de l'Information (ISMS).
- **NIST 800-53 & RMF** : Catalogue massif de contrôles de sécurité et cadre de gestion des risques du gouvernement américain.
- **COBIT** : Développé par l'ISACA, axé sur l'alignement de l'IT avec les objectifs métiers de l'entreprise.
- **SABSA** : Architecture de sécurité d'entreprise basée sur les risques métiers et structurée en couches.
- **PCI DSS** : Standard obligatoire (non gouvernemental) pour toute entité traitant des cartes de paiement.
- **FedRAMP** : Standard du gouvernement américain pour évaluer la sécurité des fournisseurs Cloud.
- **ITIL** : Bonnes pratiques pour la gestion des services IT.

Ne pas confondre

- **Due Diligence vs Due Care** (Crucial pour le CISSP) :
 - Due Diligence (Diligence raisonnable) : L'étape de **Recherche et de Planification**. C'est "penser avant de faire". (Ex : enquêter sur les antécédents d'un fournisseur Cloud).
 - Due Care (Soins raisonnables) : L'étape **d'Exécution et d'Action**. C'est "faire les bonnes choses" après avoir évalué le risque. (Ex : installer le pare-feu, faire une formation phishing).
- Responsabilité (Accountability) du Management vs Rôle de l'IT : L'IT et les Custodians ne "possèdent" pas le risque. Le management possède le risque.

Moyens Mnémotechniques

- Due Diligence = Détective (Effectuer ses recherches).
- Care = Concrétiser (Mettre en œuvre).
- COBIT = Objectifs Commerciaux/Business ; SABSA = Architecture.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Qui blâmer en cas de faille ? Le CISO ou l'équipe technique ne portent jamais la responsabilité ultime. L'Accountability repose toujours sur le Conseil d'administration (Board) ou la Haute Direction.
- Politique d'abord : Les décisions sur les politiques sont toujours du ressort du management, pas des techniciens.
- Le piège de la technologie : Considérer la sécurité comme un blocage ou un "lock-down". Au contraire, le CISSP voit la sécurité comme un facilitateur (Business Enabler) qui permet à l'entreprise d'atteindre ses buts en maîtrisant le risque.

1.4 - CONFORMITE, LOIS ET REGLEMENTATIONS

Résumé Général

La sécurité ne s'opère pas en vase clos: elle est soumise à de nombreuses lois, réglementations et contraintes de conformité à travers le monde. L'objectif est de protéger l'entreprise sur le plan légal et économique, tout en protégeant les données personnelles (vie privée) et la propriété intellectuelle (PI).

Concepts Clés à retenir

- Propriété Intellectuelle (PI) :
 - Droits d'auteur (**Copyrights**) : Protège l'expression créative d'une idée (logiciel, livre, musique), pas l'idée elle-même. Dure 70 ans après la mort de l'auteur, ou 95/120 ans pour les œuvres anonymes/"work for hire". Pénalités jusqu'à 1M\$ et 10 ans de prison.
 - Marques déposées (**Trademarks**) : Protège l'image de marque (mots, logos, sons, couleurs) pour éviter la confusion sur le marché. Dure 10 ans, renouvelable indéfiniment.
 - Brevets (**Patents**) : Protège les inventions. Doit être nouveau, utile et NON évident. Accorde un contrôle exclusif de 20 ans au propriétaire, puis tombe dans le domaine public.
 - Secrets commerciaux (**Trade Secrets**) : Informations vitales pour la survie de l'entreprise (recette, algorithme). Ne sont protégés que si l'entreprise met en place des contrôles stricts (ex : NDA, accords de non-divulgaration). Loi : Economic Espionage Act (1996).
- Localisation vs Souveraineté des données :
 - **Localisation** : Obligation physique de stocker et traiter les données à l'intérieur des frontières d'un pays.
 - **Souveraineté** : Le principe selon lequel les données sont soumises aux lois et réglementations du pays où elles sont collectées/générées.
- Contrôles d'Import/Export (États-Unis) :

- **ITAR** : Régule les technologies militaires et de défense. Géré par le Département d'État.
- **EAR** : Régule les technologies à "double usage" (civil et militaire, ex : chiffrement commercial). Géré par le Département du Commerce.
- Rôles sous le **RGPD** (GDPR) :
 - **Data Subject** (Personne concernée) : L'individu à qui appartiennent les données.
 - **Data Controller** (Contrôleur) : L'entité qui décide du "pourquoi" et du "comment" les données sont traitées (ex : un hôpital).
 - **Data Processor** (Sous-traitant) : Le tiers qui traite les données pour le compte du Contrôleur (ex : le fournisseur Cloud).
 - **DPO** (Délégué à la protection des données) : Le garant de la conformité au sein de l'organisation.
- La règle de la personne prudente (**Prudent Person Rule**) : Issue des Federal Sentencing Guidelines, elle exige d'agir avec le soin, la diligence et la compétence qu'une personne "prudente" utiliserait dans des circonstances similaires.

Lois et Cadres de Conformité (À connaître par coeur)

- États-Unis (Privacy & Sécurité) :
 - **HIPAA & HITECH** : Protège les informations de santé (PHI - Protected Health Information).
 - **GLBA** : Oblige les institutions financières à protéger les données privées des consommateurs.
 - **COPPA** : Protège la vie privée des mineurs/enfants en ligne (contrôle parental).
 - **FERPA** : Protège les dossiers scolaires des étudiants.
 - **SOX** (Sarbanes-Oxley) : Lutte contre la fraude financière d'entreprise ; exige des contrôles internes forts et la responsabilité personnelle des PDG/CFO.
 - **CCPA** (Californie) : Similaire au RGPD pour les résidents californiens (Droit de savoir, de supprimer, d'Opt-Out).

- International (Privacy) :
 - **GDPR** (RGPD - UE) : Exigences de sécurité, notification de faille (72h), droit à l'oubli, minimisation des données.
 - **PIPEDA** : Loi canadienne sur la protection des données.
 - **PIPL** : Loi chinoise sur la protection des données.
 - **POPIA** : Loi sud-africaine sur la protection des données.
- Industrie :
 - **PCI DSS** : Obligatoire pour toute entité qui stocke, traite ou transmet des données de cartes bancaires (12 exigences strictes). Évalué par un QSA (Auditeur externe), un ISA (Auditeur interne) ou un SAQ (Auto-évaluation) selon le volume de transactions (Niveaux 1 à 4).

Ne pas confondre

- Brevet (Patent) vs Secret Commercial (Trade Secret) : Le Brevet rend l'invention publique en échange d'un monopole de 20 ans. Le Secret Commercial nécessite que l'information reste strictement secrète et n'a pas de limite de temps. Si on découvre ton secret par ingénierie légale, tu perds le secret commercial.
- Controller vs Processor (RGPD) : Le Controller décide, le Processor exécute selon les instructions. (Note : La responsabilité pèse principalement sur le Controller).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Les réglementations priment : Si une politique d'entreprise entre en conflit avec une loi locale (ex : demande de transfert de données vs lois sur la souveraineté), la loi prime toujours.
- La conformité n'égale pas la sécurité : Être conforme à PCI DSS ou HIPAA signifie que tu as atteint la "ligne de base" (baseline), mais cela ne signifie pas que le système est invulnérable. La sécurité va au-delà de la conformité.
- Contrats et Tiers (Procurement) : Tu ne peux pas "externaliser ta responsabilité légale". Si un fournisseur Cloud (Processor) perd les données de tes clients, ton entreprise (Controller) sera toujours tenue responsable. Il faut évaluer les tiers (Due Diligence).

1.5 - TYPES D'INVESTIGATIONS

Résumé Général

Les incidents de sécurité mènent souvent à des enquêtes. Ce sous-domaine décrit les différents types d'investigations (juridiques ou internes) et l'importance critique de la gestion des preuves, car une simple enquête interne (administrative) peut rapidement se transformer en affaire criminelle.

Concepts Clés à retenir

- **Investigation Administrative** (Interne) : Menée par l'organisation (RH, IT, Conformité).
 - Cible : Violations des politiques internes, mauvaise conduite.
 - Résultat : Sanctions disciplinaires (avertissement, licenciement).
- **Investigation Criminelle** : Menée par les forces de l'ordre (Police, FBI, etc.).
 - Cible : Violations de la loi pénale (vol, piratage, fraude).
 - Règle absolue : Respect extrêmement strict des preuves et de la chaîne de traçabilité (**Chain of Custody**).
 - Charge de la preuve : "Au-delà d'un doute raisonnable" (**Beyond a reasonable doubt**).
- **Investigation Civile** : Litiges juridiques entre des parties privées (individus ou entreprises).
 - Cible : Conflits de contrats, négligence, responsabilité.
 - Résultat : Compensations financières ou ordonnances du tribunal.
 - Charge de la preuve : "Prépondérance de la preuve" (**Preponderance of the evidence**).

- **Investigation Réglementaire** : Initiée par des organismes gouvernementaux (ex : SEC, CNIL/DPA) pour évaluer la conformité (GDPR, HIPAA).
 - Résultat : Amendes lourdes, audits forcés ou suspension d'activités.
- **Investigation de Standards de l'Industrie** : Menée par des évaluateurs pour certifier les bonnes pratiques (ex : Audits ISO, PCI DSS). Souvent volontaire mais contractuellement obligatoire.

Ne pas confondre

- "Au-delà d'un doute raisonnable" vs "Prépondérance de la preuve" :
 - Criminel = "Au-delà d'un doute raisonnable" (la preuve doit être incontestable car on risque la prison).
 - Civil = "Prépondérance de la preuve" (il suffit de prouver qu'il est plus probable qu'improbable (51%) que la personne soit en tort).
- Criminel vs Civil : Le criminel est géré par l'État avec des peines de prison. Le civil concerne des affaires privées avec des dommages financiers (amendes).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Penser "Chaîne de traçabilité" en permanence : Même lors d'une simple enquête administrative interne, tu dois manipuler les preuves comme si elles allaient finir au tribunal. Pourquoi ? Parce qu'un employé licencié peut poursuivre l'entreprise (Civil), ou tu peux découvrir un délit grave (Criminel).
- Impliquer le management / les ressources humaines : Dans les cas d'investigation administrative (fraude d'un employé), les techniciens IT ne doivent jamais agir seuls. Il faut impliquer les RH et les conseillers juridiques.

1.6 - GOUVERNANCE DOCUMENTAIRE

Résumé Général

Pour qu'un programme de sécurité soit structuré et auditable, il doit s'appuyer sur une hiérarchie stricte de documents. C'est ce qui transforme une volonté managériale en actions techniques concrètes.

Concepts Clés à retenir (La Hiérarchie Documentaire)

- **Politique** (Policy) : Quoi / Pourquoi ? Déclaration de haut niveau exprimant la volonté de la direction.
 - Stratégique, non spécifique à une technologie.
 - Approuvée par la Haute Direction (Senior Management).
 - OBLIGATOIRE.
- **Norme** (Standard) : Avec Quoi ? Exigences spécifiques (matérielles ou logicielles) pour répondre à la politique.
 - Ex : "Tous les PC doivent utiliser Windows 11" ou "AES-256 est le standard de chiffrement de l'entreprise".
 - OBLIGATOIRE.
- **Procédure** (Procedure) : Comment ? Instructions étape par étape.
 - Détails opérationnels pour accomplir une tâche spécifique (ex : comment créer un compte utilisateur).
 - OBLIGATOIRE.
- **Lignes directrices** (Guidelines) : Recommandations et bonnes pratiques suggérées.
 - Flexible, sert à guider quand aucune procédure stricte n'existe.
 - OPTIONNEL / NON OBLIGATOIRE.
- **Baselines (Lignes de base)** (Généralement inclut) :
 - Le niveau de sécurité minimum absolu requis pour un système (ex : image de configuration serveur durcie).

Ne pas confondre

- Policy vs Procedure : La politique vient du management et définit les règles générales. La procédure vient des techniciens et explique exactement comment l'appliquer étape par étape.
- Standard vs Guideline : Le Standard DOIT être respecté. La Guideline est un conseil (Optionnelle).

Moyens Mnémotechniques

La hiérarchie descendante (du plus général au plus précis): Politique Standard Procédure (PSP).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La Politique est Reine : Tout découle de la politique. Si une question te demande la première chose à vérifier avant de faire un changement technique ou de réagir à un événement, la réponse est "Vérifier la politique de l'entreprise".
- Validation du Management : Une politique n'a aucune valeur si elle n'est pas signée et soutenue par la Haute Direction (Sponsor).
- Le piège de la réponse technique : Trap : Choosing a technical fix when the right answer is a policy or governance document. L'examen CISSP s'attend à ce que tu penses au document de gouvernance (Politique/Procédure) avant de penser au câble ou au logiciel.

1.7 - CONTINUITE DES ACTIVITES

Résumé Général

La continuité des activités (BC) vise à garantir que les processus métiers critiques de l'organisation survivent et continuent de fonctionner à un niveau acceptable pendant et après une perturbation majeure.

Concepts Clés à retenir

- **Business Continuity (BC) vs Disaster Recovery (DR) :**
 - BC (Continuité des activités) : Se concentre sur la résilience et le maintien de la livraison des services critiques du point de vue métier.
 - DR (Reprise après sinistre) : Un sous-ensemble du BCP. Se concentre spécifiquement sur la restauration de l'infrastructure informatique et des systèmes de données.
- **Business Impact Analysis (BIA) :** L'étape fondatrice du BCP. Identifie les processus critiques, leurs dépendances et l'impact d'une interruption. Comprend 3 étapes officielles (NIST) :
 - a. Déterminer les processus métiers et leur criticité.
 - b. Identifier les besoins en ressources (Définir MTD, RTO, RPO).
 - c. Identifier les priorités de récupération des systèmes.
- **Métriques de récupération (Crucial pour l'examen) :**
 - **MTD (Maximum Tolerable Downtime) :** Le temps maximum où un système peut être hors ligne avant de causer des dommages irréversibles à l'entreprise.
 - **RTO (Recovery Time Objective) :** L'objectif de temps visé pour restaurer le système. Le RTO doit toujours être inférieur au MTD.
 - **RPO (Recovery Point Objective) :** La quantité maximale de perte de données acceptable (mesurée en temps, ex : "On accepte de perdre les 30 dernières minutes de données"). Définit la fréquence des sauvegardes.

- Processus de planification de la continuité informatique (NIST 800-34) en 7 étapes :
 1. **Développer la politique.**
 2. **Conduire le BIA.**
 3. **Identifier les contrôles préventifs.**
 4. **Développer les stratégies de récupération.**
 5. **Développer le plan (DRP).**
 6. **Tester, former et exercer.**
 7. **Maintenir le plan.**
- Dépendances externes : Les tiers (Cloud, SaaS, FAI, Logistique) introduisent des risques partagés. Leurs capacités de reprise doivent être évaluées et incluses dans le BIA via des SLAs stricts.

Protocoles, Cadres ou Technologies

- NIST SP 800-34 Rev. 1 : Contingency Planning Guide for Federal Information Systems. C'est le standard de référence pour les étapes du BCP et du BIA.

Ne pas confondre

- BC vs DR : Le BC sauve le Business (processus métier), le DR sauve les Serveurs et les Données (technologie).
- RTO vs RPO : RTO = Temps d'indisponibilité (Quand sera-t-on de nouveau en ligne ?). RPO = Perte de données (Combien de données a-t-on perdues en arrière ?).

Moyens Mnémotechniques

- $RTO < MTD$: Le Temps de Restauration (RTO) doit logiquement être plus court que le Temps de Mort Tolérable (MTD), sinon l'entreprise fait faillite avant la réparation.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La sécurité des vies d'abord (Life Safety) : En cas de désastre, la priorité absolue **#1** est la **vie des personnes**, **#2** la **continuité de la mission**, **#3** la **protection des actifs** (serveurs/données).
- Le piège de la technologie immédiate : Trap : Jumping to a technology fix before understanding the business process. Si une question demande la première étape pour préparer une sauvegarde,

la réponse est "Faire le BIA", pas "Acheter des disques durs". Le métier dicte la technologie.

1.8 - SECURITE DU PERSONNEL

Résumé Général

L'humain est souvent le maillon le plus faible en sécurité. Ce sous-domaine encadre la gestion des risques liés aux employés et aux tiers tout au long de leur cycle de vie: avant l'embauche, pendant l'emploi et après leur départ.

Concepts Clés à retenir

- Sécurité avant l'embauche (**Screening**) : Vérification des antécédents criminels, vérification des références, vérification de solvabilité (selon le rôle), accords de non-divulgence (NDAs). Doit être adapté au niveau de risque du poste (Role-Based Risk Assessment).
- Accords et Politiques d'emploi (Enforcing Security) :
 - **AUP (Acceptable Use Policy)** : Définit ce que l'employé peut et ne peut pas faire sur les systèmes de l'entreprise.
 - **NDA (Non-Disclosure Agreement)** : Protège la confidentialité des secrets de l'entreprise.
 - **Clause de non-concurrence** (Non-Compete) : Limite le risque post-emploi de voir un employé partir chez un concurrent direct.
 - **Clauses de propriété de la PI** : Clarifie que tout ce qui est créé pendant le temps de travail appartient à l'organisation.
 - **Code de conduite** : Fixe les attentes éthiques.
- Transitions du personnel (Lifecycle) :
 - **Onboarding** (Embauche) : Formation à la sécurité, attribution des accès stricts selon le moindre privilège.
 - **Transfers** (Mouvements internes) : Réévaluation des accès : il faut supprimer les anciens droits et ajouter les nouveaux pour éviter la "dérive des privilèges" (Privilege Creep). Retraitement si le profil de risque change.

- **Offboarding** (Départ/Licenciement) : Désactiver les accès en premier (souvent avant même que l'employé ne soit averti en cas de licenciement hostile), récupérer le matériel, mener l'entretien de départ (Exit Interview) pour rappeler le NDA.
- Gestion des risques liés aux Tiers (Vendors/Contractors) : Ils ont besoin d'accéder à vos systèmes mais sont des portes d'entrée non surveillées. Exige des contrôles et des accords stricts.

Protocoles, Cadres ou Technologies

- **SLA (Service Level Agreement)** : Définit les niveaux de performance attendus (ex : disponibilité 99.9%, temps de réponse).
- **MSA (Master Service Agreement)** : Le contrat cadre global (paiement, lois applicables, litiges). Les SLAs y sont rattachés.
- **DPA (Data Processing Agreement)** : Contrat requis par les lois sur la vie privée (RGPD) définissant qui est Contrôleur/Sous-traitant et comment les données sont protégées.

Ne pas confondre

- SLA vs NDA : Le SLA garantit la Disponibilité/Performance, le NDA garantit la Confidentialité.
- Onboarding vs Transfers : Le piège classique est d'oublier de retirer les anciens accès lorsqu'un employé change de service. Les transferts nécessitent une révocation systématique des droits obsolètes.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La sécurité du personnel ne se limite pas au recrutement : C'est un processus continu de la vérification des antécédents jusqu'à l'entretien de départ.
- Licenciement : L'action technique #1 lors d'un licenciement est la désactivation (révocation) du compte utilisateur pour protéger les actifs, suivie de la confiscation du matériel.
- Tiers (Third-Party) : Sous-traiter une tâche à un fournisseur ne transfère jamais l'Accountability (la responsabilité finale) de l'entreprise face aux régulateurs.

1.9 - CONCEPTS DE GESTION DES RISQUES

Résumé Général

La gestion des risques est le coeur absolu du CISSP. Le but n'est pas d'éliminer le risque (ce qui est impossible), mais de l'identifier, de l'évaluer, et de le réduire à un niveau acceptable pour le management afin de protéger les actifs de l'entreprise.

Concepts Clés à retenir

- Terminologie fondamentale :
 - **Risque = Menace × Vulnérabilité.** (Probabilité qu'une menace exploite une vulnérabilité pour causer un dommage).
 - **Actif (Asset) : Toute chose ayant de la valeur** (Personnes, Données, Serveurs, Réputation).
 - **Menace (Threat) : Le danger** (ex : un hacker, un tremblement de terre).
 - **Vulnérabilité (Vulnerability) : Une faiblesse ou l'absence de contrôle** (ex : un logiciel non mis à jour).
 - **Sauvegarde/Contre-mesure (Safeguard) : Ce qui atténue le risque.**
- Évaluation des Actifs (**Asset Valuation**) : La valeur n'est pas que matérielle. Elle inclut l'impact réglementaire, la réputation, et la valeur humaine.
- Analyse de Risque Quantitative (Basée sur l'Argent) :
 - **AV (Asset Value)** : Valeur monétaire de l'actif.
 - **EF (Exposure Factor)** : Pourcentage de l'actif qui serait perdu si la menace se réalise.
 - **SLE (Single Loss Expectancy)** : Coût d'un seul incident.
 - **$SLE = AV \times EF$**
 - **ARO (Annualized Rate of Occurrence)** : Fréquence estimée de l'incident par an.

- **ALE (Annualized Loss Expectancy)** : Coût total annuel du risque.
 - **ALE = SLE × ARO**
- Coût / Bénéfice (**Annual Cost of Safeguard**) : Le coût annuel de la protection (**ACS**) ne doit jamais dépasser l'ALE avant contrôle.
- Analyse de Risque Qualitative : Basée sur des opinions d'experts, des scénarios, et classée par niveaux (Faible, Moyen, Élevé) ou des cartes de chaleur (**Heat maps**). Utilisée quand on manque de données financières précises.
- Réponses aux Risques (**Risk Response**) :
 - a. **Atténuation** (Mitigation/Reducing) : Implémenter des contrôles/contre-mesures.
 - b. **Transfert** (Assignment/Transfer) : Partager le risque (ex : Assurance cybersécurité, externalisation).
 - c. **Évitement** (Avoidance) : Arrêter l'activité qui crée le risque (ex : fermer un service web non sécurisé).
 - d. **Acceptation** (Acceptance) : Le coût de la protection est plus élevé que la perte. Le management accepte formellement le risque.
 - e. **Rejet** (Rejection/Ignore) : Nier l'existence du risque. (Inacceptable pour le CISSP).
 - f. **Dissuasion** (Deterrence) : Décourager l'attaquant (ex : panneaux, gardes).

- Types de Contrôles :
 - **Directifs** : Règles de comportement (Politiques).
 - **Dissuasifs** (Deterrent) : Décourager (Amendes, chiens).
 - **Préventifs** : Empêcher l'incident (Pare-feu).
 - **Détectifs** : Identifier l'incident (IDS, Caméras).
 - **Correctifs** : Réparer/Mitiger pendant ou après l'incident (Antivirus qui supprime le fichier).
 - **Récupération** (Recovery) : Restaurer à la normale (Backups, DRP).
 - **Compensatoires** : Alternative quand le meilleur contrôle est impossible.

Protocoles, Cadres ou Technologies

- NIST RMF (Risk Management Framework - SP 800-37) : Processus structuré en 7 étapes :
 - **Préparer**
 - **Catégoriser**
 - **Sélectionner les contrôles**
 - **Implémenter**
 - **Évaluer**
 - **Autoriser**
 - **Surveiller**

Ne pas confondre

- Quantitative vs Qualitative : Quantitative = Argent, Chiffres précis, Mathématiques. Qualitative = Subjectif, Opinions, Couleurs (Rouge/Orange/Vert).
- Transfert vs Atténuation : Prendre une assurance transfère l'impact financier, mais n'atténue pas (ne réduit pas) la probabilité d'être piraté. L'assurance est un Transfert.
- Risque Total vs Risque Résiduel : Risque Total = Menace x Vulnérabilité x Valeur. Risque Résiduel = Risque Total - Contrôles appliqués. C'est le risque qui reste après atténuation (et qui doit être "Accepté").

Moyens Mnémotechniques

- Formules Quantitatives :
 - Pour un incident isolé : $SLE = AV \times EF$ (Single = Asset × Exposure)
 - Pour l'année : $ALE = SLE \times ARO$ (Annual = Single × Rate)

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- L'Acceptation du Risque : Seul le Management (Executive) a le droit d'accepter un risque, l'IT ne peut pas. Cette acceptation doit toujours être documentée formellement.
- Coût vs Valeur : On ne dépense jamais 100 000 \$ pour protéger un serveur qui vaut 10 000\$. La contre-mesure doit coûter moins cher que l'ALE.
- Piège technique : Choisir "installer un pare-feu" au lieu de "mener une analyse des risques". Le CISSP analyse toujours le risque avant d'appliquer une solution.

1.10 - MODELISATION DES MENACES

Résumé Général

La modélisation des menaces est une approche structurée et proactive visant à identifier, analyser et hiérarchiser les menaces potentielles pesant sur un système. L'objectif est de comprendre ce qui peut mal tourner et d'intégrer les contrôles de sécurité dès la conception.

Concepts Clés à retenir

- Étapes de la modélisation des menaces :
 - a. **Identifier les actifs** : Que protège-t-on ? (Données, systèmes).
 - b. **Identifier les menaces** : Que peut-il se passer de mal ? (Attaquants, accidents).
 - c. **Identifier les vulnérabilités** : Où sont les faiblesses ?
 - d. **Évaluer le risque** : Probabilité + Impact.
 - e. **Appliquer les contrôles** : Décider des atténuations.

- **STRIDE** : Méthodologie créée par Microsoft catégorisant les menaces en 6 groupes. On l'utilise pour identifier méthodiquement les failles techniques d'une application ou d'une architecture.
 - **Spoofing** (Usurpation d'identité) : Viole l'authenticité.
 - **Tampering** (Falsification) : Viole l'intégrité.
 - **Repudiation** (Répudiation) : Viole la non-répudiation.
 - **Information Disclosure** (Divulgateion) : Viole la confidentialité.
 - **Denial of Service** (Déni de service) : Viole la disponibilité.
 - **Elevation of Privilege** (Élévation de privilèges) : Viole l'autorisation.

- **P.A.S.T.A** (Process for Attack Simulation and Threat Analysis) : **Approche centrée sur le risque** en 7 étapes pour simuler les attaques. On choisit PASTA pour aligner directement la modélisation des menaces sur les risques métiers et les objectifs de l'entreprise.
 - Définir les objectifs métiers.
 - Définir la portée technique.
 - Décomposition et analyse de l'application.
 - Analyse des menaces.
 - Analyse des vulnérabilités.
 - Modélisation et simulation d'attaques.
 - Analyse des risques et de l'impact.
- **Cyber Kill Chain** : Modèle (de Lockheed Martin) se concentrant sur **le comportement et les étapes suivies par l'adversaire lors d'une attaque**.
 - **Reconnaissance** : Collecte d'informations techniques et organisationnelles sur la cible.
 - **Weaponization (Armement)** : Création d'une charge malveillante (*payload*) adaptée aux failles repérées.
 - **Delivery (Livraison)** : Transmission de l'arme à la victime (ex : courriel de phishing, clé USB).
 - **Exploitation** : Déclenchement du code malveillant en exploitant une vulnérabilité.
 - **Installation** : Implantation du malware sur le système pour garantir un accès persistant.
 - **Command & Control (C2)** : Ouverture d'un canal de communication discret pour piloter la machine à distance.
 - **Actions on Objectives** : Accomplissement du but de l'attaque (ex : exfiltration de données, Ransomware).

Ne pas confondre

- STRIDE vs PASTA : STRIDE est orienté développeur et catégorise techniquement les menaces. PASTA est orienté "Risque/Business" et s'aligne sur l'impact financier et métier de l'attaque.

Moyens Mnémotechniques

- Chaque lettre de STRIDE cible une violation précise de la sécurité :
 - Spoofing *Faux*
 - Tampering *Modifié*
 - Repudiation *Nié*
 - Information *Fuité*
 - DoS *Bloqué*
 - Elevation *Piraté* (droits admin)

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Proactif vs Réactif : La modélisation des menaces se fait pendant la phase de conception (Design), avant même d'écrire la première ligne de code. L'examen punit les approches où la sécurité est ajoutée "après coup" (bolt-on).

1.11 - GESTION DES RISQUES DE LA CHAÎNE D'APPROVISIONNEMENT

Résumé Général

Les entreprises dépendent massivement de tiers (Cloud, FAI, fournisseurs matériels et logiciels). Ce sous-domaine gère les risques hérités de ces dépendances, car une perturbation de la chaîne d'approvisionnement peut être pire qu'un désastre naturel.

Concepts Clés à retenir

- Évaluation et surveillance des tiers : Les fournisseurs doivent être évalués en continu (questionnaires, tests d'intrusion, rapports SOC 2) pour s'assurer qu'ils respectent les exigences de sécurité.
- Exigences minimales de sécurité : C'est le socle que tout fournisseur doit respecter (ex : chiffrement, MFA, conformité RGPD).
- **SLR (Service Level Requirements)** : Ce sont les **attentes de sécurité chiffrées** (ex : uptime de 99.99%, réponse aux incidents < 1h) qui seront intégrées dans les accords (SLA).
- Atténuations techniques de la Supply Chain :
 - **Silicon Root of Trust : Ancre de sécurité intégrée directement dans le matériel** (la puce) à la fabrication pour garantir un démarrage sécurisé (Secure Boot).
 - **PUF (Physically Unclonable Function)** : "Empreinte digitale" matérielle unique basée sur les imperfections de fabrication de la puce, impossible à copier.
 - **SBOM (Software Bill of Materials)** : "L'étiquette des ingrédients" d'un logiciel. Liste tous les composants, bibliothèques et dépendances pour traquer facilement les vulnérabilités cachées (ex : faille Log4j).

Ne pas confondre

- SLA vs SLR : Le SLA (Agreement) est le contrat final. Le SLR (Requirements) représente les exigences de sécurité spécifiques injectées dans ce contrat pour rendre le fournisseur redevable.
- **TPM (Trusted Platform Module)** vs Silicon Root of Trust : Le Silicon Root of Trust est un concept matériel profond (souvent à l'intérieur du CPU) validant le code avant même le chargement de l'OS, bien que les deux concepts soient liés à la confiance matérielle.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Le piège de la sous-traitance : *You can outsource the work, but you cannot outsource the accountability*. Si ton fournisseur Cloud subit une fuite des données de tes clients, ton entreprise reste ultimement responsable face à la loi.
- La sécurité ne s'arrête pas au pare-feu : L'état d'esprit CISSP exige une vision globale (écosystème entier). Une entreprise n'est pas sécurisée si son fournisseur de système de paie ne l'est pas.

1.12 - SENSIBILISATION, EDUCATION ET FORMATION A LA SECURITE

Résumé Général

L'humain est la cible privilégiée des attaquants. Un programme de formation transforme le personnel de "maillon faible" à "pare-feu humain". La formation doit être continue, mesurable et alignée sur les menaces actuelles.

Concepts Clés à retenir

- Ingénierie Sociale : Attaque exploitant la nature humaine (confiance, désir d'aider, curiosité).
- Typologie des attaques d'ingénierie sociale :
 - **Phishing** : Courriels frauduleux visant un large public.
 - **Spear Phishing** : Phishing ciblé sur une entreprise ou un groupe spécifique.
 - **Whaling** : Phishing très ciblé sur les cadres dirigeants (CEO, CFO).
 - **Vishing & Smishing** : Phishing par la voix (téléphone, usurpation d'ID) et par SMS.
 - **Spam / Spim** : Courrier indésirable / Message instantané (IM) indésirable.
 - **Shoulder Surfing** : Regarder par-dessus l'épaule pour voler des mots de passe. Contre-mesure : filtre de confidentialité sur l'écran.
 - **Baiting** (Appâtage) : Offrir quelque chose de valeur (logiciel gratuit, clé USB "perdue") pour infecter la victime.
 - **Dumpster Diving** (Fouille de poubelles) : Récupérer des infos dans les déchets (légal si poubelle publique !). Contre-mesure : Déchiqueteuse à coupe croisée (Cross-cut shredder).

- **Tailgating & Piggybacking** : Entrer physiquement dans une zone sécurisée en suivant quelqu'un. Contre-mesures : Mantraps (sas), tourniquets, gardes.
- **Typo squatting** : Rediriger l'utilisateur s'il fait une faute de frappe dans l'URL.
- Contre-mesures et Outils de formation :
 - Simulations d'ingénierie sociale (ex : faux courriels de phishing).
 - Programme de "Champions de la Sécurité" (pairs motivés dans les services).
 - Gamification (Quiz, badges pour rendre l'apprentissage mémorable).
 - Mises à jour périodiques (inclure l'IA, la Crypto, les Deepfakes).
- Mesure de l'efficacité du programme (Metrics) :
 - Basée sur les connaissances : Quiz avant/après formation.
 - Basée sur le comportement : Baisse du taux de clics lors des simulations de phishing.
 - Opérationnelle : Temps mis par les employés pour signaler une activité suspecte.

Ne pas confondre

- Tailgating vs Piggybacking : Dans le Tailgating, l'intrus se faufile sans le consentement de la personne autorisée. Dans le Piggybacking, l'employé autorisé tient consciemment la porte à l'intrus (souvent par politesse).
- Phishing vs Spear Phishing vs Whaling : Le phishing lance un "filet" large (peu importe qui clique). Le Spear cible "un poisson précis" (ex : comptabilité de l'entreprise). Le Whaling cible "la baleine" (le grand patron).

Moyens Mnémotechniques

- Vishing = Voix (Voice).
- Smishing = SMS.

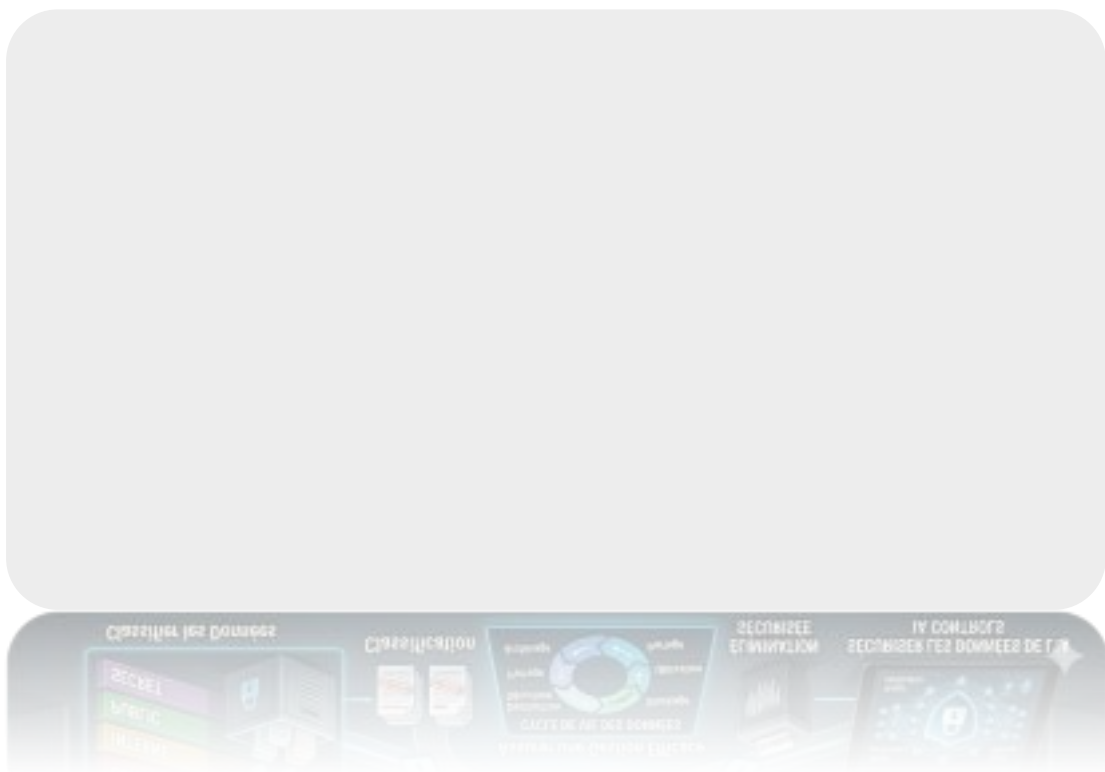
- Whaling = Whale (Baleine = Gros poisson/Directeur).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Formation continue : Le piège typique est de choisir "une formation vidéo annuelle pour la conformité". Pour le CISSP, la formation doit être continue, évolutive et mesurable.

Indicateur d'efficacité (KPI) : La meilleure preuve qu'un programme de sensibilisation fonctionne n'est pas "100% de complétion du module RH", mais "Une augmentation des signalements d'incidents par les employés" ou "une baisse du taux de clics sur les faux phishings".

DOMAINE 2 : SECURITE DES ACTIFS



2.1 - SECURITE DES ACTIFS ET DONNEES SENSIBLES

Résumé Général

L'objectif de ce sous-domaine est d'identifier, de valoriser et de classifier tous les actifs (données, matériel, logiciels, personnel) de l'entreprise afin d'appliquer le niveau de protection (contrôles) approprié pour prévenir les fuites de données. On ne peut pas protéger ce que l'on ne connaît pas.

Concepts Clés à retenir

- Cycle de gestion des données sensibles : Pour éviter les failles, la gestion se fait en 4 étapes :
 - **Étiquetage** (Labeling)
 - **Manipulation** (Handling)
 - **Stockage** (Storing)
 - **Destruction** (Destroying).
- Types de données sensibles :
 - **PII (Personally Identifiable Information)** : Toute information permettant d'identifier ou de tracer un individu (SSN, date de naissance, nom de jeune fille de la mère, biométrie).
 - **PII Non-sensible** : Trouvable dans les registres publics (annuaires). Peut être transmis en clair.
 - **PII Sensible** : Doit être chiffré au repos et en transit. Sa fuite cause des dommages à l'individu (nécessite souvent une notification de faille).
 - **PHI (Protected Health Information)** : Données démographiques, historiques médicaux, résultats de tests, assurances. Réglementé par HIPAA/HITECH. Géré par les professionnels de santé, mais aussi par tout employeur offrant une mutuelle santé à ses employés.

- **Proprietary Data** (Données exclusives) : **Informations uniques donnant un avantage concurrentiel** (secrets commerciaux, code source, listes de clients). Doivent être classifiées comme Confidentiel/Hautement Confidentiel et sécurisées techniquement et juridiquement (NDA).
- **Classification des données** : Détermine le niveau de sécurité à appliquer, la criticité et le Need-to-Know. Elle doit rester simple pour réussir. L'entreprise privée se focalise sur la triade CIA, tandis que le militaire se focalise sur la Confidentialité.
- **Classification Gouvernementale / Militaire** (De bas en haut) :
 - **Unclassified** (Non classifié) : Aucune protection spéciale (ex : manuels informatiques).
 - **Confidential** (Confidentiel) : Dommage (Damage). Nécessite une armoire avec barre métallique et cadenas.
 - **Secret** : Dommage grave (Serious Damage). Nécessite un coffre-fort approuvé.
 - **Top Secret** : Dommage exceptionnellement grave. Nécessite une chambre forte (Vault).
- **Classification Non-Gouvernementale / Privée** (De bas en haut) :
 - **Public** : Aucune protection (ex : offres d'emploi).
 - **Sensitive** (Sensible) : Infos financières, prévisions.
 - **Private** (Privé) : Infos RH, historique de travail.
 - **Confidential/Proprietary** (Confidentiel) : Secrets commerciaux, code source.
- **Classification des actifs** (Asset Classifications) : Va au-delà des données. Inclut les actifs physiques (serveurs), logiciels (licences, SBOM), humains (connaissances institutionnelles) et intangibles (réputation). Elle dépend de la valeur, de l'impact d'une compromission et des règles réglementaires.

Protocoles, Cadres ou Technologies

- HIPAA / HITECH : Lois américaines définissant les contrôles stricts pour les données PHI.

Ne pas confondre

- Classification Militaire vs Privée : L'examen joue souvent sur la hiérarchie. Dans le privé, Confidential est le plus haut niveau. Dans le militaire, Confidential est le niveau le plus bas des données classifiées (juste au-dessus de Unclassified).
- PII vs PHI : Le PHI concerne la santé et l'assurance médicale (HIPAA), tandis que le PII concerne l'identité civile et financière globale.

Moyens Mnémotechniques

- Hiérarchie Militaire (De haut en bas) : **TS-S-C-U** (Top Secret, Secret, Confidential, Unclassified).
- Hiérarchie Privée (De haut en bas) : **C-P-S-P** (Confidential, Private, Sensitive, Public).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Penser "Business" : La classification est pilotée par les affaires (Business-driven) et non par l'IT. C'est l'Asset Owner (le métier) qui décide de la valeur et de la classification, pas l'administrateur système.
- Protection proportionnelle : Le niveau de protection doit être dicté par la valeur de l'actif. On ne met pas une donnée "Publique" dans un coffre-fort.

2.2 - ÉTABLIR LES EXIGENCES DE MANIPULATION DE L'INFORMATION ET DES ACTIFS

Résumé Général

Avoir une étiquette de classification ne sert à rien si personne ne sait comment manipuler la donnée au quotidien. Ce sous-domaine encadre les règles de transport, d'utilisation et de protection physique des supports (médias) contenant des données sensibles.

Concepts Clés à retenir

- Handling (Manipulation) : Fait référence au transport sécurisé et à la gestion des médias (clés USB, disques, bandes) tout au long de leur durée de vie.
- Règles basées sur la valeur : Le personnel doit manipuler les données en se basant strictement sur leur valeur et leur classification.
- Politiques et Procédures : Elles sont obligatoires pour s'assurer que les employés comprennent comment manipuler les données sensibles (ex : interdiction de laisser des documents confidentiels sur un bureau).
- Protection des sauvegardes : La perte de contrôle des bandes de sauvegarde est un incident très fréquent. Règle d'or : Les supports de sauvegarde doivent être protégés avec exactement le même niveau de sécurité que les données de production originales.

Ne pas confondre

- Classification vs Handling (Manipulation) : La classification est le statut/la valeur de la donnée (ex : "Secret"). Le Handling est l'action procédurale qui en découle (ex : "Les documents Secrets doivent être transportés dans une mallette scellée").

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La technologie ne remplace pas le processus : Trap : Treating handling as "just encrypt it". Le chiffrement seul ne suffit pas. Le CISSP exige des contrôles physiques (coffres), procéduraux (logs de mouvements) et numériques (chiffrement) combinés (Defense in Depth).
- Responsabilité humaine : Les exigences de manipulation reposent sur des politiques claires et appliquées par les rôles (Role-enforced). Si une sauvegarde est perdue par un transporteur, c'est un échec de la politique de manipulation.

2.3 - PROVISIONNEMENT SECURISE DE L'INFORMATION ET DES ACTIFS

Résumé Général

Le provisionnement consiste à attribuer, configurer et délivrer des ressources (comptes, serveurs, données) de manière contrôlée, traçable et conforme au principe du moindre privilège, tout en gérant l'intégralité du cycle de vie de l'actif.

Concepts Clés à retenir

- Propriété de l'information et des actifs (Ownership) :
 - **Information Owner** (Propriétaire de l'information) : Responsable (Accountable) de la classification, des règles de rétention/manipulation, et des approbations d'accès.
 - **System Owner** (Propriétaire du système) : Responsable de l'exploitation sécurisée des plateformes matérielles et des applications qui hébergent la donnée.
 - **Custodians / Administrators** (Dépositaires) : Implémentent les contrôles techniques (sauvegardes, chiffrement, création des accès) dictés par les Owners.
 - **Users** (Utilisateurs) : Doivent suivre les procédures de manipulation, signaler les incidents et respecter la politique.
- **Inventaire des actifs** (Asset Inventory) : Registre unique faisant autorité (souvent une CMDB - Configuration Management Database). Il faut inventorier les actifs tangibles (serveurs) et intangibles (licences, code source). Doit inclure : propriétaire, dépositaire, classification, localisation. Objectif : Éviter les actifs "orphelins" (Shadow IT).

- Cycle de vie de la gestion des actifs (**Asset Lifecycle**) :
 - a. **Acquisition** : Assigner la propriété, classer l'actif, valider le fournisseur.
 - b. **Provisioning** (Provisionnement) : Configuration sécurisée, étiquetage, contrôle d'accès, chiffrement.
 - c. **Operation** (Exploitation) : Gestion des correctifs (patches), surveillance, tests de restauration des sauvegardes, revues d'accès.
 - d. **Sharing/Third Parties** (Partage) : Contrats, accords de partage de données, contrôles de conformité.
 - e. **Retention & Disposal** (Rétention et Destruction) : Suivre le calendrier de rétention, appliquer une destruction sécurisée (ex : NIST 800-88).

Protocoles, Cadres ou Technologies

- **CMDB (Configuration Management Database)** : Outil ITIL utilisé pour maintenir le registre centralisé et autoritaire de tous les actifs informatiques et leurs interdépendances.

Ne pas confondre

- **Information Owner vs System Owner** : Le propriétaire de l'information s'occupe de la donnée métier (ex : Directeur RH pour les fiches de paie). Le propriétaire du système s'occupe de l'infrastructure qui fait tourner l'application (ex : Responsable Infrastructure IT).
- **Shadow IT vs Orphaned Assets** : Le Shadow IT désigne les systèmes créés sans l'accord de l'IT. Les actifs orphelins sont des systèmes légitimes mais dont le propriétaire a quitté l'entreprise sans qu'un remplaçant ne soit assigné. Un bon inventaire prévient les deux.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Processus formel : Le **provisionnement** n'est pas juste "créer un compte". C'est un processus documenté :
 - **Demander**
 - **Approuver**
 - **Émettre**
 - **Tracer**
 - **Révoquer**
- Le piège de la rapidité : Trap : Granting broad access "to save time". L'examen testera la tentation de donner trop de droits pour aller vite. La bonne réponse est toujours d'appliquer le Moindre Privilège (**Least Privilege**).
- Cloud et Responsabilité partagée : Même si le fournisseur (ex : AWS) provisionne l'infrastructure, tes données = ton risque. L'entreprise reste responsable de la configuration et des accès.

2.4 - GESTION DU CYCLE DE VIE DES DONNEES

Résumé Général

La gestion du cycle de vie des données consiste à encadrer la donnée de sa création jusqu'à sa destruction sécurisée, en attribuant des rôles légaux stricts et en appliquant des contrôles pour limiter l'exposition de l'entreprise aux risques légaux et cyber.

Concepts Clés à retenir

- **Rôles** liés aux données (Très important) :
 - **Data Owner** (Propriétaire) : Responsabilité ultime (Accountability) de la donnée dans l'organisation.
 - **Data Controller** (Contrôleur) : Entité ou personne qui décide pourquoi et comment les données sont traitées (ex : l'entreprise qui collecte les données clients).
 - **Data Processor** (Sous-traitant) : Entité qui traite les données uniquement pour le compte du Controller (ex : le fournisseur Cloud AWS ou Azure).
 - **Data Custodian** (Dépositaire) : Personnel technique qui implémente les contrôles de sécurité.
 - **User / Subject** (Sujet) : La personne qui utilise la donnée, ou l'individu à qui la donnée personnelle appartient.
- **Étapes** critiques du cycle de vie :
 - 1. **Collecte** des données (Data Collection) : Doit être légale, transparente (consentement) et respecter la Minimisation des données (ne collecter que ce qui est strictement nécessaire).
 - 2. **Localisation** des données : Concerne la conformité (où la donnée est physiquement stockée) et la Souveraineté des données (la donnée est soumise aux lois du pays où elle réside, ce qui crée des conflits juridiques).

- 3. **Maintenance** des données : Sauvegardes régulières, contrôle qualité (éviter les données obsolètes ou corrompues), et application du moindre privilège.
- 4. **Rétention** des données : Conserver les données seulement le temps nécessaire aux obligations métiers ou légales.
- 5. **Remanence** et **Destruction** des données : La rémanence est le flux magnétique résiduel (les données "fantômes" qui restent sur un disque).
- **Méthodes de nettoyage / destruction** (NIST 800-88 - Sanitization) :
 - **Erasing** (Effacement simple) : Supprime le pointeur du système d'exploitation. La donnée est toujours là et facilement récupérable avec des outils de base. Insecure.
 - **Clearing / Overwriting** (Nettoyage/Écrasement) : Écrasement des données avec des suites de 0 et de 1. Protège contre la récupération standard. Permet la réutilisation du média en interne.
 - **Purging** (Purge) : Rend la donnée irrécupérable même avec des techniques de laboratoire avancées.
 - **Degaussing** (Démagnétisation) : Détruit les données en utilisant un puissant champ magnétique. Rend les disques durs (HDD) et bandes magnétiques inutilisables. Ne fonctionne PAS sur les supports optiques (CD) ni sur la mémoire Flash/SSD.
 - Destruction physique : Broyage (**Shredding**), incinération, pulvérisation. La méthode la plus sécurisée.
 - Cryptographic Erasure (**Crypto-Shredding**) : Détruire de façon permanente la clé de chiffrement ayant servi à chiffrer les données. Seule méthode viable dans le Cloud computing.

Protocoles, Cadres ou Technologies

- NIST 800-88 : Ligne directrice standard pour la destruction des médias (Guidelines for Media Sanitization).

Ne pas confondre

- Erasing vs Clearing vs Purging : L'Erasing est une simple suppression (corbeille). Le Clearing permet de recycler le matériel dans la même entreprise. Le Purging est exigé si le matériel quitte l'entreprise.
- Legal Hold (Suspension légale) vs Politique de Rétention : Si une entreprise fait l'objet d'une enquête ou d'un procès, le Legal Hold outrepassa la politique de rétention : les administrateurs doivent arrêter la destruction automatique des données concernées pour préserver les preuves.

Moyens Mnémotechniques

- Degaussing = Disques durs et bandes. (Rappelle-toi que l'aimant ne fera rien à une clé USB ou un SSD).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Destruction dans le Cloud : Si on te demande comment détruire des données hébergées chez un fournisseur Cloud (SaaS/IaaS), tu ne peux pas physiquement détruire les disques ou les démagnétiser. La réponse est l'effacement cryptographique (Cryptographic Erasure).
- Le risque de la sur-rétention : Le CISSP considère que garder des données trop longtemps n'est pas une "sécurité au cas où", c'est une augmentation massive de l'exposition au risque (violation de vie privée, piratage, coûts de stockage).

2.5 - RETENTION APPROPRIÉE DES ACTIFS - EOL & EOS

Résumé Général

Les actifs informatiques (matériels et logiciels) ont une durée de vie limitée. Conserver des systèmes obsolètes ou conserver des données sans limite de temps expose l'organisation à de graves risques de sécurité et de conformité.

Concepts Clés à retenir

- **Rétention des actifs** : L'objectif est de ne conserver les actifs (données, serveurs, accès personnels) que le temps requis par les besoins métiers, légaux ou réglementaires.
- **Risques de sous-rétention** (Under-retention) : Supprimer trop tôt entraîne la non-conformité, la perte de preuves légales et des lacunes dans la continuité des activités.
- **Risques de sur-rétention** (Over-retention) : Conserver trop longtemps entraîne une augmentation des coûts, une responsabilité juridique accrue et une surface d'attaque plus grande en cas de fuite.
- Gestion de l'obsolescence matérielle et logicielle :
 - **EOL (End of Life - Fin de vie)** : Le moment où le fournisseur cesse de vendre ou de développer le produit. L'entreprise doit alors commencer à planifier la migration ou le remplacement.
 - **EOS (End of Support - Fin de support)** : Le moment critique où le fournisseur cesse de publier des mises à jour et des correctifs de sécurité (patches). Cela crée un risque de sécurité absolu et non atténué (Legacy Systems vulnérables).
- Contrôles pour la fin de vie : L'entreprise doit maintenir un registre d'inventaire couplé aux dates EOL/EOS pour anticiper les fins de support.

Ne pas confondre

- EOL (End of Life) vs EOS (End of Support) : L'EOL est une alerte commerciale (le produit n'est plus commercialisé). L'EOS est une alerte de sécurité critique (le produit devient indéfendable contre les nouvelles vulnérabilités car il n'est plus patché).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Que faire avec un système en End of Support (EOS) ? Si une question demande ce qu'il faut faire avec une machine critique (ex : contrôle industriel SCADA) tournant sous un OS obsolète (ex : Windows XP) qui ne peut pas être mis à jour, la réponse du Manager (CISSP) est de mettre en place des contrôles compensatoires, comme la segmentation réseau / l'isolation (Air-gap) de ce système.

2.6 - CONTROLES DE SECURITE DES DONNEES ET CONFORMITE

Résumé Général

Une fois les données classifiées, l'organisation doit sélectionner et appliquer les contrôles de protection et de conformité adaptés à l'état physique de la donnée (au repos, en transit, en utilisation) tout en protégeant la propriété intellectuelle.

Concepts Clés à retenir

- Les 3 états de la donnée (**Data States**) :
 - a. Données au repos (**Data at Rest**) : Stockées sur des disques, SSD, clés USB, Cloud. Le risque principal est le vol physique ou l'accès non autorisé.
 - Contrôle : Chiffrement des disques/fichiers (ex : BitLocker), Contrôles d'accès physiques et logiques.
 - b. Données en transit (**Data in Transit**) : Données voyageant sur le réseau ou sur Internet. Le risque principal est l'interception (Sniffing, Man-in-the-Middle).
 - Contrôle : Chiffrement du trafic via TLS, IPSec, VPN, SSH.
 - c. Données en cours d'utilisation (**Data in Use**) : Données traitées activement dans la RAM ou le CPU. Le risque principal est un "memory dump" (vidage mémoire) ou une fuite par application.
 - Contrôle : Isolation des environnements (Sandboxing), Secure Enclave (espace matériel hautement sécurisé sur la puce), chiffrement de la mémoire.

- Ajustement des **cadres de conformité** :
 - **Scoping** (Délimitation) : Déterminer quelles parties du réseau ou de l'entreprise sont concernées par un standard. (Ex : Délimiter le réseau PCI DSS uniquement aux serveurs qui touchent aux cartes bancaires pour limiter les coûts d'audit).
 - **Tailoring** (Adaptation) : Personnaliser les contrôles de base d'un standard pour les adapter à la réalité de l'organisation, tout en maintenant le niveau de sécurité ou en ajoutant des contrôles compensatoires.
- Outils technologiques de protection :
 - **DRM (Digital Rights Management)** : Utilise le chiffrement pour protéger les droits d'auteur et empêcher la redistribution non autorisée de médias (musique, vidéos, documents). Protégé légalement par le DMCA.
 - **CASB (Cloud Access Security Broker)** : Logiciel (sur site ou cloud) placé entre les utilisateurs et les services Cloud. Il surveille les accès, applique les politiques de sécurité de l'entreprise (SSO, MFA), analyse les logs et détecte les comportements anormaux dans le Cloud.
 - **DLP (Data Loss Prevention)** : Technologie conçue pour bloquer, mettre en quarantaine ou alerter lors d'une tentative d'exfiltration de données sensibles. Identifie les données grâce à des motifs (Regex, ex : numéros de SSN) ou des classifications préalables.
 - Network DLP : Surveille le trafic sortant de l'entreprise.
 - Endpoint DLP : Installé sur le PC, bloque les transferts USB, impressions ou captures d'écran.
 - Storage/Cloud DLP : Scanne les serveurs de fichiers pour trouver des données non chiffrées mal rangées.

Protocoles, Cadres ou Technologies

- **SSL/TLS & IPSec** : Protocoles standards pour la protection des données en transit.
- **BitLocker / FileVault** : Outils standards de chiffrement de bout en bout pour les données au repos.

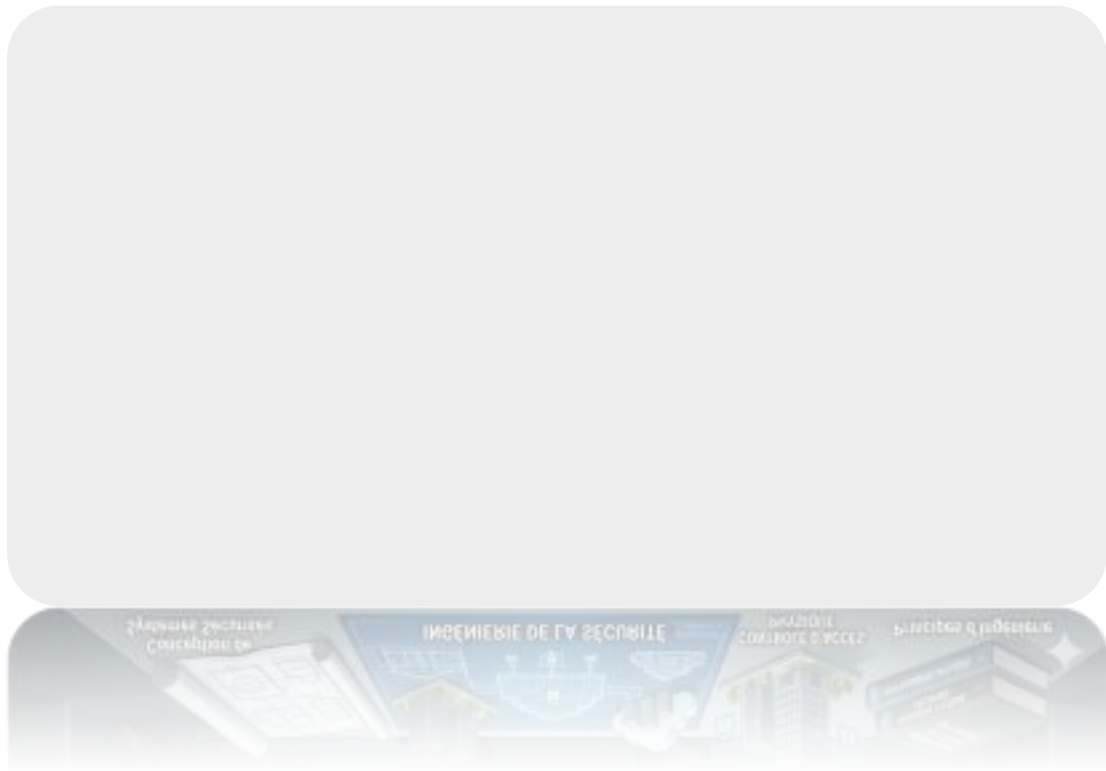
Ne pas confondre

- Scoping vs Tailoring : Le Scoping définit OÙ les règles s'appliquent (les limites du terrain). Le Tailoring définit COMMENT on ajuste les règles (retoucher le costume pour qu'il soit à la bonne taille).
- DLP Network vs DLP Endpoint : Si les employés volent des données via des clés USB, le Network DLP ne verra rien. Il faut un Endpoint DLP.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La limite du chiffrement : Attention au piège, les données en cours d'utilisation (in Use) ne sont généralement pas chiffrées lorsqu'elles sont traitées par le CPU.
- Conditions de succès d'un DLP : Un outil DLP ne fonctionnera jamais correctement si l'entreprise n'a pas effectué un travail rigoureux de Classification des données en amont. L'outil ne peut protéger que ce qu'on lui a appris à reconnaître.

DOMAINE 3 : ARCHITECTURE ET INGENIERIE DE LA SECURITE



3.1 - PRINCIPES DE CONCEPTION SECURISEE

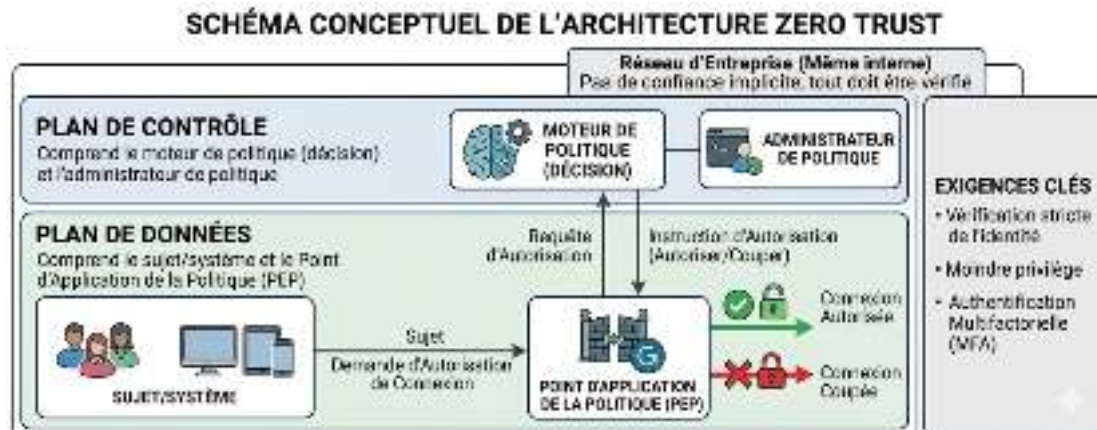
Résumé Général

La sécurité doit être intégrée dès la conception initiale de l'architecture d'un système, et non ajoutée après coup. Ce sous-domaine définit les principes d'ingénierie fondamentaux permettant de réduire la surface d'attaque, de limiter l'impact d'une compromission et de garantir la résilience de l'entreprise.

Concepts Clés à retenir

- **Moindre Privilège (Least Privilege)** : Limiter les droits d'accès des utilisateurs, comptes et processus au strict minimum nécessaire pour accomplir leur tâche.
- **Défauts Sécurisés (Secure Defaults)** : Les systèmes doivent être configurés par défaut sur l'option la plus sécurisée (ex : tout bloquer par défaut), même si cela limite l'utilisabilité initiale. L'administrateur devra ajuster ensuite.
- **Échec Sécurisé (Fail Securely)** : Lorsqu'un système rencontre une erreur ou plante, il doit revenir à un état sécurisé pour éviter d'exposer des données (ex : une porte électronique qui se verrouille en cas de panne de courant, sauf si la vie humaine est en jeu).
- **Séparation des Tâches (Separation of Duties - SoD)** : Nécessite plus d'une personne pour accomplir une tâche critique afin d'éviter la fraude et les erreurs.
- **KISS (Keep It Simple and Small)** : La complexité est l'ennemi de la sécurité. Un design simple réduit les erreurs et la surface d'attaque. Inclut des concepts comme **DRY** (Don't Repeat Yourself) et **YAGNI** (You Aren't Gonna Need It).
- **Zero Trust (Zéro Confiance)** : "Ne jamais faire confiance, toujours vérifier". Pas de confiance implicite, même à l'intérieur du réseau de l'entreprise. Exige une vérification stricte de l'identité, le moindre privilège et le MFA. Comprend deux plans :
 - **Data Plane** (Plan de données) : Le sujet/système, et le Point d'Application de la Politique (PEP) qui autorise ou coupe la connexion.

- **Control Plane** (Plan de contrôle) : Le moteur de politique (décision) et l'administrateur de politique.



- **Privacy by Design (PbD)** : La vie privée est intégrée dès le départ, par défaut, de bout en bout, de manière proactive et transparente pour l'utilisateur.
- **Responsabilité Partagée (Shared Responsibility)** : La sécurité est partagée entre plusieurs acteurs (ex : dans le Cloud SaaS, le fournisseur gère l'infrastructure, le client gère les accès et les données).
- **Infrastructure as Code (IaC)** : Gérer l'infrastructure via du code (modèles/scripts) au lieu de configurations manuelles. Permet l'automatisation, évite la dérive de configuration (Configuration Drift) et utilise le contrôle de version (Git/Branching) pour un retour en arrière facile en cas d'erreur.

Protocoles, Cadres ou Technologies

- **SASE (Secure Access Service Edge)** : Combine les fonctions de sécurité réseau et les capacités WAN (réseau étendu) directement dans le tissu réseau pour sécuriser les travailleurs distants.
- **SSE (Security Service Edge)** : Se concentre spécifiquement sur l'aspect sécurité du SASE délivré depuis le Cloud :
 - **SWG** (Secure Web Gateway)
 - **CASB** (Cloud Access Security Broker)
 - **ZTNA** – (Zero Trust Network Access)

Ne pas confondre

- Data Plane vs Control Plane (Zero Trust) : Le Control Plane prend la décision d'accès (le cerveau), le Data Plane applique physiquement la décision et fait passer le trafic (les muscles).
- SASE vs SSE : SASE englobe tous (Sécurité + Réseau SD-WAN). SSE est un sous-ensemble du SASE qui ne gère que les services de sécurité Cloud (CASB, Passerelles web), sans la partie routage réseau pur.

Moyens Mnémotechniques

- KISS : Keep It Simple and Small. Plus le code est complexe, plus il y a de trous.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La sécurité "**Bolt-on**" (rajoutée) : L'examen te pénalisera si tu choisis d'ajouter un outil de sécurité (ex : chiffrer à la fin) plutôt que de sélectionner une option prônant l'intégration de la sécurité dans le cycle de développement (SDLC) dès le premier jour.
- La dérive de configuration (**Drift**) : Si un administrateur fait un changement manuel rapide sur un serveur (hors procédure), cela crée une dérive. La solution CISSP est d'utiliser l'IaC (Infrastructure as Code) pour imposer une cohérence automatisée.

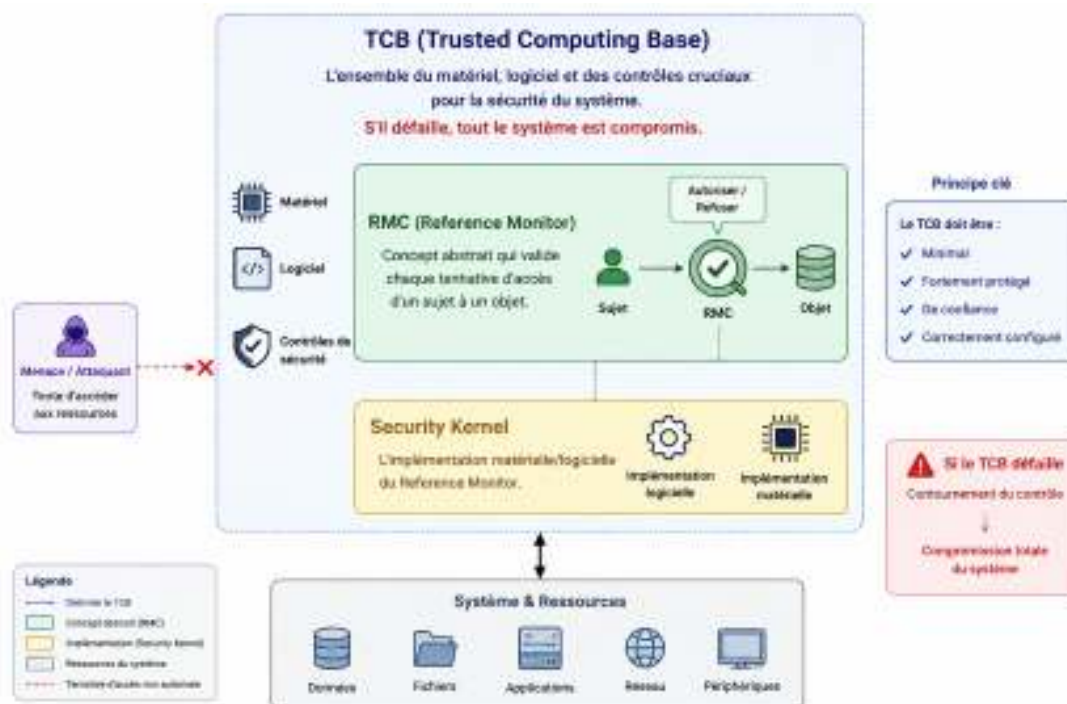
3.2 - MODELES DE SECURITE – BIBA & BELL-LAPADULA

Résumé Général

Les modèles de sécurité transforment les politiques de sécurité (abstraites) en règles mathématiques et logiques strictes que le système d'exploitation peut appliquer pour contrôler les accès. Ils sont la fondation des architectures hautement sécurisées.

Concepts Clés à retenir

- **TCB (Trusted Computing Base)** : L'ensemble du matériel, logiciel et des contrôles cruciaux pour la sécurité du système. S'il défaille, tout le système est compromis. Inclut :
 - **RMC (Reference Monitor)** : Concept abstrait qui valide chaque tentative d'accès d'un sujet à un objet.
 - **Security Kernel** : L'implémentation matérielle/logicielle du Reference Monitor.

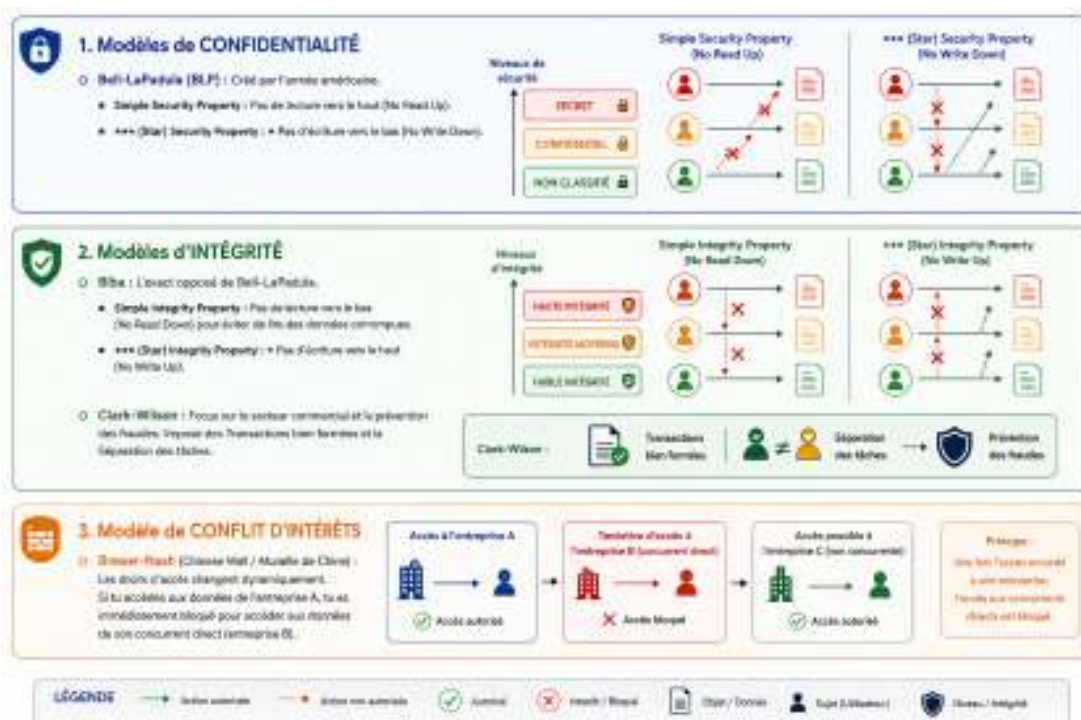


- **Modèle de Machine à États (State Machine)** : Le système ne passe que **d'un état sécurisé à un autre** état sécurisé lors d'une transition.
- **Modèle de Flux d'Informations (Information Flow)** : Empêche les **informations** de circuler de manière **non sécurisée** (ex : d'un niveau secret vers un niveau public).
- **Modèle de Non-interférence** : Les actions d'un utilisateur de haut niveau (Secret) ne doivent jamais interférer ou être visibles pour un utilisateur de bas niveau (Non-classifié) afin d'éviter les canaux cachés (**Covert Channels**).

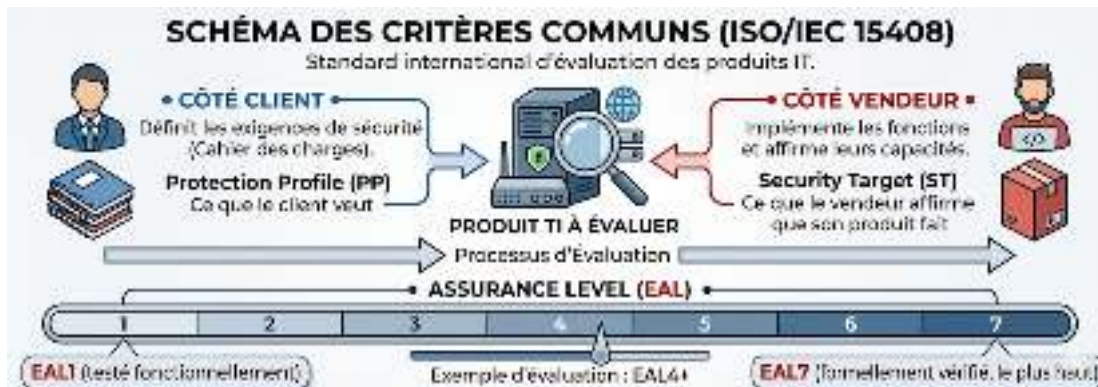


- **Matrice de Contrôle d'Accès (Access Control Matrix)** : Tableau croisant Sujets et Objets.
 - Lecture par colonne (Objet) = **Liste de contrôle d'accès (ACL)**.
 - Lecture par ligne (Sujet) = **Liste de capacités (Capabilities List)**.
- **Modèles de CONFIDENTIALITÉ** :
 - **Bell-LaPadula (BLP)** : Créé par l'armée américaine.
 - **Simple Security Property** : Pas de lecture vers le haut (**No Read Up**).

- **Star Security Property** : Pas d'écriture vers le bas (**No Write Down**).
- Modèles d'INTÉGRITÉ :
 - **Biba** : L'exact opposé de Bell-LaPadula.
 - **Simple Integrity Property** : Pas de lecture vers le bas (**No Read Down**) pour éviter de lire des données corrompues.
 - **Star Integrity Property** : Pas d'écriture vers le haut (**No Write Up**).
 - **Clark-Wilson** : Focus sur le secteur **commercial** et la prévention des fraudes. Impose des **Transactions bien formées** et la **Séparation des tâches**.
- Modèle de CONFLIT D'INTÉRÊTS :
 - **Brewer-Nash** (Chinese Wall / Muraille de Chine) : **Les droits d'accès changent dynamiquement**. Si tu accèdes aux données de l'entreprise A, tu es immédiatement bloqué pour accéder aux données de son concurrent direct (entreprise B).



- Critères Communs (**Common Criteria** - ISO/IEC 15408) : Standard international d'évaluation des produits IT.
 - **Protection Profile** (PP) : Ce que le client veut (le cahier des charges).
 - **Security Target** (ST) : Ce que le vendeur affirme que son produit fait.
 - **EAL** (Evaluation Assurance Level) : De **EAL1** (testé fonctionnellement) à **EAL7** (formellement vérifié, le plus haut).



Protocoles, Cadres ou Technologies

- **ATO (Authorization to Operate)** : Décision formelle du management d'accepter le risque et d'autoriser un système à traiter des données (Souvent valable 3 ans).

Ne pas confondre

- Bell-LaPadula vs Biba : Le piège n1 de l'examen.
 - **Bell-LaPadula = Confidentialité. WURD** (Write Up, read Down).
 - **Biba = Intégrité. WDRU** (Write down, Read Up).
- Reference Monitor vs Security Kernel : Le Reference Monitor est l'idée (l'abstraction de la police d'accès). Le Security Kernel est le code réel dans le système d'exploitation qui l'applique.
- Clark-Wilson vs Biba : Tous deux gèrent l'intégrité, mais Biba est mathématique (niveaux de confiance), tandis que Clark-Wilson est commercial (empêcher un employé de modifier un registre comptable sans passer par une transaction stricte).

Moyens Mnémotechniques

- Bell-LaPadula = Bloque La Publication (Confidentialité).
- Biba = L'inverse de Bell (Intégrité).
- Les niveaux EAL (1 à 7) : Retenir que **EAL 4** est "**Methodically designed, tested, and reviewed**" (Souvent le standard commercial acceptable).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Associer le modèle au bon scénario métier : Si la question parle de secret militaire, choisis Bell-LaPadula. Si elle parle de prévenir la fraude comptable, choisis Clark-Wilson. Si elle parle d'un cabinet d'audit gérant des clients concurrents, choisis Brewer-Nash.

3.3 - SELECTION DES CONTROLES BASEE SUR LES EXIGENCES DU SYSTEME

Résumé Général

Aucune entreprise ne peut appliquer tous les contrôles de sécurité existants. Ce sous-domaine décrit le processus visant à sélectionner, délimiter et adapter les contrôles de sécurité en fonction des risques réels, des exigences métiers et des réglementations applicables.

Concepts Clés à retenir

- 1. Définir les exigences de sécurité (**Requirements**) : Avant de choisir un contrôle, il faut comprendre les besoins métiers (Confidentialité, Intégrité, Disponibilité), les lois en vigueur et les résultats de l'analyse des risques (menaces, vulnérabilités, impacts).
- 2. Choisir les contrôles depuis un catalogue : Sélectionner une base de référence (**baseline**) issue d'un framework reconnu en fonction de son industrie ou de son secteur.
- 3. **Scoping** (Délimitation) : Le processus consistant à décider quels contrôles s'appliquent et lesquels ne s'appliquent pas, en fonction de la frontière du système. (Ex : exclure les systèmes qui ne traitent aucune donnée sensible).
- 4. **Tailoring** (Adaptation / Personnalisation) : Le processus consistant à personnaliser les contrôles de base pour les adapter à l'environnement spécifique, au profil de risque et aux besoins de l'entreprise (ajouter, retirer ou modifier).
- 5. Contrôles compensatoires (**Compensating Controls**) : Des mesures de sécurité alternatives mises en place lorsque le contrôle standard recommandé n'est techniquement pas faisable ou trop coûteux.

- 6. Priorisation basée sur le risque :
 - **Risque élevé** = contrôles plus forts et plus nombreux.
 - **Risque faible** = contrôles minimaux pour éviter la sur-ingénierie et l'impact négatif sur la productivité.
- 7. **Validation** : Vérifier que les contrôles sélectionnés répondent effectivement aux exigences initiales de Confidentialité, Intégrité et Disponibilité (CIA) et s'alignent sur la mission de l'entreprise.

Protocoles, Cadres ou Technologies

- NIST SP 800-53 : Catalogue complet de contrôles de sécurité et de confidentialité, principalement utilisé pour les systèmes fédéraux et gouvernementaux américains.
- PCI DSS, HIPAA, SOX, GDPR, ISO 27001 : Cadres, lois et réglementations spécifiques à l'industrie (cartes bancaires, santé, finance, vie privée) utilisés pour définir les exigences initiales et choisir les contrôles.

Ne pas confondre

- Scoping vs Tailoring :
 - Le **Scoping** répond à "**OÙ**" on applique les règles (définir les limites du terrain de jeu).
 - Le **Tailoring** répond à "**COMMENT**" on ajuste les règles (retailer le costume pour qu'il convienne parfaitement à l'entreprise).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- L'approche basée sur les risques (**Risk-Based Approach**) : C'est la réponse par défaut du CISSP. On ne sélectionne jamais un contrôle parce qu'il est "nouveau", "tendance" ou "le plus fort". On le sélectionne parce qu'une évaluation des risques a prouvé qu'il était nécessaire et rentable.
- Contrôles Compensatoires : Concept extrêmement testé. Si une réglementation exige un chiffrement, mais qu'un équipement obsolète ne le supporte pas, le Manager (CISSP) appliquera un contrôle compensatoire, comme l'isolation stricte (**Air-gap**) ou la surveillance accrue de ce réseau.

3.4 - CAPACITES DE SECURITE DES SYSTEMES D'INFORMATION

Résumé Général

L'architecture de sécurité repose sur le matériel, la mémoire et le système d'exploitation. Ce sous-domaine explore la manière dont les composants internes de l'ordinateur protègent les données contre les comportements malveillants, les défaillances et les fuites d'informations physiques.

Concepts Clés à retenir

- Anneaux de protection (**Protection Rings**) : Mécanismes isolant le code et les données pour améliorer la tolérance aux pannes et la sécurité.
 - Règle absolue : Plus le numéro de l'anneau est bas, plus le niveau de privilège est élevé (au centre du cercle). Les processus des anneaux inférieurs s'exécutent avant ceux des anneaux supérieurs.
 - **Ring 0** : Noyau de l'OS (Kernel) et mémoire. Fonctionne en "Supervisor / Privileged mode".
 - **Ring 1** : Autres composants de l'OS.
 - **Ring 2** : Pilotes (Drivers), protocoles.
 - **Ring 3** : Programmes et applications de l'utilisateur (User mode).
- Volatile vs Non-Volatile :
 - **Volatile** : Nécessite du courant pour conserver les informations (perd tout si éteint). Ex : RAM, CPU cache. Souvent utilisé comme stockage "Primaire".
 - **Non-Volatile** : Conserve les données sans courant. Ex : Disques durs, clés USB, ROM, Bandes. Souvent utilisé comme stockage "Secondaire".
- Types de Mémoire :
 - **ROM (Read-Only Memory)** : Non-volatile, l'utilisateur final ne peut pas écrire dessus.

- **EEPROM** : ROM effaçable électroniquement pour être réécrite (utilisée pour flasher les firmwares).
- **RAM (Random Access Memory)** : Mémoire volatile composée de puces dynamiques (DRAM).
- **Cache RAM** : Partie de la mémoire faite de **SRAM (Static RAM)**, beaucoup plus rapide et chère que la DRAM. Très efficace car les programmes lisent souvent les mêmes données.
- **Virtual Memory** (Mémoire virtuelle) : Gérée par l'OS (logiciel + matériel). Mappe les adresses virtuelles vers les adresses physiques. Permet de dépasser la capacité de la RAM physique via la "pagination" (**Paging/Swapping**) sur le disque dur.
- Protection de la mémoire : Empêche un processus d'interagir avec une zone mémoire qui ne lui est pas allouée. Utilise l'isolation, la mémoire virtuelle, la segmentation et les anneaux de protection.
- Stockage :
 - **Séquentiel** : Lecture dans l'ordre (**inefficace**). Ex : Bande magnétique (**Magnetic tape**).
 - Aléatoire/Direct (**Random**) : Fichiers accessibles dans n'importe quel ordre, **lecture/écriture rapides** (divisé en pistes et secteurs). Ex : RAM, Disque dur.
- **Firmware** (Micrologiciel) : Programme stocké sur une puce ROM/EEPROM (non-volatile). Ex : **BIOS/UEFI** (pour démarrer l'OS) ou firmware d'imprimante. Mis à jour pour corriger des bugs.
- **Émanations / Radiations électromagnétiques (EMR)** : Les écrans, claviers et câbles émettent des ondes qui peuvent être interceptées pour recréer les frappes ou l'affichage.
 - **Protections** : Blindage des câbles (**Shielding**), éloignement des équipements, **cages de Faraday** (bloque les ondes), bruit blanc (**White Noise** : générer un faux trafic), et **zones de contrôle**.
- **TPM (Trusted Platform Module)** : Crypto-processeur matériel dédié et inviolable (**tamper-resistant**). Génère et stocke de manière sécurisée les clés cryptographiques. Utilisé pour le **Secure Boot** (intégrité du démarrage) et le chiffrement de disque (ex : **BitLocker**).

Protocoles, Cadres ou Technologies

- **TEMPEST** : Technologie et standard militaire américain pour protéger les équipements contre l'espionnage des radiations électromagnétiques (EMR).

Ne pas confondre

- Ring 0 vs Ring 3 : Ring 0 est le cœur du système (Kernel), un malware qui y accède prend le contrôle total. Ring 3 est l'espace utilisateur, là où s'exécutent tes applications (Word, navigateur).
- Primary Storage vs Secondary Storage : Le stockage primaire (RAM) est ultra-rapide et volatile (le risque est qu'une clé de chiffrement y reste et soit extraite via un "memory dump"). Le stockage secondaire (Disque dur) est lent, permanent (le risque est le vol physique, nécessitant un chiffrement ou une destruction propre).

Moyens Mnémotechniques

- 0 est un Héros : Ring 0 = Kernel (Pouvoir absolu).
- Volatile vole : Si on coupe le courant, les données de la RAM "s'envolent".

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Menaces de la mémoire virtuelle : Les données sensibles (comme des mots de passe en clair) dans la RAM peuvent être écrites (swapped) temporairement sur le disque dur via la mémoire virtuelle (Paging file). Cela signifie qu'un disque non chiffré peut contenir des secrets extraits de la RAM.
- Protection EMR : Si on te demande la protection la plus efficace contre l'espionnage des câbles réseau en cuivre, la réponse est l'utilisation de câbles blindés (Shielded) ou de fibres optiques (immunisées contre les EMI).

3.5 - VULNERABILITES DES ARCHITECTURES ET CONCEPTIONS

Résumé Général

Les systèmes modernes sont complexes et interconnectés. Ce sous-domaine passe en revue les vulnérabilités inhérentes aux différentes architectures (Bases de données, Cloud, IoT, ICS, Virtuel) et les contrôles de conception permettant de les sécuriser.

Concepts Clés à retenir

- Architectures Client/Serveur vs Distribuées :
 - **Client-based** : Les contrôles sont sur le terminal (Antivirus, DLP local). Vulnérable au vol et au manque de patches.
 - **Server-based** : Contrôles centralisés (AD, Cloud). Une compromission affecte tous les clients.
 - **Systèmes Distribués** : Multiples noeuds travaillant comme un seul système (Cloud, CDNs).
 - Avantages : Transparence, scalabilité, tolérance aux pannes.
 - Inconvénients : Authentification complexe, risque d'interception des données en transit.
- Vulnérabilités et Sécurité des Bases de données :
 - Clé primaire (**Primary Key**) : Identifiant unique d'un enregistrement (ex : SSN).
 - Clé étrangère (**Foreign Key**) : Force la relation entre deux tables (intégrité référentielle).

- Tests **ACID** (Garantit l'intégrité) :
 - **Atomicity** : Tout s'exécute, ou rien du tout (Rollback en cas d'échec).
 - **Consistency** : Respecte toutes les contraintes d'intégrité définies.
 - **Isolation** : Les transactions n'interfèrent pas entre elles (invisibles tant que non terminées).
 - **Durability** : Une fois validée (commit), la transaction est permanente.
- Attaques de bases de données :
 - **Agrégation** (Aggregation) : Combiner plusieurs informations autorisées de faible sensibilité pour en déduire une information globale de haute sensibilité à laquelle l'utilisateur n'a pas accès.
 - **Inférence** (Inference) : Déduire des faits cachés à partir de faits connus (sans forcément les combiner massivement comme l'agrégation).
- Contrôles de sécurité DB :
 - **Vues** (Views) : Tables virtuelles cachant les colonnes sensibles (applique le Need-to-Know).
 - **Polyinstanciation** : Avoir plusieurs lignes avec la même clé primaire mais des niveaux de classification différents (Prévient l'inférence : l'utilisateur de bas niveau voit un faux nom, le directeur voit le vrai nom du projet secret).
 - **Bruit / Perturbation** (Noise) : Insérer de fausses données pour empêcher l'inférence statistique.
- Entrepôt de données (**Data Warehouse**) : Grand dépôt centralisé pour l'analyse et le reporting. Contient des données historiques de multiples sources. Le risque majeur est la Confidentialité (agrégation massive de PII). Contrôle clé : Chiffrement, RBAC, masquage (anonymisation).
- **ICS (Industrial Control Systems) / SCADA** : Systèmes contrôlant les infrastructures critiques (électricité, eau, gaz). Incluent les PLC (Automates) et capteurs. Priorité absolue : Disponibilité et Sécurité physique.

- **Cloud Computing :**
 - Pay-as-you-go, élasticité rapide.
 - Modèles : Public, Privé, Communautaire, Hybride.
 - Services : SaaS (Software), PaaS (Platform/Développeurs), IaaS (Infrastructure).
- **IoT (Internet of Things) :** Objets physiques connectés (domotique, capteurs). Risques : Systèmes embarqués (Embedded), souvent non sécurisés par défaut et difficiles à patcher.
- **Virtualisation / Hyperviseurs :** Permet d'héberger plusieurs OS (Machines Virtuelles) sur un même matériel.
 - **Type 1 (Bare-Metal) :** S'exécute directement sur le matériel (ex : ESXi, Hyper-V). Le plus sécurisé et performant.
 - **Type 2 (Hosted) :** S'exécute au-dessus d'un système d'exploitation classique (ex : VirtualBox). Moins performant.
- **Évolution de l'architecture :**
 - **Conteneurisation :** Remplace l'hyperviseur par un moteur partageant un seul noyau d'OS (Single Kernel) pour plusieurs conteneurs isolés. Densité 10 à 100 fois supérieure aux VMs.
 - **Microservices :** Casser une application monolithique en petits services indépendants.
 - **Serverless (FaaS) :** Le développeur fournit juste le code, le fournisseur Cloud gère toute l'infrastructure serveur.
- **Edge vs Fog Computing :**
 - **Edge Computing :** Traiter la donnée au plus près de sa création (sur l'appareil lui-même) pour une faible latence (temps réel).
 - **Fog Computing :** Une couche intermédiaire décentralisée entre le Edge et le Cloud central.

- **HPC (High-Performance Computing) / RTOS (Real-Time OS) :**
 - **HPC** : Supercalculateurs pour traitement de données massives en temps réel.
 - **RTOS** : OS spécialisé nécessitant un déterminisme absolu (le même input donne toujours la même réponse dans un délai strict). Utilisé dans l'aéronautique ou la robotique (sécurité critique de la vie).

Ne pas confondre

- Agrégation vs Inférence : **L'agrégation est un problème de quantité** (je rassemble 1000 données non-secrètes pour trouver le secret). **L'inférence est un problème de logique/déduction humaine** (je sais que Bob est le seul médecin à travailler de nuit, donc le patient traité cette nuit-là a été vu par Bob).
- Hyperviseur Type 1 vs Type 2 : Le Type 1 est le chef direct du matériel (Bare-metal = métal nu). Le Type 2 est juste un logiciel installé sur Windows ou Mac.
- IaaS vs PaaS vs SaaS :
 - IaaS = **Le fournisseur gère le réseau/serveur**, tu gères l'OS.
 - PaaS = **Le fournisseur gère l'OS**, tu gères l'application/le code.
 - **FaaS = Le fournisseur gère l'application**, tu gères **juste une fonction de code** (Serverless).
 - SaaS = **Le fournisseur gère tout**, tu gères juste tes données et accès.

Moyens Mnémotechniques

- Base de données ACID : Atomicity, Consistency, Isolation, Durability.
- Polyinstanciation : Poly = Plusieurs, Instanciation = Versions. Plusieurs versions d'une même ligne pour brouiller les pistes.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Le piège de la solution technique : Trap : Jumping to "install a tool". L'examen s'attend à ce que tu répondes par des solutions d'architecture (segmentation, politiques, isolation) plutôt que d'acheter un antivirus.
- Sécuriser les SCADA/ICS ou IoT obsolètes : Tu ne peux pas installer un antivirus sur un vieux système de vanne d'eau (ICS), cela le ferait planter (perte de disponibilité). La solution du CISSP est la segmentation du réseau (isoler physiquement ou logiquement l'équipement du reste d'internet).

3.6 - SELECTION ET DETERMINATION DES SOLUTIONS CRYPTOGRAPHIQUES

Résumé Général

La cryptographie protège les informations en présence d'adversaires. Ce sous-domaine détaille les algorithmes et les processus mathématiques qui garantissent la Confidentialité, l'Intégrité, l'Authentification et la non-répudiation des données, tout en insistant sur la gestion du cycle de vie des clés.

Concepts Clés à retenir

- Concepts fondamentaux :
 - **Cryptographie** : L'art de **cacher** le sens des communications.
 - **Cryptanalyse** : L'étude des méthodes pour **casser les codes** et chiffrements.
 - **Cryptologie** : **Cryptographie + Cryptanalyse**.
 - **Principe de Kerckhoffs** : Un système cryptographique doit **rester sécurisé même si tout est public** à son sujet, à l'exception de la clé.
- Algorithmes vs Clés (Cryptovariables) : L'algorithme est la "serrure" (la méthode mathématique), la clé est la "combinaison" unique. La sécurité dépend de la longueur et de la complexité de la clé, pas du secret de l'algorithme.
- Types de chiffrements (Ciphers) :
 - **Block Ciphers** (Chiffrement par blocs) : Chiffre les données par blocs fixes (ex : 64 ou 128 bits). Idéal pour les grandes quantités de données.
 - **Stream Ciphers** (Chiffrement par flux) : Chiffre bit par bit ou octet par octet. Idéal quand les ressources matérielles sont limitées (ex : RC4).
 - **Substitution** : Remplace une lettre par une autre (ex : Code de César).
 - **Transposition** : Mélange l'ordre des lettres sans les changer.

- **Chiffrement Symétrique** (Clé privée/secrète partagée) :
 - Utilise la même clé pour chiffrer et déchiffrer.
 - Avantages : Très rapide, efficace, idéal pour de gros volumes de données.
 - Inconvénients : Distribution des clés extrêmement complexe, problème de scalabilité (Formule : $N(N-1)/2$ clés nécessaires pour N utilisateurs), et aucune non-répudiation (puisque les deux parties ont la même clé).
 - **Algorithmes Symétriques** (À mémoriser) :
 - **DES** : Bloc de 64 bits, clé effective de 56 bits. Obsolète.
 - **3DES** : Applique DES 3 fois. Clé effective de 111 bits. Bientôt obsolète.
 - **IDEA** : Remplacement européen du DES. Bloc 64 bits, clé 128 bits.
 - **Blowfish / Twofish** : Remplaçants du DES, très rapides.
 - **Skipjack** : Utilisé par le gouvernement US, supporte le séquestre de clé (Key Escrow).
 - **RC4** : Chiffrement par flux (Stream). Utilisé dans WEP/SSL (aujourd'hui vulnérable).
 - **AES** (Rijndael) : Le standard actuel. Bloc de 128 bits. Clés de 128 (10 tours), 192 (12 tours) ou 256 bits (14 tours).
- **Chiffrement Asymétrique** (Clé Publique / Clé Privée) :
 - Chaque utilisateur a 2 clés mathématiquement liées. Ce qui est chiffré par l'une est déchiffré par l'autre.
 - Avantages : Règle le problème de distribution des clés, permet les signatures numériques (Non-répudiation).
 - Inconvénients : Très lent (gourmand en calculs).
 - **Algorithmes Asymétriques** :
 - **RSA** : Basé sur la difficulté de factoriser de grands nombres premiers.

- **ECC** (Elliptic Curve Cryptography) : Basé sur les courbes elliptiques. Offre une sécurité égale à RSA avec des clés beaucoup plus petites. Idéal pour les mobiles/sans-fil.
- **Diffie-Hellman** : Ne chiffre pas les données, mais permet un échange sécurisé de clés symétriques sur un réseau public.
- **Cryptosystème Hybride** : Utilise l'asymétrie pour s'échanger en toute sécurité une clé symétrique de session. Utilise ensuite la symétrie pour chiffrer les données (ex : TLS/SSL). Allie sécurité et vitesse.
- **Fonctions de Hachage** (Hashing) :
 - Convertit un message de n'importe quelle taille en une chaîne de taille fixe (Digest). Assure l'Intégrité.
 - Propriétés : Unidirectionnel (One-way / Pre-image resistance), Déterministe, Effet d'avalanche (un changement d'un bit modifie tout le hash), Résistance aux collisions.
 - Algorithmes : MD5 (128 bits, cassé/collisions), SHA-1 (160 bits, obsolète), SHA-2 (256/512 bits, standard actuel), RIPEMD.
- **Signatures Numériques** : Assure l'**Authenticité**, l'**Intégrité** et la **Non-répudiation**. L'expéditeur hache le document et chiffre le hash avec SA clé PRIVÉE. Le destinataire déchiffre avec la clé PUBLIQUE de l'expéditeur et compare les hashes.
- **PKI (Public Key Infrastructure)** :
 - Cadre de gestion des certificats numériques (Standard **X.509**).
 - CA (**Certificate Authority**) : Tiers de confiance qui émet et signe les certificats.
 - RA (**Registration Authority**) : Vérifie l'identité du demandeur avant que le CA n'émette le certificat.
 - CSR (**Certificate Signing Request**) : La demande envoyée par le serveur au CA, contenant sa clé publique.

- Révocation : **CRL** (Liste noire téléchargée par le client) ou **OCSP** (Vérification en temps réel). Le "Certificate Stapling" permet au serveur web de fournir directement la preuve OCSP pour soulager le CA.
- Salage (**Salting**) : Ajouter une chaîne aléatoire au mot de passe avant de le hacher. Rend les attaques par tables arc-en-ciel (rainbow tables) inefficaces.
- Sécurité matérielle :
 - **Secure Enclave** : Zone isolée physiquement sur le processeur pour les opérations cryptographiques et biométriques.
 - **HSM (Hardware Security Module)** : Appareil physique pour stocker et gérer les clés à grande échelle. Évalué par le standard FIPS 140-2 (Niveaux 1 à 4).

Protocoles, Cadres ou Technologies

- FIPS 140-2 : Standard du NIST pour valider la robustesse des modules cryptographiques (HSM). **Le Niveau 4 est le plus élevé** (réponse aux altérations environnementales et destruction des clés si forcé).

Ne pas confondre

- Chiffrer avec la clé publique vs Chiffrer avec la clé privée :
 - Chiffrer avec la clé PUBLIQUE du destinataire = Confidentialité (Lui seul pourra lire).
 - Chiffrer (un hash) avec MA clé PRIVÉE = Signature / Non-répudiation (Tout le monde peut lire avec ma clé publique, prouvant que ça vient de moi).
- **Obfuscation** (Masquage) vs **Tokenisation** : L'obfuscation change le format visuel (ex : étoiles sur le mot de passe). La tokenisation remplace une vraie donnée (ex : CB) par un jeton aléatoire qui sert de référence vers une base de données ultrasécurisée.

Moyens Mnémotechniques

- Symétrique Scalabilité : $N(N-1) / 2$. (Si 10 utilisateurs : $10 \times 9 / 2 = 45$ clés).

- Hash = Empreinte digitale (Intégrité). Chiffrement = Coffre-fort (Confidentialité).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La cryptographie n'est pas une solution magique : Une clé AES-256 est inutile si elle est stockée dans un fichier texte sur le bureau. Le CISSP insiste sur la gestion du cycle de vie des clés (Key Management).
- Sélection d'algorithmes : Ne choisis jamais MD5, SHA-1, DES ou WEP dans une réponse d'examen, ils sont dépréciés. Choisis AES (symétrique), RSA/ECC (asymétrique) et SHA-256 (Hash)

3.7 - COMPRENDRE LES METHODES D'ATTAQUES CRYPTANALYTIQUES

Résumé Général

Pour concevoir des systèmes sécurisés, il faut comprendre comment les attaquants tentent de contourner ou de casser la cryptographie. Les failles proviennent rarement des mathématiques elles-mêmes, mais presque toujours d'une mauvaise implémentation logicielle, matérielle ou d'une erreur humaine.

Concepts Clés à retenir

- **Attaques Mathématiques / Théoriques :**
 - **Brute Force** : Essayer absolument toutes les combinaisons de clés possibles. Parade : Clés longues et Rate Limiting.
 - **Ciphertext-Only** (Texte chiffré uniquement) : L'attaquant n'a que le fichier chiffré et cherche des patterns. Difficile sur les algorithmes modernes.
 - **Known Plaintext** (Texte clair connu) : L'attaquant possède une version en clair et la version chiffrée correspondante pour déduire la clé. Parade : **Vecteurs d'initialisation** (IVs) et **Sels** (Salts).
 - **Chosen Ciphertext** (Texte chiffré choisi) : L'attaquant envoie ses propres messages chiffrés corrompus au système et analyse les messages d'erreur en retour pour trouver des indices. Parade : Messages d'erreur génériques.
 - **Frequency Analysis** (Analyse de fréquence) : Compter quelles lettres reviennent le plus souvent. Inutile contre AES, utilisé contre la substitution (César).
- **Attaques d'Implémentation & Matérielles :**
 - **Implementation Attacks** : Exploiter un mauvais code (ex : un générateur de nombres pseudo-aléatoires défectueux).
 - **Side-Channel** (Canal auxiliaire) : Ne pas attaquer le code, mais mesurer la consommation électrique, les émissions électromagnétiques ou les bruits matériels de la puce pendant qu'elle chiffre. Parade : Blindage, bruit blanc.

- **Timing Attack** (Attaque temporelle) : Mesurer le temps exact (en millisecondes) que prend le processeur pour déchiffrer. Parade : Algorithmes à temps constant.
- **Fault Injection** (Injection de fautes) : Surchauffer la puce ou faire varier le voltage pour la faire "bugger" et sauter une étape de sécurité.
- **Attaques Réseaux & Identités :**
 - **MITM** (Man-in-the-Middle / On-path) : Intercepter et altérer la session. Parade : TLS, authentification mutuelle.
 - **Pass-the-Hash** : Voler un hash de mot de passe (souvent NTLM sur Windows) et le renvoyer directement au serveur pour s'authentifier sans jamais avoir besoin de craquer le vrai mot de passe. Parade : Utiliser Kerberos, restreindre les droits d'admin locaux.
 - **Kerberos Exploitation** : Forger un faux ticket (Ticket-Granting Ticket) pour usurper n'importe quel utilisateur (Golden Ticket).
 - **Ransomware** : Utiliser la cryptographie contre la victime en chiffrant ses fichiers pour exiger une rançon (Extorsion). Parade : Sauvegardes hors-ligne, EDR, moindre privilège.

Ne pas confondre

- Known Plaintext vs Chosen Ciphertext : Dans Known Plaintext, l'attaquant écoute et possède un couple (Clair/Chiffré) par hasard (ex : en-tête de courriel). Dans Chosen Ciphertext, l'attaquant interagit activement avec le système en lui injectant des données manipulées.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Les mathématiques vs l'humain : La cryptographie moderne (AES-256) ne se casse pas par la force brute. L'examen mettra l'accent sur les failles d'implémentation (Side-Channel) ou la mauvaise gestion des clés (Key Management) comme vecteurs d'attaque privilégiés.

3.8 - PRINCIPES DE SECURITE POUR LA CONCEPTION DES SITES ET INSTALLATIONS

Résumé Général

La sécurité d'un système d'information commence par le bâtiment physique qui l'héberge. Ce sous-domaine se concentre sur les principes architecturaux et géographiques permettant de concevoir un site structurellement sécurisé avant même d'y installer des contrôles électroniques.

Concepts Clés à retenir

- **Choix du site** (Site Selection) : La première étape consiste à évaluer l'emplacement physique. Il faut prendre en compte la criminalité locale, les risques de catastrophes naturelles, la proximité des services d'urgence (police, pompiers), et la discrétion (camouflage industriel pour cacher la nature du bâtiment).
- **CPTED** (Crime Prevention Through Environmental Design) : Utiliser le design urbain et architectural pour influencer le comportement humain et dissuader les crimes. Repose sur 4 piliers :
 - **Surveillance Naturelle** : Concevoir des espaces où les gens sont visibles (éclairage, haies taillées, lignes de vue dégagées). Les criminels détestent être observés.
 - **Contrôle d'Accès Naturel** : Guider physiquement les personnes vers les bonnes zones via des chemins, clôtures ou portes, tout en restreignant l'accès aux zones sensibles.
 - **Renforcement Territorial** : Marquer clairement la frontière entre l'espace public et privé (panneaux, aménagement paysager) pour affirmer la propriété.
 - **Maintenance** (Théorie de la vitre brisée) : Un espace propre et bien entretenu signale qu'il est surveillé. Il faut réparer les dégâts immédiatement.
- **Conception des Locaux Techniques (Wiring Closets)** : Salles de distribution des câbles réseau. Ne doivent jamais servir de lieu de stockage (pas de cartons inflammables). Nécessitent des serrures solides, des logs d'accès et une inspection régulière.

- **Salles de serveurs / Data Centers :**

- Doivent être situées au cœur du bâtiment (loin des fenêtres et murs extérieurs, loin des canalisations d'eau/gaz).
- Allées Chaudes / Allées Froides (Hot and Cold Aisles) : Les baies de serveurs sont disposées face à face. L'air froid (climatisation) est aspiré par l'avant (Cold Aisle), l'air chaud est rejeté par l'arrière (Hot Aisle) et extrait. Cela empêche l'air chaud et froid de se mélanger, optimisant le refroidissement.

- **Stockage des médias** (Media Storage) : Les bandes de sauvegarde et clés USB doivent être stockées dans des armoires verrouillées, avec un processus de traçabilité strict (Check-in/Check-out par un bibliothécaire/dépositaire).

- **Stockage des preuves** (Evidence Storage) : Système dédié et déconnecté du réseau de production (hors ligne). Exige un chiffrement des données, un hachage des preuves pour l'intégrité, et un contrôle d'accès strict.

- **Zones restreintes et de travail** : Application du cloisonnement (Routing). Les murs des zones ultra-sensibles doivent aller du vrai plancher au vrai plafond (Floor-to-ceiling) pour éviter les intrusions par les faux plafonds.

Protocoles, Cadres ou Technologies

- CPTED : Cadre conceptuel globalement reconnu pour la conception physique sécurisée.

Ne pas confondre

- Surveillance Naturelle vs Contrôle d'Accès Naturel (CPTED) : Tailler une haie pour qu'un intrus ne puisse pas s'y cacher est de la Surveillance Naturelle. Planter une haie d'épineux pour empêcher quelqu'un de traverser la pelouse est du Contrôle d'Accès Naturel.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Design Core (Cœur du bâtiment) : Si on te demande où placer une salle de serveurs critique dans un nouveau bâtiment, la réponse correcte est toujours "au centre du bâtiment" (loin des menaces externes, des inondations du rez-de-chaussée ou du toit).

- Le piège du câblage : L'examen adore tester les Wiring Closets. Le piège est de laisser le personnel d'entretien y ranger les balais et produits chimiques (risque d'incendie/coupure de câbles). L'accès doit être strictement réservé à l'IT.

3.9 - CONCEPTION DES CONTROLES DE SECURITE DES SITES ET INSTALLATIONS

Résumé Général

Une fois le bâtiment conçu, il faut l'équiper de contrôles environnementaux et physiques pour le protéger contre les pannes, le feu, les coupures de courant et les intrusions. La priorité absolue de tout contrôle physique reste la sécurité de la vie humaine.

Concepts Clés à retenir

- Ordre fonctionnel de la sécurité physique (Dans l'ordre d'action) :
 - a. **Deter** (Dissuader) : Panneaux, éclairage, caméras visibles (décourager).
 - b. **Deny** (Refuser) : Serrures, badges, barrières (bloquer).
 - c. **Detect** (Détecter) : Capteurs de mouvement, alarmes (identifier si le refus a échoué).
 - d. **Delay** (Retarder) : Portes renforcées (ralentir l'intrus pour donner le temps de réagir).
 - e. **Determine** (Déterminer) : Évaluer l'incident via les logs et caméras.
 - f. **Decide** (Décider) : Lancer la réponse.
- Contrôles environnementaux :
 - CVC (**HVAC**) : Doit maintenir une température de 15-23C et une humidité de 45-60%. Trop d'humidité = corrosion. Trop sec = électricité statique.
 - **Pressurisation positive** : Lors de l'ouverture d'une porte, l'air doit sortir vers l'extérieur pour repousser la fumée et la poussière.
 - En cas d'incendie, le HVAC doit se couper pour ne pas nourrir le feu en oxygène.
- Défaillance de l'équipement (Mesures) :

- **MTTF** (Mean Time to Failure) : Durée de vie fonctionnelle attendue.
- **MTTR** (Mean Time to Repair) : Temps moyen de réparation.
- **MTBF** (Mean Time Between Failures) : Temps moyen entre deux pannes.
- Alimentation Électrique (Power) :
 - **Onduleurs** (UPS) : Fournissent une alimentation de secours temporaire (batterie) pour permettre un arrêt propre ou attendre le démarrage du générateur.
 - **Conditionneurs de ligne & Régulateurs** : Lissent la qualité du courant pour éviter les surtensions.
- Prévention et Suppression des Incendies :
 - **Détecteurs** : Ionisation (très précoce, capte les particules), Photoélectrique (capte la fumée bloquant un laser), Thermique (chaleur), Infrarouge (flammes).
 - **Classes de feu** : **A** (Matériaux courants/bois Eau), **B** (Liquides inflammables CO2), **C** (Électrique Gaz/CO2), **D** (Métaux combustibles Poudre sèche), **K** (Cuisine).
 - Systèmes à eau :
 - **Wet Pipe** : Tuyaux toujours remplis d'eau. Risque de gel ou de fuite accidentelle sur les serveurs.
 - **Dry Pipe** : Tuyaux remplis d'air sous pression (idéal pour le froid).
 - **Pre-action** : Le meilleur pour les Data Centers. L'eau ne remplit le tuyau qu'après une alarme, puis n'est libérée que si le capteur thermique de la buse fond. Prévient les inondations accidentelles.
 - **Systèmes à Gaz** (Clean Agents) : Privent le feu d'oxygène ou cassent la réaction chimique. Halon (banni car toxique pour la couche d'ozone), FM-200, Argon, CO2. Attention au risque d'asphyxie pour le personnel !
- Contrôles de périmètre et Accès :
 - **Éclairage** : Force de **2 à 10 foot-candles**.

- **Clôtures : 3-4 pieds** (dissuade les passants), 8 pieds et plus + barbelés (stoppe un intrus déterminé).
- **Access Control Vestibule (Mantrap)** : Sas à deux portes qui empêche le Tailgating (talonnage) et le Piggybacking. Une porte ne s'ouvre que si l'autre est verrouillée.
- **Serrures (Locks)** : À code (**Cipher locks**), **biométriques**, etc. Possèdent des alarmes de délai (porte ouverte trop longtemps) et des codes sous la contrainte (**Hostage/Duress alarm**).
- Sécurité du personnel : Code de contrainte (Duress PIN) tapé sous la menace, qui ouvre la porte tout en déclenchant une alarme silencieuse.

Ne pas confondre

- Fail Safe vs Fail Secure : En cas de coupure de courant, une porte Fail Safe s'ouvrira pour permettre aux humains d'évacuer (priorité à la vie). Une porte Fail Secure restera fermée pour protéger les actifs (ex : une salle de coffres).
- Tailgating vs Piggybacking : Dans le Tailgating, l'intrus se faufile sans autorisation. Dans le Piggybacking, l'employé consent à laisser entrer la personne (par politesse). Les Mantraps corrigent ces deux problèmes.

Moyens Mnémotechniques

- Classes de feu (Mot anglais) :
 - A = Ash (Cendre : papier, bois).
 - B = Boil (Bouillir : pétrole, alcool).
 - C = Current (Courant : équipements électriques).
 - D = Dent (Bosseler : Métal).
 - K = Kitchen (Cuisine : Huiles de cuisson).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La Vie Humaine d'Abord (Life Safety First) : C'est le principe fondamental du CISSP. Si une question te demande de choisir entre verrouiller un data center pour protéger des millions de dollars de

données lors d'un incendie, ou laisser les portes ouvertes (Fail Safe) pour que les gens s'échappent : Tu dois toujours privilégier l'évacuation et la vie humaine.

- Le meilleur système anti-incendie pour un serveur : L'examen demande souvent le système d'extinction à eau recommandé pour un Data Center. La réponse est toujours le système Pre-Action (car il limite drastiquement le risque de dégâts des eaux liés à une fausse alarme).

3.10 - GESTION DU CYCLE DE VIE DES SYSTEMES D'INFORMATION

Résumé Général

Chaque système d'information possède un cycle de vie (de sa conception à sa destruction). Ce sous-domaine décrit comment intégrer la sécurité de manière proactive à chaque phase de ce cycle pour éviter d'avoir à "bricoler" des correctifs coûteux une fois le système en production.

Concepts Clés à retenir

- 1. Besoins et Exigences des parties prenantes (Stakeholders) :
 - Traduire les objectifs métiers et les contraintes de conformité en exigences.
 - **Exigences Fonctionnelles** : Ce que le système doit faire (ex : "Le système doit calculer la paie").
 - **Exigences Non-fonctionnelles** : Comment le système doit se comporter, incluant la sécurité, la performance et la fiabilité (ex : "Le système doit utiliser l'authentification MFA").
- 2. Conception architecturale (**Architectural Design**) : Création du plan (**Blueprint**). Définition des flux de données, des interfaces, et de l'architecture de sécurité (segmentation, contrôles d'accès).
- 3. **Développement** / Implémentation : C'est la phase de création/codage et d'assemblage du matériel. L'accent est mis sur les pratiques de codage sécurisées.
- 4. **Intégration** : Combiner tous les composants individuels (modules, bases de données) et vérifier qu'ils fonctionnent ensemble de manière sécurisée sans failles d'interface.
- 5. Vérification et Validation (**V&V**) : Étape critique de test.
- 6. **Transition** / Déploiement : Passage de l'environnement de développement à la production. Inclut la migration des données et la formation des utilisateurs.
- 7. Opérations et Maintenance (**Sustainment**) : C'est la phase la plus longue du cycle. Inclut le monitoring, l'application des correctifs (Patching), le support utilisateur, et la gestion des changements.

- Gestion des changements (**Change Management**) :
Demande (**RFC**) Analyse d'impact Approbation (**CAB**)
Implémentation Vérification Documentation.
- 8. Retrait / Mise au rebut (**Retirement / Disposal**) : Déclassement du système. Nécessite une destruction sécurisée des données, la migration vers de nouveaux systèmes et le respect des règles de conformité.

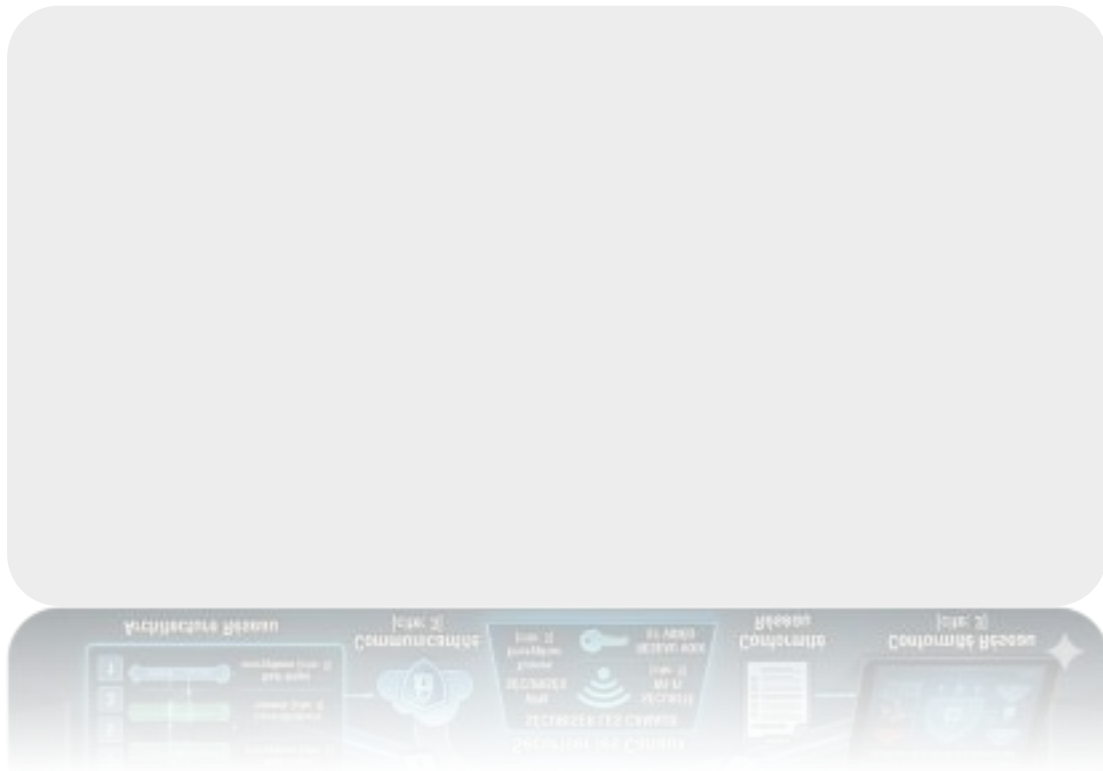
Ne pas confondre

- Vérification vs Validation (Concepts très testés) :
 - Vérification : "Did we build it right ?" (Avons-nous bien construit la chose ?). Teste le code, les fonctions et s'assure que le système respecte le cahier des charges technique.
 - Validation : "Did we build the right system ?" (Avons-nous construit le BON système ?). Confirme que le produit final répond réellement aux besoins de l'utilisateur et aux objectifs de l'entreprise.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La gestion des changements est non négociable : Si un administrateur veut appliquer un patch de sécurité "critique" en urgence un vendredi soir sans passer par le processus d'approbation (CAB), le CISSP s'y oppose. Tout changement non documenté est une faille de sécurité potentielle.
- Security "Built-in" : L'examen pénalisera toujours une option qui suggère de vérifier la sécurité uniquement à l'étape du déploiement. La sécurité commence à l'étape des Exigences (Requirements).

DOMAINE 4 : SECURITE DES COMMUNICATION S ET DES RESEAUX



4.1 – PRINCIPES DES ARCHITECTURES RESEAU ET SECURITE

Résumé Général

La sécurité des communications (Domaine 4) exige une maîtrise totale de la façon dont les données transitent (modèle OSI), des protocoles utilisés pour les sécuriser, de la segmentation pour contenir les failles, et des menaces qui pèsent sur l'infrastructure (filaire, sans fil, cloud et SDN).

Concepts Clés à retenir

1. Modèles Réseau et Adressage

- **Modèle OSI (7 couches)** : Cadre théorique d'interopérabilité.
 - **L7 Application** : Point d'entrée des services réseau. Cible majeure des attaques actuelles (SQLi, XSS, Phishing).
 - **L6 Présentation** : Gère le formatage, la compression et le chiffrement/déchiffrement (ex : JPEG, ASCII). Attaques : Exploits SSL/TLS.
 - **L5 Session** : Crée et maintient les connexions logiques (Full/Half Duplex). Attaques : Session hijacking.
 - **L4 Transport** : Communication de bout en bout via des Ports. Utilise TCP ou UDP. Attaques : SYN Floods.
 - **L3 Réseau (Network)** : Adresses logiques (IP) et routage. Attaques : IP spoofing, Ping floods.
 - **L2 Liaison de Données (Data Link)** : Adresses physiques (MAC), commute les trames (frames) sur le réseau local via les sous-couches MAC et LLC. Attaques : ARP Spoofing, MAC Flooding.
 - **L1 Physique** : Signaux électriques, optiques ou radio. Attaques : Écoute clandestine (Wiretapping), Brouillage (Jamming).
- **TCP/IP** : Suite de protocoles standard d'Internet (4 couches), plus simple mais moins ciblée sécurité que l'OSI.

- TCP vs UDP (Couche 4) :
 - **TCP** : Orienté connexion (**3-way handshake** : SYN, SYN/ACK, ACK), fiable, séquencé, contrôle de flux (Windowing). Lourd (overhead).
 - **UDP** : Sans connexion, non fiable (best effort), pas d'accusé de réception. Léger et très rapide (idéal pour VoIP/Vidéo).
- IPv4 vs IPv6 :
 - **IPv4** : 32 bits. Utilise le trafic Unicast (1 vers 1), Multicast (1 vers groupe) et Broadcast (1 vers tous).
 - **IPv6** : 128 bits. Intègre **IPSec** nativement pour la sécurité. Le Broadcast disparaît au profit de l'Anycast (envoi au nœud disponible le plus proche).
- **NAT** (Network Address Translation) : Masque les IP privées internes. **Static NAT** (1 interne pour 1 externe), **Dynamic NAT** (Plusieurs pour Plusieurs), et **PAT** (Plusieurs IP internes utilisent 1 seule IP externe via les ports).

2. Tunnels, VPN et Réseaux de Stockage

- **GRE** (Generic Routing Encapsulation) : Protocole de tunneling de Cisco, encapsule divers protocoles réseau dans des tunnels IP.
- **IPSec** : Sécurise les paquets IP. Utilise **AH** (Authentication Header) pour l'intégrité/authentification et **ESP** (Encapsulating Security Payload) pour le chiffrement (Confidentialité). Deux modes : **Transport** (chiffre la charge utile) et **Tunnel** (chiffre tout le paquet).
- **SAN** (Storage Area Network) : Réseau haute vitesse dédié au stockage. Utilise **iSCSI** (stockage sur IP/Ethernet standard) et **IBoE** (InfiniBand sur Ethernet pour le HPC).
- **QoS** (Quality of Service) : Priorise le trafic critique (comme la VoIP) pour réduire la latence et le Jitter.

3. Typologies et Métriques Réseau

- Types de réseaux : **PAN** (Personnel/Bluetooth), **LAN** (Local), **CAN** (Campus), **MAN** (Métropolitain), **WAN** (Étendu/Internet).
- Topologies : **Point-à-point**, **Mesh** / Maillé (ultra-tolérant aux pannes, coûteux), **Star** / Hub-and-Spoke (point central, Single Point of Failure).

- Métriques de performance :
 - **Bandwidth** (Bande passante) : Capacité maximale théorique.
 - **Throughput** (Débit) : Taux réel de transfert de données.
 - **Latency** (Latence) : Temps de trajet source-destination.
 - **Jitter** : Variabilité du temps d'arrivée des paquets.
 - **SNR** (Signal-to-Noise Ratio) : Ratio signal/bruit (un faible SNR cause des erreurs).

- Flux de trafic : **Nord-Sud** (Internet vers Data Center) vs **Est-Ouest** (Serveur vers Serveur en interne).

4. Segmentation, Routage et Pare-feu

- **Segmentation** : Isole les réseaux. VLANs (séparation logique L2 réduisant les domaines de broadcast), marquage 802.1Q (**VLAN tagging**). Jump Box/Host (machine ultra-sécurisée servant de pont vers une zone sensible).

- **Pare-feu** (Firewalls) :
 - **Packet Filtering** : Basique, bloque IP/Ports (L4).
 - **Stateful** : Suit l'état de la connexion (L4).
 - **WAF** (Web Application Firewall) : Protège les applications web (L7) contre les XSS/SQLi.
 - **UTM** : Solution tout-en-un (Firewall, AV, IDS).
 - **NGFW** : Pare-feu de nouvelle génération avec Deep Packet Inspection (L7).

- **Routage** (L3) :
 - **Distance-Vector** : Basé sur le nombre de sauts (ex : RIP, EIGRP).
 - **Link-State** : Basé sur la bande passante (ex : OSPF).
 - **BGP** : Protocole de routage inter-domaines (fait fonctionner Internet).
 - **VRRP** / **FHRP** : Protocoles de redondance de routeurs utilisant une IP virtuelle (VIP) pour la haute disponibilité.

- **IDS / IPS** :

- **Knowledge-based** (Signatures) : Compare avec une base de données d'attaques connues.
- **Behavior-based** (Anomalies) : Crée une ligne de base et détecte les déviations (nouveaux types d'attaques), génère plus de faux positifs.
- **HIDS** (Host) vs **NIDS** (Network). L'IPS bloque activement l'attaque, l'IDS se contente d'alerter.

5. Réseaux Sans Fil (Wi-Fi)

- Fréquences : **2.4 GHz** (longue portée, forte interférence), **5 GHz** (plus rapide, courte portée), **6 GHz** (très haute capacité).
- Normes **802.11** : Définit le standard Wi-Fi.
- Terminologie : **BSS** (un point d'accès), **SSID** (Nom du réseau), **BSSID** (Adresse MAC du point d'accès), **ESS** (Plusieurs points d'accès partageant le même réseau).
- Antennes : **Omnidirectionnelle** (360 degrés, bureaux), **Directionnelle** (Yagi, Parabolique, pour viser sur des kilomètres).
- Sécurité Wi-Fi : **WPA2** (utilise AES et CCMP), **WPA3** (le plus récent, utilise **SAE**).
- **Déploiement** : Nécessite des **Site Surveys** et des **Heat maps** (cartes de chaleur) pour optimiser la couverture et éviter que le signal ne fuite hors du bâtiment (sécurité).

6. Réseaux Définis par Logiciel (SDN) et Cloud

- **SDN** (Software-Defined Networking) : Sépare l'architecture en trois plans : **Data plane** (transfère les paquets), **Control plane** (le cerveau, gère les politiques via logiciel), **Application plane**.
- **SD-WAN** : Applique le SDN aux réseaux étendus (WAN) pour un routage dynamique.
- **NFV (Network Functions Virtualization)** : Remplace le matériel réseau (firewalls, load balancers) par des machines virtuelles.
- **VPC (Virtual Private Cloud)** : Réseau isolé dans le Cloud. Protégé par des Security Groups (pare-feu virtuels). Le **NAT Gateway** permet aux instances privées de se mettre à jour sur Internet sans être exposées.

7. Menaces et Acteurs

- **Malware** (Logiciels malveillants) :
 - **Virus** : Nécessite une action humaine/un programme hôte pour s'exécuter.
 - **Worm** (Ver) : S'auto-réplique via le réseau sans action humaine.
 - **Trojan** : Se déguise en logiciel légitime.
 - **Ransomware** : Chiffre les données pour exiger une rançon (entrave la disponibilité).
 - **Spyware** : Espionne l'utilisateur en silence.
 - **Rootkit** : Se cache au niveau du Kernel (Ring 0) pour maintenir un accès privilégié.
 - **Logic Bomb** : Code dormant déclenché par un événement précis (ex : date, licenciement).
 - **Keylogger** : Enregistre les frappes clavier.
- **Attaques réseau** :
 - **DDoS** : Submerge la cible (UDP floods, SYN floods, Attaques par amplification via DNS) en utilisant des Botnets.
 - **On-Path** (MITM) : L'attaquant s'interpose pour lire ou modifier le trafic (ex : SSL Stripping).
- **Acteurs de menaces** :
 - **Nation-State** (État-Nation) : Extrêmement financés, utilisent des APT (Advanced Persistent Threats) pour l'espionnage.
 - **Script Kiddies** (Inexpérimentés) : Utilisent des outils tout faits.
 - **Hacktivistes** : Motivés par une idéologie (politique/sociale).
 - **Insider Threat** (Menace interne) : Employés (malveillants ou négligents).
 - **Crime Organisé** : Motivé par l'argent (Ransomware, fraudes).
 - **Shadow IT** : Systèmes utilisés par les employés sans l'accord de la DSI.

Protocoles, Cadres ou Technologies (Ports à mémoriser)

- Non sécurisés (À éviter) : **FTP** (20/21), **Telnet** (23), **SMTP** (25), **TFTP** (69), **HTTP** (80), **POP3** (110), **IMAP** (143), **SNMP v1/v2** (161/162).
- Sécurisés (À privilégier) : **SSH / SFTP** (22), **HTTPS** (443), **SMTPS** (587), **IMAPS** (993), **POP3S** (995), **LDAPS** (636), **SNMP v3**.
- Autres : **RDP** (3389), **DHCP** (67/68), **NTP** (123), **DNS** (53), **SMB** (445), **Syslog** (514).
- Sécurité Courriel : **SPF** (vérifie l'IP de l'expéditeur), **DKIM** (signature cryptographique du domaine), **DMARC** (politique combinant SPF et DKIM).
- Sécurité DNS : **DNSSEC** (Authentifie les données DNS via signatures numériques pour éviter le Cache Poisoning), DoH / DoT (Chiffre les requêtes DNS via HTTPS ou TLS).

Ne pas confondre

- TCP vs UDP : TCP garantit l'arrivée des données (accusés de réception) au prix de la vitesse. UDP sacrifie la garantie d'arrivée pour la vitesse pure (streaming, VoIP).
- WAF (L7) vs NGFW (L7) : Le WAF protège spécifiquement les applications web (ex : un site e-commerce) contre les attaques HTTP/Web. Le NGFW protège l'ensemble du réseau de l'entreprise avec une inspection profonde des paquets pour bloquer les malwares.
- Virus vs Worm (Ver) : Un virus a besoin qu'un humain clique sur un fichier pour se lancer. Un ver voyage et s'exécute tout seul sur le réseau.
- HIDS vs NIDS : Le HIDS (Host) est sur la machine (voit dans les fichiers chiffrés locaux). Le NIDS (Network) voit tout le trafic du réseau mais est aveugle si le trafic est chiffré.

Moyens Mnémotechniques

- Couches OSI : Please Do Not Throw Sausage Pizza Away (Physical, Data, Network, Transport, Session, Presentation, Application).

- DDoS SYN Flood : L'attaquant envoie des "SYN" (demande de connexion) et ne répond jamais au "SYN/ACK" du serveur, épuisant ses ressources.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Defense in Depth (Défense en profondeur) : Ne jamais compter sur un seul pare-feu. L'examen valorise la segmentation (VLAN, DMZ) couplée à des IDS, des WAF et du chiffrement. Il faut sécuriser toutes les couches OSI.
- Remplacer les protocoles clairs : Si une question montre un administrateur utilisant Telnet ou FTP, la réponse corrective est TOUJOURS de les remplacer par SSH ou SFTP. Le trafic de gestion ne doit jamais être en clair.
- Zero Trust : Les réponses favorisant la confiance implicite ("parce qu'il est sur le réseau interne") sont toujours fausses. Le modèle actuel est de toujours authentifier et vérifier (Control Plane / Data Plane).

4.2 - COMPOSANTS RESEAUX SECURISES

Résumé Général

Ce sous-domaine se concentre sur la couche physique et la sécurité d'accès au réseau. L'objectif est de sécuriser le matériel (câbles, connecteurs), de contrôler rigoureusement qui ou quoi se connecte au réseau (NAC), et de protéger les terminaux finaux (Endpoints).

Concepts Clés à retenir

- Propriétés des câbles réseau :
 - **Atténuation** : Plus le câble est long, plus le signal s'affaiblit.
 - Immunité au bruit (**EMI**) : Les interférences électromagnétiques peuvent perturber les câbles en cuivre. La fibre optique est immunisée contre l'EMI.
 - **Duplex** : **Half-duplex** (communication unidirectionnelle à la fois) vs **Full-duplex** (communication bidirectionnelle simultanée).
- Types de Câblages :
 - Paires Torsadées (**Twisted Pair**) : UTP (non blindé, sensible à l'EMI) et STP (blindé). Limité à 100 mètres. Connecteurs RJ11 (téléphone) et RJ45 (réseau).
 - **Coaxial** : Protège contre l'EMI grâce à son blindage. Va jusqu'à 1100m. Connecteurs BNC (verrouillage) et F (vissé, pour modems).
 - **Fibre Optique** : Transmet des impulsions lumineuses. Immunisée contre l'EMI, très rapide et longue distance. Connecteurs : ST (Straight Tip), SC (Square/Subscriber), LC (Lucent/Little), MPO (Multi-fiber).
 - Monomode (**Single-Mode**) : Pour les très longues distances (télécommunications).
 - **Multimode** : Pour les courtes distances (bâtiment, LAN).

- **Twinaxial / DAC** (Direct Attach Copper) : Câbles en cuivre pour des connexions très courtes (0.5 à 7m) mais à très haut débit (10 à 40 Gbps) dans les Data Centers.
- **Plenum Rating** : Concerne la résistance au feu. Les câbles Plenum sont conçus pour ne pas propager le feu et émettre très peu de fumées toxiques, obligatoires dans les faux plafonds ou conduits d'aération.
- **Transceivers** (Émetteurs-récepteurs) : Convertissent les signaux (ex : électrique vers optique).
 - **SFP** : Jusqu'à 4.25 Gbps. **SFP+** : Jusqu'à 10 Gbps.
 - **QSFP** : Jusqu'à 28 Gbps. **QSFP+** : Jusqu'à 40 Gbps.
- **NAC** (Network Access Control) : Empêche les appareils non autorisés ou non conformes d'accéder au réseau.
 - **Health Checks** (Vérification de santé) : Vérifie si l'appareil a son antivirus à jour et ses correctifs installés avant de le laisser entrer.
 - **Pre-Admission** : Authentification et contrôle avant de donner l'accès.
 - **Post-Admission** : Surveillance continue une fois l'appareil connecté.
- Sécurité des terminaux (**Endpoint Security**) : Contrôles installés directement sur les appareils (Antivirus, HIDS/HIPS, DLP, Chiffrement BitLocker).
 - **EDR** (Endpoint Detection and Response) : Outil avancé qui surveille en continu les terminaux pour détecter, analyser et répondre aux menaces comportementales (au-delà du simple antivirus).
 - **XDR** (Extended Detection and Response) : Étend l'EDR en corrélant les données de sécurité au-delà des seuls terminaux (réseau, cloud, courriel).

Protocoles, Cadres ou Technologies

- 802.3 : Le standard IEEE définissant le réseau Ethernet filaire.

- 802.1X : Standard IEEE pour le contrôle d'accès basé sur les ports (PNAC). Le Switch (Authentificateur) bloque tout trafic tant que la machine (Supplicant) n'est pas validée par le Serveur (ex : RADIUS).
- **EAP (Extensible Authentication Protocol)** : Framework utilisé avec 802.1X pour transporter les méthodes d'authentification (certificats, mots de passe).

Ne pas confondre

- Fibre Monomode (Single-Mode) vs Multimode : Le Monomode est pour les kilomètres (entre les villes, laser fin). Le Multimode est pour les mètres (dans un bâtiment, LED plus large).
- Câble Plenum vs Câble Non-Plenum : Le Plenum ne prévient pas les cyberattaques, il prévient la mort par asphyxie en cas d'incendie physique dans un bâtiment.

Moyens Mnémotechniques

- Connecteurs Fibre : ST = Straight Tip (bout droit), SC = Square Connector (carré), LC = Little Connector (petit).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Contrôle d'accès physique au réseau : On ne laisse jamais un port réseau (RJ45) actif et ouvert dans une salle d'attente. Le CISSP exige l'utilisation de 802.1X pour authentifier toute machine qui se branche physiquement au mur.
- Appareils personnels (**BYOD**) : L'examen testera la façon de sécuriser un appareil inconnu. La solution est le NAC, qui vérifiera la "santé" (Health check) de l'appareil personnel avant de l'isoler ou de le laisser entrer sur le LAN.

4.3 - IMPLEMENTER DES CANAUX DE COMMUNICATION SECURISES

Résumé Général

Les entreprises collaborent à distance et dépendent de tiers. Ce sous-domaine couvre les contrôles de sécurité nécessaires pour garantir la confidentialité, l'intégrité et la disponibilité des flux de voix, de vidéo, d'accès à distance et des liens avec les fournisseurs externes.

Concepts Clés à retenir

- **Voix, Vidéo et Systèmes de Collaboration (VoIP / Zoom) :**
 - Les flux temps réel nécessitent une haute bande passante et une faible latence (**QoS**).
 - **Risques :** Écoutes clandestines (**Eavesdropping**), piratage de session (**Zoombombing**), déni de service (**DoS**).
 - Contrôles : Chiffrement des signaux (TLS) et des médias (**SRTP**), segmentation du trafic vocal via des VLAN dédiés, utilisation de salles d'attente/authentification forte pour les réunions.
 - **Impact : Touche la triade CIA au complet** (Confidentialité des appels, Intégrité des fichiers partagés, Disponibilité du service).
- **Accès à Distance (Remote Access) :**
 - Accès Utilisateur : Pour le télétravail. Utilise des **VPN** (IPSec, SSL) ou des bureaux virtuels (**RDP**).
 - Accès Administrateur : Pour la gestion des serveurs/routeurs. Utilise **SSH** ou l'accès "**Out-of-Band**" (console isolée du réseau de production comme iLO/iDRAC).
 - Risques : Vol de mots de passe, sessions non chiffrées (MITM), exposition des ports (RDP/SSH ouverts sur Internet).
 - Contrôles : Chiffrement systématique, MFA obligatoire, segmentation réseau, Moindre privilège.

- Communications de Données :
 - Réseaux de raccordement (**Backhaul**) : Relient les réseaux locaux (ex : antennes relais) au cœur d'Internet (Fibre, micro-ondes). Risque de coupures physiques et de congestion. Contrôles : Redondance, chiffrement fort.
 - Communications **Satellites** : Couverture globale mais forte latence. Risques de brouillage (**Jamming**) et d'usurpation. Contrôles : Technologies anti-brouillage, redondance.
- Connectivité avec les Tiers (Third-Party Connectivity) :
 - **Fournisseurs Télécoms** : Fournissent le WAN/Internet. Risques d'interruptions et d'écoutes. Contrôles : SLAs stricts, redondance multi-fournisseurs, chiffrement de bout en bout.
 - **Fournisseurs de support matériel** : Maintiennent les serveurs. Risques : Abus de l'accès à distance par le fournisseur, attaques de la chaîne d'approvisionnement via le firmware. Contrôles : Restreindre l'accès au strict besoin via VPN, valider les patches.
 - **Cloud / MSP** (Managed Service Providers) : Délivrent le SaaS/IaaS/SOC. Risques : Menaces internes chez le fournisseur, mauvaise compréhension de la responsabilité partagée. Contrôles : Audits de conformité (SOC 2, ISO 27001), gestion des clés de chiffrement par le client.

Protocoles, Cadres ou Technologies

- **SRTP (Secure Real-Time Transport Protocol)** : Protocole indispensable pour chiffrer les communications vocales et vidéo (VoIP) afin d'éviter les écoutes.
- **Out-of-Band Management** (Gestion hors bande) : Un canal réseau physique ou logique totalement séparé du réseau de production, utilisé uniquement par les administrateurs en cas de panne majeure.

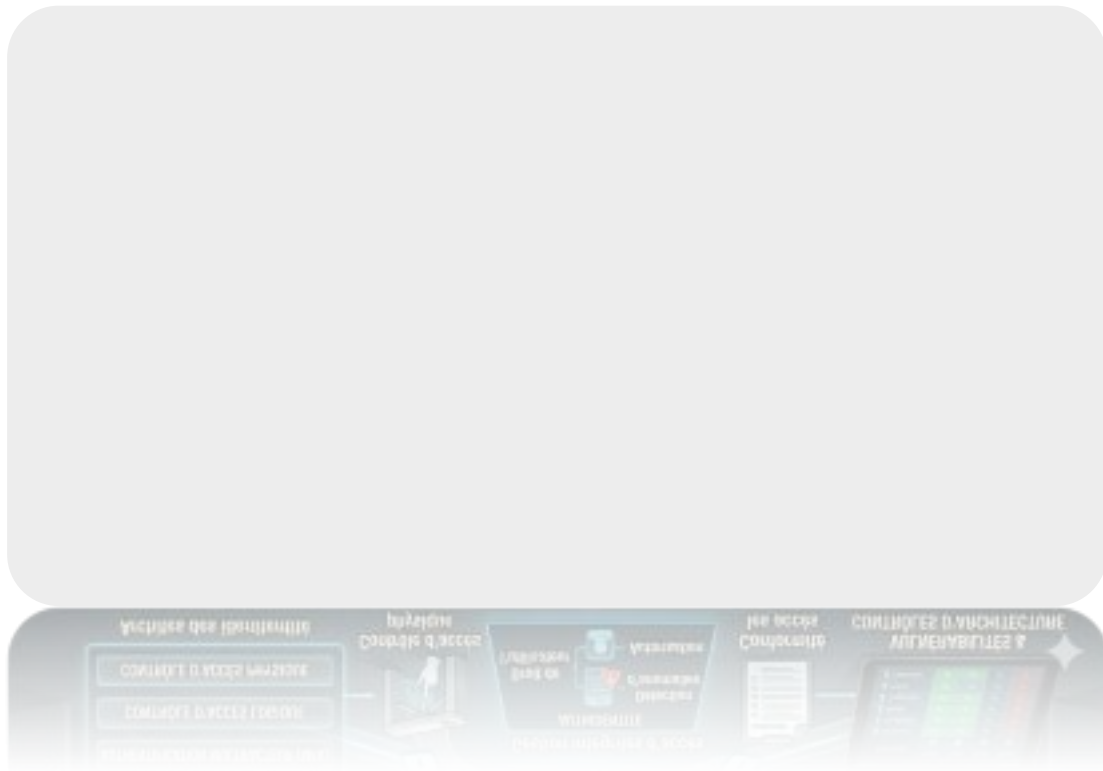
Ne pas confondre

- **Accès In-Band vs Out-of-Band** : L'accès In-Band utilise le réseau de l'entreprise (si le réseau plante, tu perds le contrôle). L'accès Out-of-Band utilise un lien dédié séparé (port de console physique) pour garder le contrôle même en cas d'attaque ou de panne majeure.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Le piège de la responsabilité (Accountability) dans le Cloud : Si tu externalises la gestion de tes accès ou de tes données à un MSP ou un fournisseur Cloud, tu restes légalement et financièrement responsable en cas de faille. Le contrat et le SLA sont tes seuls leviers de contrôle.
- L'exposition des ports d'administration : Ne jamais laisser un port d'administration (comme le port RDP 3389 ou SSH 22) exposé directement sur Internet. Le CISSP exige de les placer derrière un pare-feu ou de forcer l'utilisation d'un VPN au préalable.
- Chiffrement de bout en bout avec les FAI : Tu ne dois jamais faire confiance à ton Fournisseur d'Accès Internet (FAI/Telecom) pour protéger tes données. Tout le trafic qui transite par leurs câbles doit être chiffré par tes propres moyens (IPSec, TLS).

DOMAINE 5 : GESTION DES IDENTITES ET DES ACCES (IAM)



5.1 - CONTROLE DE L'ACCES PHYSIQUE ET LOGIQUE AUX ACTIFS

Résumé Général

Le contrôle d'accès consiste à restreindre l'utilisation des ressources organisationnelles (physiques et numériques) afin que seuls les utilisateurs, processus ou appareils autorisés puissent y accéder. Ce contrôle s'aligne toujours sur le principe du moindre privilège.

Concepts Clés à retenir

Le contrôle d'accès doit s'appliquer à plusieurs strates de l'organisation pour être efficace:

- Information (Données) : L'objectif est de protéger la Confidentialité, l'Intégrité et la Disponibilité (CIA) des données.
 - Contrôles : **Classification des données** (ex : public, interne, confidentiel), Chiffrement (au repos et en transit), et outils de prévention des fuites de données (DLP).
- Systèmes : Empêcher l'utilisation non autorisée des ressources de calcul.
 - Contrôles : **Authentification** et autorisation (MFA, RBAC), durcissement (**Hardening**) et correctifs (**Patching**) des OS, ainsi que la **surveillance** et la **journalisation** (SIEM, syslog).
- Dispositifs (Devices / Terminaux) : Chaque appareil représente une surface d'attaque potentielle.
 - Contrôles : **Sécurité des terminaux** (Antivirus, Chiffrement des disques), **gestion des appareils mobiles (MDM)**, et **restrictions des ports/clés USB**.
- Installations (Accès Physique / Facilities) : La sécurité physique est le socle de la sécurité logique. Si un attaquant accède physiquement à la salle des serveurs, les contrôles numériques échoueront.
 - Contrôles : **Badges**, **biométrie**, **serrures intelligentes**, **gardes**, **caméras**, **sas (Mantraps)**, et contrôles environnementaux (**CVC/HVAC**, suppression des incendies).

- Applications : Les applications sont des cibles courantes pour les injections, les abus et les escalades de privilèges.
 - Contrôles : Authentification forte (**OAuth, SSO, MFA**), pratiques de codage sécurisé (ex : **OWASP Top 10**), et Pare-feu d'applications web (**WAF**).
- Services (Cloud / SaaS) : Les services hébergés doivent être gouvernés par des **contrats stricts**, des **SLA** et une **surveillance continue**.
 - Contrôles : **Segmentation du réseau** (isoler les services critiques), **fédération d'identités** (SSO pour le cloud), et **journalisation** des accès au niveau du service.

Protocoles, Cadres ou Technologies

- MFA (Multi-Factor Authentication) & RBAC (Role-Based Access Control) : Les fondations de l'autorisation et de l'authentification logiques pour les systèmes et applications.
- **OAuth & SSO** (Single Sign-On) : Utilisés pour fédérer les identités et contrôler l'accès aux applications et services de manière centralisée.

Ne pas confondre

- **Accès Logique vs Accès Physique** : L'accès logique concerne les barrières logicielles (mots de passe, listes de contrôle d'accès, pare-feu) protégeant les données et systèmes. L'accès physique concerne les barrières tangibles (portes, serrures, gardes) protégeant les bâtiments et le matériel.

Moyens Mnémotechniques

Pour l'examen, le contrôle d'accès s'appuie toujours sur la "Sainte Trinité" du CISSP Mindset:

1. Moindre Privilège (**Least Privilege**) : Donner uniquement les droits nécessaires.
2. Défense en Profondeur (**Defense in Depth**) : Superposer plusieurs protections (ex : Badge physique + Mot de passe logique).
3. Auditabilité (**Auditability**) : Toujours journaliser et surveiller l'accès.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La primauté du physique sur le logique : L'examen adore tester cette notion : la sécurité logique ne sert à rien sans sécurité physique. Un pare-feu ultra-performant est inutile si n'importe qui peut entrer dans la salle des serveurs et voler le disque dur.
- **Couverture globale** : Le contrôle d'accès n'est pas qu'une question technologique. Le CISSP exige une vision qui englobe les personnes (**People**), les processus (**Processes**), la technologie (**Technology**) et les espaces physiques (**Physical spaces**).

5.2 - STRATEGIE D'IDENTIFICATION ET D'AUTHENTIFICATION

Résumé Général

Ce sous-domaine se concentre sur la conception de systèmes permettant de vérifier avec certitude qui accède au réseau. Une stratégie robuste s'appuie sur le framework AAA, l'authentification multifacteur (MFA) et la biométrie, afin de bloquer les usurpations tout en fluidifiant l'expérience utilisateur.

Concepts Clés à retenir

- **Framework AAA** : Le pilier du contrôle d'accès.
 - **Authentication** (Authentification) : Vérifie l'identité des utilisateurs ou des appareils.
 - **Authorization** (Autorisation) : Détermine les permissions et niveaux d'accès accordés.
 - **Accounting** (Traçabilité/Audit) : Suit les activités de l'utilisateur pour l'audit et la facturation.
- **Preuve d'identité (Identity Proofing)** : Valider qu'une personne est bien celle qu'elle prétend être avant de lui créer un compte (via documents d'identité, biométrie, ou KBA - Knowledge-Based Authentication / Questions de sécurité).
- **Facteurs d'Authentification (MFA)** : Utiliser plus d'une méthode de catégories indépendantes pour vérifier l'identité.
 - **Type 1** - Quelque chose que vous savez (**Know**) : Mot de passe, code PIN, KBA.
 - **Type 2** - Quelque chose que vous avez (**Have**) : Token physique (Smart card), Token logiciel (App sur smartphone), Clé de sécurité USB (FIDO2).
 - **Type 3** - Quelque chose que vous êtes (**Are**) : Biométrie.
 - **Type 4** - Quelque part où vous êtes (**Somewhere**) : Authentification basée sur la géolocalisation (GPS, adresse IP).

- **Biométrie** (Type 3) : Basée sur des attributs physiques ou comportementaux.
 - Empreintes digitales (**Fingerprints**) / Visage (Face Scans).
 - Rétine (**Retina**) : Le plus précis, mais le moins bien accepté (intrusif). Lit les vaisseaux sanguins, peut révéler des informations médicales (grossesse, hypertension).
 - **Iris** : Deuxième plus précis, excellente durée de vie (ne change pas avec l'âge).
 - Dynamique de signature / Frappe au clavier (**Keystroke**) : Biométrie comportementale (analyse la vitesse, le temps de vol et de pression des touches).
- Erreurs Biométriques (Métriques cruciales) :
 - Erreur de Type 1 (**FRR - False Rejection Rate**) : Un utilisateur légitime est rejeté (le système est trop sensible).
 - Erreur de Type 2 (**FAR - False Acceptance Rate**) : Un imposteur est accepté (le système n'est pas assez sensible).
 - **CER / EER (Crossover Error Rate)** : Le point exact où FRR et FAR se croisent. **Plus le CER est bas, plus le système est précis et performant.**
- Gestion des mots de passe : Reste la première ligne de défense. Les bonnes pratiques incluent la **longueur** (8-12 caractères min.), la **complexité**, l'interdiction de réutilisation, et **l'utilisation de gestionnaires de mots de passe**. La tendance va vers le **Passwordless** (sans mot de passe, via biométrie ou clés matérielles).

Protocoles, Cadres ou Technologies

- **Kerberos** : Protocole d'authentification réseau utilisant la cryptographie symétrique (AES) et des "**Tickets**" (**TGT**) pour éviter de faire transiter les mots de passe sur le réseau. Souvent utilisé pour le **SSO (Single Sign-On) interne**. Ses composants incluent le **KDC (Key Distribution Center)** et l'**AS (Authentication Server)**.
- **RADIUS** : Protocole AAA centralisé. Utilise **UDP**, combine l'**Authentification** et l'**Autorisation**, et **ne chiffre que le mot de passe** (le reste du paquet est en clair).

- **TACACS+** : Protocole AAA propriétaire **Cisco** (devenu standard ouvert). Utilise le port **TCP 49**, sépare les processus **d'Authentification, d'Autorisation et d'Audit**, et chiffre l'intégralité de la charge utile (**payload**).

Ne pas confondre

- RADIUS vs TACACS+ :
 - RADIUS = UDP, chiffre uniquement le mot de passe, fusionne Auth & Autorisation (moins granulaire).
 - TACACS+ = TCP, chiffre tout, sépare les 3 A (très granulaire, idéal pour l'administration des routeurs).
- Type 1 Error (FRR) vs Type 2 Error (FAR) : L'erreur de Type 1 (FRR) frustre les employés (le boss ne peut pas entrer). L'erreur de Type 2 (FAR) crée une faille de sécurité majeure (l'hacker entre).
- Rétine vs Iris : Le scan de la rétine tire un laser dans le fond de l'oeil (intrusif, révèle l'état de santé). Le scan de l'iris prend une photo de la partie colorée de l'oeil (plus passif, très précis).

Moyens Mnémotechniques

- TACACS+ : Pense à "Tout est Chiffré en TCP".
- Erreurs Biométriques : FRR = Fréquemment Rejeté (Type 1, embêtant). FAR = Fatalement Accepté (Type 2, danger).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Le talon d'Achille de Kerberos : L'examen testera souvent les faiblesses de Kerberos. Ses deux plus gros points faibles sont :
 - a. La **synchronisation d'horloge** : Kerberos utilise des **horodatages** pour contrer les attaques par rejeu (**Replay attacks**). Si les horloges du client et du serveur sont désynchronisées (généralement de plus de 5 minutes), l'authentification échoue.
 - b. Point de défaillance unique (**SPOF**) : Si le serveur KDC (Key Distribution Center) tombe en panne, personne ne peut plus s'authentifier sur le réseau.

- Comment choisir le meilleur système biométrique ? La réponse à cette question est toujours le système avec le CER (Crossover Error Rate) le plus bas.
- Définition stricte du MFA : Avoir deux mots de passe différents ou un mot de passe + un code PIN n'est PAS du MFA (c'est deux fois le même facteur "Quelque chose que l'on sait"). Le MFA exige au minimum deux catégories différentes (ex : Mot de passe + Token SMS).

5.3 - IDENTITE FEDEREE AVEC UN SERVICE

Résumé Général

Ce sous-domaine traite de la simplification et de la centralisation des accès. L'objectif est de permettre aux utilisateurs de naviguer de manière transparente entre de multiples systèmes ou entreprises partenaires avec une seule identité, tout en renforçant le contrôle de sécurité global et en réduisant la fatigue liée aux mots de passe.

Concepts Clés à retenir

- **Fédération (Federation)** : Le processus de liaison et de gestion des identités à travers différents systèmes et frontières organisationnelles. Elle permet à un utilisateur d'utiliser le même ensemble d'identifiants pour accéder à de multiples applications externes, facilitant ainsi le Single Sign-On (SSO).
- Composants clés de la Fédération :
 - **IdP (Identity Provider - Fournisseur d'Identité)** : Le service qui détient l'annuaire, authentifie les utilisateurs et affirme (attestation) leur identité auprès des autres services (ex : Okta, Microsoft Azure AD, Google Identity).
 - **SP (Service Provider - Fournisseur de Service)** : L'application ou le système cible qui s'appuie sur les informations fournies par l'IdP pour accorder l'accès à l'utilisateur (ex : Salesforce, Office 365).
- Modèles de déploiement de la Fédération :
 - **Fédération sur site (On-Premise)** : L'IdP et le SP résident dans le data center de l'organisation (ex : ADFS). Offre un contrôle total et les données ne sortent pas, mais demande une forte charge de maintenance.
 - **Fédération Cloud** : L'identité est gérée par un fournisseur Cloud (ex : Azure AD). Très flexible et facile à intégrer avec les applications SaaS, mais introduit une dépendance externe et exige des SLAs stricts.

- **Fédération Hybride** : Combine l'identité sur site (ex : Active Directory local) avec un fournisseur Cloud. Idéal pour la migration, mais complexe à configurer.
- **SSO (Single Sign-On / Authentification unique)** : Fonctionnalité permettant aux utilisateurs de se connecter une seule fois pour accéder à de multiples systèmes sans se ré-authentifier.
 - Avantages du SSO : Réduit la "fatigue des mots de passe" (et donc l'utilisation de mots de passe faibles), centralise le contrôle des accès pour les administrateurs, et réduit considérablement la charge de travail du support IT (réinitialisation de mots de passe).

Protocoles, Cadres ou Technologies

- **SAML** (Security Assertion Markup Language) : Standard ouvert d'entreprise basé sur XML pour échanger des données d'authentification ET d'autorisation entre un IdP et un SP. C'est le standard historique et le plus courant pour le SSO d'entreprise.
- **OAuth 2.0** : Standard ouvert pour la délégation d'accès (Autorisation). Il permet à un site web ou une application d'accéder aux données d'un utilisateur sur un autre site, sans jamais partager le mot de passe (utilise des tokens d'accès).
- **OpenID Connect (OIDC)** : Une couche d'identité (Authentification) construite au-dessus du protocole OAuth 2.0. Principalement utilisé pour l'authentification dans les applications web et mobiles modernes.
- **LDAP** (Lightweight Directory Access Protocol) : Protocole permettant d'accéder et de maintenir les services d'informations d'annuaires distribués (comme les utilisateurs et les groupes) sur un réseau IP. C'est la fondation de Microsoft Active Directory et d'OpenLDAP.

Ne pas confondre

- **SAML vs OAuth vs OpenID Connect (Le trio de pièges classiques) :**
 - SAML gère l'Authentification ET l'Autorisation. Il utilise XML et est conçu pour les entreprises lourdes.
 - OAuth ne gère QUE l'Autorisation (la délégation d'accès). Il ne vérifie pas "qui" vous êtes.

- OpenID Connect vient corriger OAuth en lui ajoutant la brique "Authentication". Il est léger et moderne.
- IdP (Identity Provider) vs SP (Service Provider) : L'IdP est la "douane" qui vérifie ton passeport et affirme qui tu es. Le SP est le "pays" dans lequel tu entres sur la base de la confiance accordée à la douane.

Moyens Mnémotechniques

- **OAuth** = Autorisation.
- **OpenID** = IDentité (Authentication).
- **SAML** = Security Assertion (les assertions XML).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Le point de défaillance unique (**SPOF**) du **SSO** : L'examen testera souvent le risque inhérent au Single Sign-On : si les identifiants d'un utilisateur sont compromis, l'attaquant obtient "les clés du royaume" et accède à TOUTES les applications liées. La réponse managériale (CISSP) pour mitiger ce risque est l'obligation d'utiliser le MFA (Authentication Multi-Facteurs) couplé au SSO.
- Fédération et Confiance (**Trust**) : Lors de l'intégration d'un partenaire commercial via une fédération d'identités, l'entreprise A fait confiance à l'entreprise B pour authentifier ses propres utilisateurs. L'examen insistera sur le fait que cette confiance doit être **formalisée juridiquement par des contrats stricts** (SLAs/B2B agreements) et des audits de conformité.
- Délégation d'accès (OAuth) : Si une question décrit un scénario où l'utilisateur autorise l'application A à lire ses contacts sur l'application B sans fournir son mot de passe, la réponse technique recherchée est OAuth.

5.4 - IMPLEMENTER ET GERER LES MECANISMES D'AUTORISATION

Résumé Général

Les contrôles d'accès sont les mécanismes et les politiques utilisés pour gérer et restreindre l'accès aux ressources dans un système d'information. L'objectif est d'appliquer le modèle le plus adapté à l'entreprise pour équilibrer sécurité, complexité et utilisabilité tout en maintenant la conformité.

Concepts Clés à retenir

- **MAC** (Mandatory Access Control - Contrôle d'accès obligatoire) : Modèle de sécurité où les droits d'accès sont **régulés par une autorité centrale en fonction des niveaux d'habilitation de sécurité** (Clearance). Les utilisateurs ne peuvent pas modifier les permissions d'accès, elles sont définies et appliquées par l'administrateur système. Très utilisé dans les gouvernements et l'armée.
- **DAC** (Discretionary Access Control - Contrôle d'accès discrétionnaire) : C'est **le propriétaire (Owner) de la ressource qui décide des niveaux d'accès**. C'est le modèle le plus flexible, utilisé par exemple pour les permissions de fichiers dans un système d'exploitation. Son risque majeur réside dans le fait que les utilisateurs peuvent accorder des accès excessifs, menant à des failles de sécurité.
- **RBAC** (Role-Based Access Control - Contrôle d'accès basé sur les rôles) : **Assigne les permissions en fonction du rôle de l'utilisateur au sein de l'organisation**. Il rationalise la gestion des accès, particulièrement dans les grandes entreprises avec de nombreux utilisateurs et fonctions.
- **RuBAC** (Rule-Based Access Control - Contrôle d'accès basé sur des règles) : **Les décisions d'accès sont basées sur un ensemble de règles définies par l'administrateur**. Utile dans les environnements nécessitant un contrôle strict, comme la sécurisation des ressources réseau via les pare-feux (ex : règles basées sur les adresses IP source/destination).

- **ABAC** (Attribute-Based Access Control - Contrôle d'accès basé sur les attributs) : **Utilise des politiques qui évaluent les caractéristiques (attributs) des utilisateurs, de l'environnement et des ressources.** Fournit un contrôle extrêmement granulaire et nuancé (fine-grained), idéal pour les environnements complexes et dynamiques.
- **Risk-Based Access Control** (Contrôle d'accès basé sur les risques) : **Les décisions d'accès sont prises dynamiquement en fonction du niveau de risque posé par l'utilisateur, l'appareil ou la requête** (et non plus seulement sur des rôles statiques). Aussi appelé accès adaptatif ou sensible au contexte. Il évalue des éléments comme la santé de l'appareil (patché, chiffré), la localisation (région habituelle vs inhabituelle) ou les modèles de comportement.

Protocoles, Cadres ou Technologies

- **ACLs (Access Control Lists)** : Souvent utilisées pour implémenter techniquement le DAC (**permissions NTFS/Linux**) ou le **RuBAC** (**règles de pare-feu et routeurs**).

Ne pas confondre

- **MAC vs DAC** : Dans le MAC, le système (et l'étiquette de sécurité) est roi, l'utilisateur n'a aucun pouvoir de modification. Dans le DAC, le créateur/propriétaire du fichier a le pouvoir absolu de donner l'accès à qui il veut, ce qui est dangereux.
- **RBAC (Rôle) vs ABAC (Attribut)** : Le RBAC vous donne accès parce que vous êtes "Comptable". L'ABAC vous donne accès parce que vous êtes "Comptable" (attribut utilisateur) travaillant "depuis le bureau" (attribut environnemental) sur un "PC de l'entreprise" (attribut ressource).

Moyens Mnémotechniques

- **MAC** = Militaire (Environnements hautement classifiés et stricts).
- **DAC** = Direction par le propriétaire (Discrétion du créateur).
- Les deux **RBAC** : Role-Based (Rôle RH / Métier) vs Rule-Based (Règle If/Then d'un pare-feu).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La gestion à grande échelle : L'examen testera la meilleure solution pour une entreprise qui grandit rapidement. Le DAC devient vite un cauchemar ingérable. Le MAC est trop rigide pour le secteur privé. La réponse managériale par défaut pour une entreprise est le RBAC (Rôle) car il permet de gérer les accès en masse via les profils de poste (Onboarding/Offboarding simplifié).
- L'accès Adaptatif (Zero Trust) : Si un scénario décrit un utilisateur essayant de se connecter depuis un ordinateur personnel à l'étranger et que le système lui demande soudainement un MFA, c'est l'application directe du Risk-Based Access Control (Accès basé sur le risque/contexte).
- Le piège du DAC : Le CISSP considère le DAC comme intrinsèquement risqué car il délègue la gestion de la sécurité aux utilisateurs finaux qui ne sont pas des experts en sécurité.

5.5 - GERER LE CYCLE DE VIE DU PROVISIONNEMENT DES IDENTITES ET DES ACCES

Résumé Général

Le cycle de vie des accès garantit qu'un utilisateur possède exactement les bons droits au bon moment, de son arrivée à son départ de l'entreprise. L'objectif est de réduire la surface d'attaque en automatisant la gestion des accès et en empêchant l'accumulation de privilèges inutiles au fil du temps.

Concepts Clés à retenir

- **Provisioning** (Création de compte) : Processus de création et de configuration d'un compte avec les droits d'accès appropriés. Comprend l'identification de l'utilisateur, l'attribution des droits selon le principe du moindre privilège, et l'application des mesures de sécurité (MFA, mots de passe forts).
- Transition de rôle (**Transfers/Role Transition**) : Ajustement des accès lorsqu'un employé change de poste. Il est crucial de retirer les anciens droits avant d'ajouter les nouveaux pour éviter les failles.
- Revue des accès (**Account Access Review**) : Validation périodique visant à s'assurer que les utilisateurs, les systèmes et les comptes de service ne détiennent que les permissions strictement nécessaires.
- Dérive des privilèges (**Privilege Creep**) : Vulnérabilité majeure se produisant lorsque les utilisateurs accumulent des droits d'accès excessifs au fil du temps (souvent à la suite de changements de poste).
- **Deprovisioning** (Révocation) : Processus de suppression ou de désactivation des comptes lorsqu'ils ne sont plus nécessaires (ex : départ d'un employé). Inclut la révocation immédiate des accès, la gestion des données de l'utilisateur et la désactivation/suppression du compte.
- **Comptes Orphelins et Dormants** : Les comptes d'anciens employés non révoqués (orphelins) ou les comptes inutilisés (dormants) représentent un risque élevé de compromission.

- Gestion des comptes de service (**Service Account Management**) : Comptes non-humains utilisés par des applications ou des scripts. Leurs mots de passe ne doivent pas être codés en dur (**hardcoded**) et doivent être protégés dans un coffre-fort (**Vault**), avec une surveillance stricte des abus.

Protocoles, Cadres ou Technologies

- Systèmes IAM (Identity and Access Management) : Outils technologiques permettant d'automatiser le provisionnement et le déprovisionnement pour éviter les erreurs humaines.

Ne pas confondre

- Comptes Partagés (**Shared accounts**) vs Comptes de Service : Les comptes partagés par plusieurs humains détruisent toute traçabilité (**Accountability**) et sont à proscrire. Les comptes de service sont légitimes pour les machines, mais nécessitent le moindre privilège et une journalisation stricte.
- Provisioning vs **Identity Proofing** : L'Identity Proofing (prouver qui l'on est) se fait avant. Le Provisioning est l'action technique qui suit l'Identity Proofing en créant le compte.

Moyens Mnémotechniques

- **JML (Joiner, Mover, Leaver)** : Les trois étapes clés du cycle de vie des employés à surveiller.
 - Joiner = Provisioning.
 - Mover = Transition de rôle (Risque de Privilege Creep).
 - Leaver = Deprovisioning immédiat.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- L'automatisation et l'auditabilité : Le CISSP considère que la gestion du cycle de vie doit être automatisée via des systèmes IAM et basée sur les rôles (RBAC) pour prévenir les erreurs humaines et la dérive des privilèges.
- La gestion du départ d'un employé : Si une question demande l'action la plus urgente lors du licenciement d'un employé, la réponse est toujours la révocation immédiate de ses accès logiques et physiques (Deprovisioning).

5.6 - IMPLEMENTER DES SYSTEMES D'AUTHENTIFICATION

Résumé Général

Ce sous-domaine porte sur la mise en oeuvre pratique des outils d'authentification pour sécuriser les accès. Il met l'accent sur la protection des comptes à hauts privilèges (PAM), la vérification initiale de l'identité, et la transition vers des méthodes plus robustes que les simples mots de passe.

Concepts Clés à retenir

- **Identity Proofing** (Preuve d'identité) : Processus validant **qu'une personne est bien celle qu'elle prétend être** avant de lui donner un accès. Méthodes utilisées :
 - Vérification de documents officiels (passeport).
 - **KBA (Knowledge-Based Authentication)** : Questions personnelles (ex : nom de jeune fille de la mère) connues censément par le seul utilisateur légitime.
 - Vérification biométrique ou via des services tiers.
- Gestion des mots de passe (**Best Practices**) : Les mots de passe restent la première ligne de défense. Les bonnes pratiques incluent une longueur adéquate (8-12 caractères minimum), la complexité, l'interdiction de réutilisation, et la surveillance de l'âge du mot de passe. Note : L'expiration forcée tous les 90 jours est aujourd'hui reconsidérée face aux connaissances modernes en sécurité.
- Gestionnaires de mots de passe (**Password Managers**) : Fortement encouragés pour gérer un grand nombre de mots de passe complexes. L'utilisateur n'a qu'à mémoriser un seul "Master Password" robuste.
- Authentification **Passwordless** (Sans mot de passe) : Remplacement des mots de passe traditionnels par des méthodes alternatives (biométrie, clés de sécurité, jetons à usage unique) pour éliminer les risques liés aux mots de passe faibles ou compromis.

- **PAM (Privileged Access Management)** : Outils conçus pour contrôler, gérer et surveiller les utilisateurs possédant des droits élevés (administrateurs). Ils incluent :
 - **JIT (Just-in-Time permissions)** : Accorder un accès privilégié uniquement en cas de besoin et pour une durée strictement limitée (ex : pour une maintenance ponctuelle).
 - **Password Vaulting** (Mise en coffre-fort) : Stockage centralisé et sécurisé des identifiants à privilèges. L'utilisateur "emprunte" (check out) le mot de passe, et le système le modifie automatiquement après utilisation.
 - Identifiants Éphémères (**Ephemeral Credentials**) : Mots de passe ou jetons temporaires générés à la demande et qui expirent après une courte durée, très utiles dans les environnements Cloud.

Protocoles, Cadres ou Technologies

- Outils PAM (CyberArk, BeyondTrust, etc.) : Indispensables pour implémenter le Vaulting et le JIT sur les comptes administrateurs.
- Clés de sécurité (Security Keys) : Périphériques matériels (ex : YubiKey) supportant les protocoles d'authentification forte (comme **U2F** ou **FIDO2**) pour prouver la possession ("quelque chose que vous avez").

Ne pas confondre

- Just-in-Time (JIT) vs Ephemeral Credentials : **Le JIT modifie les droits d'un utilisateur** existant pendant un temps donné (ex : un développeur devient temporairement admin). **Les identifiants éphémères créent un nouveau secret d'accès** (clé ou mot de passe) qui s'autodétruit très rapidement.
- KBA (Knowledge-Based Auth) vs MFA "Something you know" : Le KBA (Où êtes-vous né ?) sert souvent lors de l'Identity Proofing ou de la récupération de compte. Le "Something you know" classique est le mot de passe secret défini par l'utilisateur.

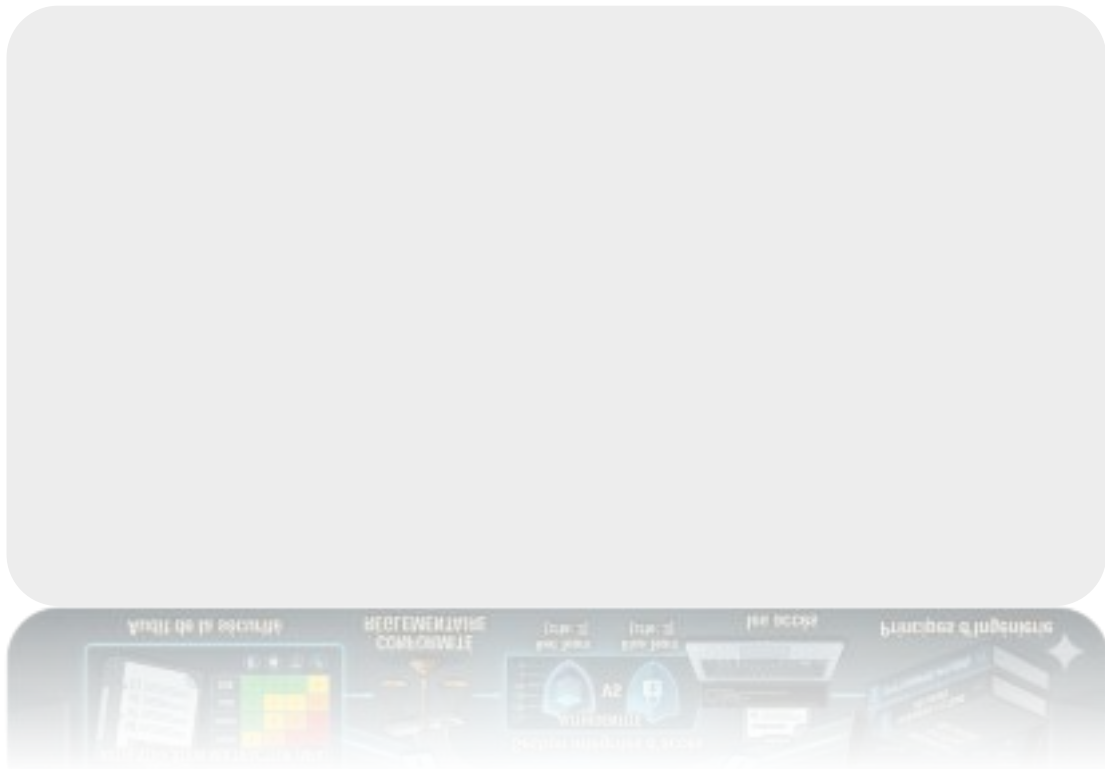
Moyens Mnémotechniques

- Le PAM contrôle les "Clés du Royaume". Si tu as des administrateurs, il te faut du PAM avec du Vaulting (Coffre) et du JIT (Juste à temps).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La gestion des comptes à hauts privilèges : C'est un sujet brûlant. Le CISSP considère que donner un compte administrateur permanent et statique à un employé est une erreur. La bonne réponse face à la sécurisation des administrateurs est l'utilisation d'outils PAM avec des droits Just-in-Time (JIT).
- Le changement de paradigme des mots de passe : Si l'examen propose une question sur la meilleure politique de mots de passe actuelle, imposer une rotation tous les 30 jours n'est plus la panacée (cela pousse les utilisateurs à utiliser "Motdepasse1", puis "Motdepasse2"). L'utilisation de Gestionnaires de mots de passe ou la **transition vers le Passwordless (avec MFA)** est privilégiée.

DOMAINE 6 : ÉVALUATION ET TESTS DE LA SECURITE



6.1 - CONCEVOIR ET VALIDER LES STRATEGIES D'EVALUATION, DE TEST ET D'AUDIT

Résumé Général

Ce sous-domaine structure l'approche permettant d'évaluer, de valider et d'améliorer les contrôles de sécurité à l'aide de revues, de tests et d'audits indépendants. L'objectif est d'obtenir l'assurance que le système est sécurisé dans n'importe quel environnement.

Concepts Clés à retenir

- Évaluations Internes (**Internal Assessments**) : Menées par **l'organisation elle-même** (auto-audits, scans, red/blue teams).
 - Avantages : Faible coût, détection précoce.
 - Risques : Manque d'indépendance, biais potentiel.
- Évaluations Externes (**External Assessments**) :
 - Réalisées par des entités externes mais toujours **sous le contrôle de l'organisation** (ex : consultants en tests d'intrusion).
 - Avantages : Perspective indépendante, crédibilité.
 - Risques : Plus coûteux, nécessite une définition stricte du périmètre (scoping).
- Audits Tiers (**Third-Party Audits**) :
 - Réalisés en dehors du contrôle de l'entreprise (régulateurs, organismes de certification comme ISO ou PCI DSS).
 - Avantages : La plus haute crédibilité, souvent requis pour la conformité.
 - Risques : Très coûteux, peut exposer des lacunes publiquement.

- Localisation de l'évaluation :
 - **On-Premises** (Sur site) : Focus sur l'accès physique et logique interne.
 - **Cloud** : Évaluation des modèles SaaS, IaaS, PaaS. Le défi majeur est le modèle de **responsabilité partagée**.
 - **Hybride** : Exige d'assurer une cohérence des politiques à travers tous les environnements.

Ne pas confondre

- Évaluation Externe vs Audit Tiers : L'évaluation externe est payée et dirigée par l'entreprise pour s'améliorer (ex : un consultant). L'audit tiers est imposé ou certifié par une autorité totalement indépendante (ex : un auditeur étatique ou ISO).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- L'approche en couches (Layered Assurance) : Ne jamais compter uniquement sur des audits externes. L'examen valorise une combinaison d'audits internes (fréquents) puis externes puis tiers pour une assurance globale.

6.2 - MENER DES TESTS DE SECURITE ET GESTION DES VULNERABILITES

Résumé Général

L'identification et l'exploitation encadrée des vulnérabilités (tests d'intrusion, scans) permettent de mesurer l'efficacité réelle des défenses face aux attaques. Ce processus inclut la détection, l'analyse, la classification et la remédiation (patch management).

Concepts Clés à retenir

- Tests de Sécurité Applicative :
 - **SAST (Static)** : Analyse du code source sans l'exécuter. Trouve les failles tôt dans le SDLC.
 - **DAST (Dynamic)** : Teste l'application en cours d'exécution (runtime) pour trouver des failles comme les XSS ou SQLi.
 - **Package Monitoring (SCA)** : Surveille les bibliothèques logicielles tierces pour y trouver des vulnérabilités connues.
- Types de Tests Spécifiques :
 - **Transactions Synthétiques** : Envoi d'actions simulées (ex : faux logins) pour vérifier le comportement et les performances sous contrainte.
 - **Misuse Case Testing** (Cas de mauvaise utilisation) : Tester comment le système réagit à des actions malveillantes (ex : tenter une injection SQL).
 - **Coverage Analysis** : S'assurer qu'absolument tous les contrôles et surfaces d'attaque ont été testés, sans aucun point aveugle.
 - **Interface Testing** : Tester la sécurité aux points d'interaction (UI, Réseau, APIs).
 - **BAS (Breach & Attack Simulations)** : Outils automatisés simulant des attaques du monde réel pour mesurer la résilience du SOC.

- Tests de Pénétration (**Pen Testing**) :
 - Méthodes : **Black Box** (Zéro connaissance), **Grey Box** (Connaissance partielle), **White Box** (Connaissance totale/Admin).
 - Acteurs : **White Hat** (Éthique avec permission), **Black Hat** (Malveillant sans permission), **Grey Hat** (Mixte), Script Kiddie (Utilise des outils sans coder).
 - **Règles d'Engagement (RoE)** : Définissent les IP autorisées, les horaires, les outils, et si le DoS ou l'ingénierie sociale sont permis. Il faut toujours un document signé de la direction avant de commencer et qui doit être conservé sur soi.
 - Méthodologie NIST (4 Étapes) :
 - **Reconnaissance/Découverte**
 - **Énumération**
 - **Recherche de Vulnérabilités**
 - **Exécution/Pénétration**
- Analyse et Gestion des Vulnérabilités :
 - **Faux Positif** : Une alerte déclenchée pour une activité bénigne (gaspille des ressources).
 - **Faux Négatif** : Le système rate une vraie vulnérabilité (Très dangereux).
 - **CVE** (Common Vulnerability Enumeration) : Base de données publique identifiant les failles.
 - **CVSS** (Common Vulnerability Scoring System) : Score de 0 à 10 mesurant la gravité.
- Remédiation et Validation :
 - **Patch Management** : Appliquer les mises à jour pour fermer les failles, en faisant attention à la compatibilité.
 - **Segmentation & Contrôles Compensatoires** : Isoler le système ou ajouter des alternatives si le patch est impossible.

- Validation : Refaire un scan (**Rescanning**) et vérifier (**Verification**) que la faille est bien fermée sans casser la production.
- Sources de Données et **Logs** : L'analyse s'appuie sur les logs (Pare-feu, Application, Endpoint, OS, IPS/IDS, Réseau, Métadonnées) et les captures de paquets (PCAP) pour comprendre l'incident.

Protocoles, Cadres ou Technologies

- NIST SP 800-115 : Méthodologie standard de test de pénétration en 4 étapes (Reconnaissance Énumération Recherche Vuln Exécution).

Ne pas confondre

- Scanner de Vulnérabilité vs Test de Pénétration : Le scanner (automatisé) identifie passivement les failles. Le test de pénétration (humain) exploite activement ces failles pour prouver l'impact métier réel.
- Faux Positif vs Faux Négatif : Le faux positif te fait perdre du temps. Le faux négatif te fait perdre ton entreprise (tu es piraté sans le savoir).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Permission écrite obligatoire : Un pentester ne doit jamais lancer le moindre scan sans un accord formel et signé de la direction (Rules of Engagement). Agir sans cet accord transforme le test en crime.
- Consentement aux risques : Le client doit signer qu'il accepte les risques (ex : faire planter un système industriel SCADA lors d'un scan).

6.3 - COLLECTER LES DONNEES DES PROCESSUS DE SECURITE

Résumé Général

La collecte et l'analyse de données de sécurité, tant techniques qu'administratives, permettent de mesurer l'efficacité réelle des processus, d'assurer la responsabilité (Accountability) et de soutenir les prises de décision de la direction.

Concepts Clés à retenir

- Gestion des comptes (**Account Management**) :
 - Suivre les créations de comptes, les modifications et les révocations (**deprovisioning**).
 - Collecter les journaux (**logs**) liés aux changements de privilèges, aux comptes dormants et aux tentatives de connexion ratées.
 - Objectif : Prévenir les accès non autorisés et détecter la dérive des privilèges (Privilege creep).
- Revue et approbation par la direction (**Management Review and Approval**) :
 - Documenter toutes les approbations de politiques de sécurité, la gestion des exceptions et les décisions formelles d'acceptation des risques.
 - Objectif : Fournir la preuve (évidence) de la surveillance et de l'implication de la haute direction, ce qui est indispensable pour valider les audits.
- Indicateurs de Performance et de Risque (KPIs / KRIs) :
 - **KPI (Key Performance Indicators)** : Métriques montrant à quel point les processus de sécurité sont performants (ex : pourcentage de terminaux mis à jour dans le délai prévu par le SLA).
 - **KRI (Key Risk Indicators)** : Métriques montrant les risques à venir (ex : nombre de vulnérabilités critiques non corrigées).

- Données de vérification des sauvegardes :
 - **Collecter les journaux** et rapports confirmant le succès des opérations de sauvegarde.
 - **Collecter les résultats** de tests lors d'exercices de restauration périodiques.
 - Objectif : **Valider l'intégrité** et la **disponibilité** des données pour la récupération.
- **Formation et Sensibilisation** (Training & Awareness) :
 - Suivre les taux de complétion des formations par les employés.
 - Analyser les résultats des simulations de phishing ou des quiz de sensibilisation pour mesurer l'état de préparation du personnel face aux menaces humaines.
- Reprise après sinistre et Continuité (**DR & BC**) :
 - Collecter les métriques de réussite du **RTO** (Recovery Time Objective) et du **RPO** (Recovery Point Objective) lors des tests de DR.
 - Documenter les leçons apprises (**lessons learned**) lors des exercices sur table (**tabletop**) et des tests de basculement (**failover**).

Ne pas confondre

- KPI (Indicateur de Performance) vs KRI (Indicateur de Risque) :
 - Le KPI regarde vers le passé/présent pour évaluer l'efficacité d'un processus existant (A-t-on bien effectué notre travail ?).
 - Le KRI regarde vers l'avenir pour alerter sur une vulnérabilité ou un danger croissant (Sommes-nous en danger ?).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Preuves Techniques vs Preuves Administratives : La collecte de données soutient la surveillance continue. Le CISSP sait que les logs techniques des pare-feux ne suffisent pas : il faut les équilibrer avec des preuves administratives (signatures, approbations du management, registres de formation).

- L'exigence des auditeurs : Les auditeurs et les régulateurs n'acceptent pas les promesses orales. Ils exigent une "assurance basée sur des preuves" (**evidence-based assurance**) pour valider les processus de sécurité.

6.4 - ANALYSER LES RESULTATS DES TESTS ET GENERER DES RAPPORTS

Résumé Général

Après avoir mené des évaluations, des audits ou des tests de sécurité, les résultats doivent être analysés, documentés et communiqués. Les rapports produits orientent les parties prenantes sur les risques identifiés, les actions à mener et les responsabilités.

Concepts Clés à retenir

- Remédiation (**Remediation**) :
 - Il s'agit des actions correctives prises pour réparer les vulnérabilités ou les faiblesses de contrôle identifiées.
 - Exemples : Appliquer des correctifs (patches), mettre à jour des configurations, améliorer la surveillance ou renforcer la formation.
 - Les actions de remédiation doivent être priorisées en fonction de la gravité du risque et de l'impact sur le métier (Business impact).
 - Règle d'or du rapport : Les rapports doivent toujours inclure des **actions recommandées**, désigner des propriétaires (**owners**) pour ces actions, et fixer des délais stricts (**timelines**).
- Gestion des Exceptions (**Exception Handling**) :
 - Utilisé lorsqu'un risque ou une vulnérabilité **ne peut pas être corrigé immédiatement** (ex : un système Legacy obsolète qui ne supporte pas le chiffrement).
 - Ce risque doit être formellement documenté, et des contrôles compensatoires doivent être appliqués.
 - Règle stricte : L'exception nécessite **l'approbation de la direction** et doit inclure une date d'expiration ou de révision claire.

- Divulgence Éthique (**Ethical Disclosure**) :
 - Le signalement responsable des vulnérabilités aux parties concernées (ex : un chercheur découvrant une faille et la signalant d'abord au fournisseur du logiciel via une divulgation coordonnée).
 - Objectif : Réduire le risque en permettant la création d'un patch sans exposer prématurément les détails sensibles au public, équilibrant ainsi la transparence et la sécurité.

Ne pas confondre

- Remédiation vs Gestion des exceptions :
 - La Remédiation résout le problème à la source (on ferme la faille).
 - L'Exception est un accord formel pour vivre temporairement avec la faille parce qu'on ne peut pas faire autrement à l'instant T (nécessite l'accord du management).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Les "**exceptions permanentes**" : C'est un piège majeur. Une exception sans date de fin devient un risque caché ("**hidden risk**") oublié par l'entreprise. Le CISSP exige qu'une exception ait toujours une date d'expiration pour forcer sa réévaluation.
- Caractéristiques d'un bon rapport : Les résultats d'un test sont inutiles s'ils ne débouchent pas sur des actions. Un rapport CISSP doit être :
 - Clair (**Clear**) : Compréhensible par les parties prenantes techniques ET non techniques.
 - Actionnable (**Actionable**) : Avec une hiérarchisation des priorités et l'attribution claire des responsabilités.
 - **Auditable** : Servant de preuve formelle de diligence raisonnable (**Due Diligence**)

6.5 - MENER OU FACILITER LES AUDITS DE SECURITE

Résumé Général

Un audit de sécurité est une revue formelle et systématique des politiques, des contrôles et des processus de sécurité d'une organisation. Son objectif est de vérifier la conformité, l'efficacité et la posture globale face aux risques, tout en fournissant une assurance aux partenaires, aux clients et aux régulateurs.

Concepts Clés à retenir

- Types d'Audits :
 - **Audit Interne** : Réalisé par le personnel de l'organisation (équipe de sécurité, conformité, audit). Il est peu coûteux, flexible et prépare aux audits externes. Risque : Il peut manquer d'indépendance et comporter un risque de biais.
 - **Audit Externe** : Réalisé par des consultants indépendants ou des cabinets contractés, mais toujours sous le contrôle de l'organisation. Il offre une validation indépendante et une crédibilité auprès de la direction et des régulateurs. Risque : Plus coûteux et nécessite une définition de périmètre (scoping) très minutieuse.
 - **Audit Tiers** (Third-Party) : Réalisé en dehors du contrôle de l'entreprise par des organismes de réglementation, des autorités de certification ou des évaluateurs contractuels (ex : QSA pour PCI DSS, auditeur ISO 27001). Il offre la plus haute crédibilité et est souvent obligatoire pour la conformité. Risque : Très lourd en ressources, et des résultats négatifs peuvent impacter des contrats ou la réputation.
- Localisation de l'Audit :
 - **Sur site (On-Premises)** : Examen des centres de données physiques, des systèmes internes et des contrôles locaux.
 - **Cloud** : Nécessite une collaboration avec les fournisseurs de services cloud (CSPs) en raison du modèle de responsabilité partagée. Repose souvent sur des rapports tiers comme les rapports SOC 2.

- **Hybride** : Combinaison du cloud et du sur-site, exigeant de vérifier la cohérence des politiques à travers tous les environnements.
- **Rapports SOC** (System and Organization Controls) : Des revues indépendantes des contrôles d'une organisation, réalisées selon les normes de l'AICPA. Ils sont critiques pour évaluer les fournisseurs Cloud et les services gérés.
 - **SOC 1** : Se concentre sur les contrôles internes liés aux rapports financiers. Destiné aux auditeurs financiers, directeurs financiers (CFOs) et régulateurs.
 - **SOC 2** : Se concentre sur les contrôles liés à la Sécurité, la Disponibilité, l'Intégrité du traitement, la Confidentialité et la Vie privée (Trust Services Criteria). C'est LE rapport de référence pour les professionnels de l'informatique (CISO, gestion des risques fournisseurs).
 - **SOC 3** : Évalue les mêmes critères que le SOC 2, mais sous forme de résumé public simplifié. Il ne contient pas de détails sensibles et est utilisé comme outil marketing (souvent publié sur le site web du fournisseur).
- Types de rapports SOC (Applicables pour SOC 1 et SOC 2) :
 - **Type I** : Confirme que les politiques et contrôles existent et sont documentés/conçus correctement à un instant T (à une date précise).
 - **Type II** : Confirme que ces contrôles fonctionnent efficacement sur une période donnée (généralement 6 à 12 mois).

Protocoles, Cadres ou Technologies

- AICPA (American Institute of Certified Public Accountants) : L'organisation qui définit les normes pour les audits et les rapports SOC.
- PCI DSS / ISO 27001 : Cadres de sécurité nécessitant souvent des audits tiers formels (Third-Party Audits).

Ne pas confondre

- Audit Interne vs Audit Externe : L'audit interne est fait par tes propres employés (risque de partialité). L'audit externe est fait par un consultant que tu as embauché.
- SOC 1 vs SOC 2 : SOC 1 = Finance/Comptabilité. SOC 2 = Cybersécurité/IT.
- SOC 2 vs SOC 3 : Le SOC 2 est ultra-détaillé et confidentiel (ne se partage qu'avec les clients sous accord de non-divulgence). Le SOC 3 est une version publique allégée pour le marketing.
- Type I vs Type II : Type I = Évaluation de la conception à une date précise (Point in time). Type II = Évaluation de l'efficacité opérationnelle sur une longue période (Over time).

Moyens Mnémotechniques

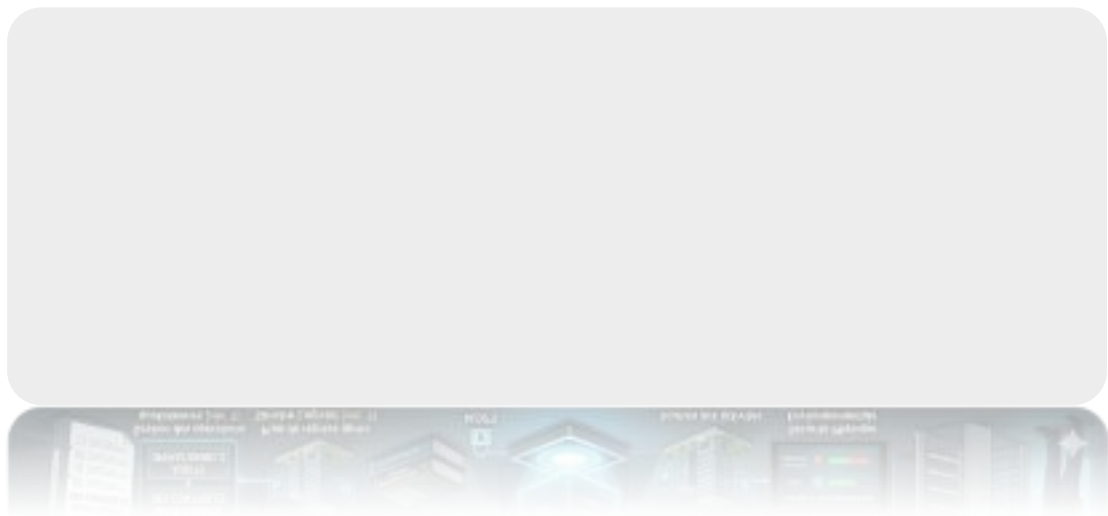
- Type 1 vs Type 2 :
 - Type 1 = Une Photo (un instant précis).
 - Type 2 = Un Film (une durée de 6 à 12 mois).
- SOC 1, 2, 3 :
 - 1 = Argent/Finance
 - 2 = IT (Sécurité/Privé).
 - 3 = WWW (Web/Public).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Évaluation d'un fournisseur Cloud (SaaS/IaaS/PaaS) : Si l'examen te demande la meilleure méthode pour qu'un CISO valide la posture de sécurité d'un futur fournisseur Cloud sans pouvoir l'auditer lui-même, la réponse attendue est d'exiger son rapport SOC 2 Type II.
- Le principe d'Indépendance : Un audit n'a de la valeur que s'il est indépendant. L'examen insistera sur le fait qu'une équipe informatique ne doit jamais auditer son propre travail (conflit d'intérêts).
- L'assurance en couches (Layered Assurance) : Les audits visent à apporter des garanties, de la responsabilité et une amélioration

continue. Le CISSP privilégie une combinaison : utiliser l'audit interne d'abord, puis l'externe, puis le tiers pour créer une assurance en profondeur.

DOMAINE 7 : OPERATIONS DE SECURITE



7.1 - INVESTIGATIONS ET ENQUETES

Résumé Général

L'objectif de ce sous-domaine est d'établir les faits lors d'un incident de sécurité ou d'une violation de politique de manière à ce que les preuves numériques collectées soient admissibles, authentiques et inaltérées devant un tribunal ou une instance réglementaire.

Concepts Clés à retenir

- Types de preuves (**Evidence Types**) :
 - Preuve Réelle (**Real evidence**) : Les objets physiques (ex : clé USB, disque dur, ordinateur).
 - **Preuve Documentaire** : Les registres écrits, les journaux (logs), les courriels, les rapports.
 - **Preuve Testimoniale** : Les déclarations orales ou écrites de témoins (interviews).
 - **Preuve Démonstrative** : Les graphiques, diagrammes ou reconstitutions utilisés pour expliquer la situation de façon visuelle.
- Principes de collecte des preuves :
 - **Admissibilité** : La preuve doit être pertinente, fiable et obtenue légalement pour être présentée en cours.
 - **Intégrité** : La preuve ne doit pas être altérée, corrompue ou détruite.
 - **Authentification** : Capacité à prouver que la preuve est bien ce qu'elle prétend être.
 - Règle de la meilleure preuve (**Best evidence rule**) : Les preuves originales sont toujours préférées aux copies.
- Chaîne de traçabilité (**Chain of Custody**) : Un document ininterrompu qui prouve la chronologie de la preuve. Il documente qui l'a collectée, la date/heure, où elle a été stockée, et qui y a accédé. C'est indispensable pour préserver la crédibilité devant un tribunal.

- **Ordre de volatilité (**Order of Volatility**)** : Les données doivent être collectées des plus éphémères aux plus permanentes :
 - a. **Registres CPU et Cache.**
 - b. **RAM** (Table de routage, cache ARP, statistiques du noyau).
 - c. **Trafic réseau.**
 - d. **Disque dur** (Fichiers, système d'exploitation).
 - e. **Sauvegardes** (Backups).
- **Types d'Investigations** :
 - **Administrative** : Enquête interne (RH, IT). Cible les violations de politiques. Standard : **Prépondérance de la preuve.**
 - **Criminelle** : Menée par les forces de l'ordre. Cible les lois enfreintes. Standard : **Au-delà d'un doute raisonnable.**
 - **Civile** : Litige privé (contrats). Standard : **Prépondérance de la preuve.**
 - **Réglementaire** : Menée par des agences externes (ex : HIPAA, GDPR) pour vérifier la conformité.
- **Forensique Numérique et Manipulation (Handling)** :
 - Ne jamais analyser l'équipement original.
 - Créer une copie bit-à-bit (clone parfait, incluant l'espace vide et les fichiers effacés).
 - Utiliser des Bloqueurs d'écriture (Write blockers) lors de la copie pour éviter d'altérer la source.
 - Calculer les Hashes (MD5, SHA-1, SHA-256) de l'original et de la copie pour prouver qu'ils sont identiques (Intégrité).
- **Artéfacts** : Traces laissées par une attaque.
 - **Fichiers/Métadonnées** : Horodatages MAC (Modified, Accessed, Created).
 - **Système/OS** : Registre Windows (programmes installés, USB), crontab, syslog.
 - **Réseau** : PCAP (captures de paquets), NetFlow, logs pare-feu/proxy.

- **Mobiles** : Journaux d'appels, GPS, métadonnées EXIF des photos.

Protocoles, Cadres ou Technologies

- Outils Forensiques (Exemples industriels) : EnCase, FTK (Forensic Toolkit), Autopsy/Sleuth Kit pour les disques ; Volatility, Rekall pour la RAM ; Wireshark, tcpdump, Zeek pour le réseau.
- NTP (Network Time Protocol) : Indispensable pour la synchronisation temporelle afin que les horodatages (timestamps) soient valides et corrélables lors d'une enquête.

Ne pas confondre

- Interview vs Interrogatoire (Interrogation) : L'interview est une conversation neutre visant à trouver des faits (utilisée en interne/audit). L'interrogatoire est réservé aux forces de l'ordre (police/militaire) pour questionner des suspects.
- **Au-delà d'un doute raisonnable vs Prépondérance de la preuve** : Le pénal (criminel) exige un niveau de certitude quasi absolu (car on risque la prison). Le civil et l'administratif n'exigent qu'une "prépondérance" (il suffit de prouver qu'il est probable à 51% que le fait soit vrai).

Moyens Mnémotechniques

- L'ordre de volatilité : Crazy Ram Needs Disk Backups (CPU -> RAM -> Network -> Disk -> Backups).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La préparation au tribunal : Une règle d'or pour le CISSP est d'agir en permanence comme si les preuves allaient finir devant un tribunal. Même si c'est une petite enquête RH, la chaîne de traçabilité est non négociable.
- Toucher l'original : Si une question demande ce qu'un enquêteur doit faire en premier avec le PC d'un attaquant, la réponse n'est jamais de l'allumer ou d'explorer ses dossiers. La réponse est de débrancher l'appareil ou de **créer une image forensique bit-à-bit via un bloqueur d'écriture**.

7.2 - JOURNALISATION ET SURVEILLANCE

Résumé Général

La journalisation (Logging) et la surveillance permettent de rendre le réseau "observable" afin de détecter proactivement les menaces, de s'assurer de la conformité (Accountability) et de répondre rapidement aux incidents de sécurité. Sans surveillance, l'entreprise est aveugle.

Concepts Clés à retenir

- Composants de la surveillance :
 - **Agrégation de logs (Log Aggregation)** : Collecter et consolider les messages générés par de multiples sources à travers le réseau dans un point central (souvent via un Syslog Collector).
 - **SIEM (Security Information and Event Management)** : Outil central qui agrège les logs, les normalise (format commun) et les corrèle pour fournir une analyse en temps réel, alerter sur des modèles d'activité inhabituels et générer des rapports.
 - **UEBA (User & Entity Behavior Analytics)** : Utilisation de l'analytique pour surveiller et évaluer le comportement des utilisateurs. L'objectif est de créer une ligne de base (baseline) puis de détecter des déviations pouvant indiquer une menace interne (Insider threat) ou un compte compromis.
- Cycle de vie de la gestion des logs :
 - a. **Collecte** : Rassembler depuis les serveurs, terminaux, applications.
 - b. **Normalisation & Agrégation** : Convertir dans un format cohérent et supprimer les doublons.
 - c. **Stockage & Rétention** : Stocker de manière sécurisée (chiffré, inaltérable) selon les règles de conformité.
 - d. **Surveillance & Analyse** : Corrélation en temps réel et alertes.

- e. **Revue & Rapports** : Audits réguliers pour la direction et la conformité.
- **Threat Hunting** (Chasse aux menaces) : Approche proactive et itérative visant à chercher manuellement ou via des outils des menaces avancées qui auraient contourné les défenses automatisées existantes (IDS/Antivirus).
- Flux de renseignements sur les menaces (Threat Feeds) :
 - **OSINT** (Open-Source Intelligence) : Données publiques gratuites.
 - **Propriétaires / Tiers** : Services payants (temps réel, spécialisés).
 - **ISACs (Information Sharing and Analysis Centers)** : Groupes de partage d'informations spécifiques à une industrie (ex : ISAC de la santé, ISAC de la finance).
 - **Dark Web** : Surveillance des marchés illicites pour anticiper les outils ou tactiques des pirates.
- Sources de données primaires :
 - **Logs Pare-feu** (Firewall) : Connexions tentées/bloquées, trafic autorisé.
 - **Logs Applicatifs** : Performance, erreurs, événements de sécurité internes à l'app.
 - **Logs Endpoints & OS** : Mises à jour, connexions réussies/ratées (logon/logoff), alertes antivirus.
 - **Logs IPS/IDS** : Violations de politiques et détections de trafic réseau suspect.
 - **Captures de paquets** (PCAP) : Enregistrement complet du trafic réseau (utile pour comprendre une exfiltration ou un malware).
 - **Métadonnées** : Données sur les données (ex : expéditeur/destinataire d'un courriel, localisation).

Protocoles, Cadres ou Technologies

- **Syslog** (Port UDP 514 par défaut) : Standard pour la transmission des messages de journalisation des appareils réseau vers un

collecteur central. Les versions modernes utilisent TCP et TLS pour sécuriser ces flux en transit.

Ne pas confondre

- Surveillance en temps réel vs Surveillance périodique : La surveillance en temps réel (SIEM/IPS) vise la réponse immédiate aux menaces (gourmande en ressources). La surveillance périodique (scans réguliers, revues de logs) sert aux systèmes non critiques ou à la conformité (audits).
- SIEM vs Threat Hunting : Le SIEM est réactif (il sonne quand une règle est enfreinte). Le Threat Hunting est proactif (un humain cherche activement des menaces silencieuses qui n'ont déclenché aucune alerte).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Protection des journaux (Logs) : Les logs sont la cible numéro 1 d'un hacker qui vient de pénétrer un système (pour effacer ses traces). Le CISSP exige que **les logs soient centralisés, chiffrés, avec des contrôles d'accès stricts (WORM - Write Once Read Many)** pour garantir leur Non-répudiation.
- Normalisation : Le plus grand défi de l'agrégation de logs est que chaque système (Windows, Cisco, Linux) parle une "langue" de log différente. La réponse à ce problème est la Normalisation opérée par le SIEM.

7.3 - GESTION DES CONFIGURATIONS

Résumé Général

La gestion des configurations consiste à contrôler et maintenir de façon sécurisée et cohérente les paramètres matériels et logiciels de l'infrastructure informatique. L'objectif est d'empêcher les modifications non autorisées qui pourraient créer des vulnérabilités ou perturber la disponibilité.

Concepts Clés à retenir

- Configuration de Production (**Production Configuration**) :
 - Il s'agit des paramètres et réglages actuellement utilisés et actifs dans l'environnement opérationnel du réseau.
 - Elle doit être surveillée en permanence pour s'assurer des performances et détecter toute altération.
- Configuration de Sauvegarde (**Backup Configuration**) :
 - La **conservation d'une copie conforme des configurations** de l'équipement (ex : la configuration d'un routeur ou d'un pare-feu).
 - Objectif : Empêcher la perte de données en cas de panne matérielle et permettre une restauration extrêmement rapide pour assurer la Continuité des Activités.
- **Baseline / Golden Configuration** (Ligne de base / Image Dorée) :
 - Un modèle de référence (**Template**) approuvé par la sécurité, contenant les réglages idéaux et durcis.
 - Sert de standard pour le déploiement de tout nouvel appareil, garantissant ainsi que tous les systèmes naissent avec un niveau de sécurité identique et conforme.
- Dérive de configuration (**Configuration Drift**) : (Concept inhérent pour le CISSP)
 - Le phénomène où **la Configuration de Production s'éloigne (dérive) de la Golden Configuration au fil du temps** à cause

de modifications locales, d'urgences ou de mises à jour non tracées.

Protocoles, Cadres ou Technologies

- **IaC (Infrastructure as Code)** / Outils d'automatisation (Ansible, Terraform) : (Lien avec le domaine 3) **Technologies permettant de déployer, vérifier et forcer en continu le respect de la Baseline Configuration pour prévenir la dérive.**

Ne pas confondre

- Production Configuration vs Baseline Configuration :
 - La Baseline est l'idéal théorique approuvé (le standard à atteindre).
 - La Production est la réalité du terrain (qui doit être alignée sur la Baseline, mais qui peut subir des dérives).
- Backup Data vs Backup Configuration : La sauvegarde de données protège les fichiers métiers (ex : bases de données, documents utilisateurs). La configuration de sauvegarde protège le "cerveau" de l'infrastructure (ex : les règles ACL du routeur) pour éviter de devoir tout reconfigurer à zéro.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La standardisation avant tout : Pour un manager CISSP, le déploiement manuel d'équipements est une faille en soi car il introduit l'erreur humaine. L'examen privilégiera toujours l'utilisation d'une Baseline (Golden Image) automatisée.
- Le traitement de la dérive (Drift) : Si un audit révèle que les serveurs en production ont des ports ouverts qui ne sont pas dans la Baseline, le système souffre de Configuration Drift. L'action corrective managériale est d'identifier pourquoi le processus de gestion des changements n'a pas été respecté.

7.4 - CONCEPTS FONDAMENTAUX DES OPERATIONS DE SECURITE

Résumé Général

Les opérations de sécurité quotidiennes (SecOps) reposent sur des principes administratifs stricts visant à réduire la surface d'attaque, limiter les menaces internes et s'assurer que les employés et les fournisseurs n'ont accès qu'à ce qui est strictement nécessaire pour leur travail.

Concepts Clés à retenir

- Besoin d'en connaître (**Need-to-Know**) : L'utilisateur n'a accès qu'aux données et informations spécifiques requises pour accomplir sa fonction.
- Moindre privilège (**Least Privilege**) : L'utilisateur (ou le processus) ne reçoit que les droits et permissions systèmes minimums nécessaires pour accomplir ses tâches. Réduit la surface d'attaque et limite les dégâts en cas de compromission d'un compte. Appliqué via le RBAC et des revues régulières.
- Séparation des tâches (**Separation of Duties - SoD**) : Aucune personne seule ne doit avoir la capacité d'exécuter l'intégralité d'une transaction critique. (Ex : Le développeur écrit le code, le testeur le valide, l'opérationnel le déploie). Préviend la fraude et augmente la responsabilité.
- Gestion des comptes à privilèges (PAM - **Privileged Account Management**) : Les comptes administrateurs (root, domain admin, comptes de service) posent un risque d'impact maximal en cas d'abus. Contrôles exigés : coffres-forts de mots de passe (Vaulting), surveillance et audit stricts des activités, et MFA obligatoire.
- Rotation des postes (**Job Rotation**) : Déplacer périodiquement les employés sur différents rôles.
 - Avantages : Réduit la fraude (il est difficile de cacher une anomalie quand quelqu'un d'autre reprend le poste), assure une formation croisée (cross-training), améliore la résilience opérationnelle et identifie les points de défaillance uniques humains (SPOF).

- Accords de niveau de service (**SLAs - Service-Level Agreements**) : Contrat définissant les attentes entre un fournisseur et un client.
 - Composants : Disponibilité/Uptime (ex : 99.9%), Performance (temps de réponse), Sécurité (gestion des données, conformité), Support, et Pénalités en cas de non-respect. Fournit de la responsabilité et de la confiance.

Ne pas confondre

- Need-to-Know vs Least Privilege : Le Need-to-Know concerne l'accès à la donnée (ex : le droit de lire un dossier classifié). Le Least Privilege concerne l'action sur le système (ex : le droit de lecture, mais pas le droit d'effacer le dossier).
- Séparation des tâches (SoD) vs Contrôle duel (Dual Control) : La SoD divise un processus en plusieurs étapes faites par des personnes différentes. Le Contrôle duel exige que deux personnes agissent simultanément pour faire une seule action (ex : tourner deux clés en même temps pour ouvrir un coffre).

Moyens Mnémotechniques

- SoD (Separation of Duties) : Diviser pour mieux régner (sur la fraude). Si on ne peut pas diviser (entreprise trop petite), on compense (Audits stricts).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Les contrôles compensatoires pour la SoD : Si une petite entreprise n'a qu'un seul administrateur IT, la Séparation des Tâches est impossible. Le CISSP exige alors l'implémentation de contrôles compensatoires, tels que la journalisation (logging) stricte et l'audit régulier de ses actions par un tiers.
- Confiance envers les fournisseurs : On ne fait jamais "simplement confiance" à un fournisseur cloud pour la disponibilité. La garantie s'obtient uniquement par le biais d'un SLA contractuel.

7.5 - PROTECTION DES RESSOURCES

Résumé Général

La protection des ressources englobe la gestion sécurisée des supports de stockage physiques (clés USB, bandes) tout au long de leur cycle de vie, ainsi que la protection cryptographique inébranlable des données, qu'elles soient au repos sur un disque ou en transit sur un réseau.

Concepts Clés à retenir

- Gestion des supports (**Media Management**) : Contrôler et tracer les supports de stockage.
 - **Étiquetage** et **Classification** : Identifier visuellement la sensibilité (Confidentiel, Public).
 - **Contrôle d'accès & Inventaire** : Restreindre au personnel autorisé et maintenir des journaux de mouvements.
 - **Conditions de stockage** : Protéger contre les risques environnementaux (feu, eau, champs magnétiques).
 - **Transport contrôlé** : Utiliser des coursiers sécurisés, des conteneurs scellés ou des sacs avec témoin d'effraction (tamper-evident).
- Techniques de protection des supports :
 - **Chiffrement** : Protéger les clés USB, disques durs (HDD) et bandes.
 - Démagnétisation (**Degaussing**) : Effacer les supports magnétiques.
 - **Broyage/Incinération** : Pour la destruction physique définitive.
 - **Protection en écriture** (Write Protection) : Empêcher la modification non autorisée.
- Nettoyage des données (Sanitization - NIST SP 800-88) :
 - **Clear** (Nettoyer) : Écraser avec des données non sensibles (permet la réutilisation en interne).

- **Purge** : Démagnétisation ou effacement sécurisé avancé (permet de sortir le matériel de l'entreprise).
- **Destroy** (Détruire) : Destruction physique.
- Protection des Données au Repos (**Data at Rest**) : Données stockées sur disque, bande ou cloud.
 - Contrôles : Chiffrement (AES-256 ou équivalent), chiffrement complet du disque (BitLocker), application stricte des ACLs/RBAC, et sécurisation des sauvegardes.
- Protection des Données en Transit (**Data in Transit**) : Données traversant un réseau.
 - Contrôles : Protocoles forts (TLS 1.2/1.3, IPsec, SSH, HTTPS, VPN) et chiffrement de bout en bout (E2E).
 - Certificats : Utiliser des certificats numériques pour l'authentification mutuelle.
 - Intégrité : Utiliser le hachage (SHA-256), les signatures numériques et les codes HMAC.
 - Prévention : Désactiver les protocoles faibles pour empêcher les attaques par rétrogradation (Downgrade attacks), comme SSL ou TLS 1.0.

Protocoles, Cadres ou Technologies

- NIST SP 800-88 : Le standard absolu (Guidelines for Media Sanitization) définissant les méthodes Clear, Purge, et Destroy.
- AES-256 / TLS 1.3 / IPsec : Les standards de référence actuels pour chiffrer respectivement au repos et en transit.

Ne pas confondre

- Clear vs Purge : Clear protège contre les outils de récupération basiques (tu donnes le PC à un autre service de ta boîte). Purge protège contre les attaques de récupération avancées en laboratoire (tu vends le PC sur eBay).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Les sauvegardes sont des cibles de choix : Les attaquants ciblent souvent les bandes de sauvegarde en transit (lorsqu'elles sont envoyées vers un site de stockage externe). Le CISSP exige que ces supports soient chiffrés avant de quitter le bâtiment et transportés via une chaîne de traçabilité stricte.
- Downgrade attacks : Si un serveur supporte à la fois TLS 1.3 et le vieux SSL v3 "pour des raisons de compatibilité", un attaquant fera croire au serveur que le client ne comprend que le SSL v3 pour forcer une connexion vulnérable. Solution CISSP : Désactiver purement et simplement les protocoles obsolètes.

7.6 - GESTION DES INCIDENTS

Résumé Général

La gestion des incidents est le processus structuré permettant de détecter, de réagir et de se remettre d'événements de sécurité. L'objectif principal n'est pas d'attraper le hacker, mais de minimiser les dommages, de restaurer les services critiques au plus vite, de prévenir la récurrence et de maintenir la confiance.

Concepts Clés à retenir

- Événement vs Incident :
 - Événement (Event) : Toute occurrence observable sur un système ou un réseau (ex : une connexion d'utilisateur, une entrée de log, une alerte). C'est généralement bénin ou neutre.
 - Incident : Un événement indésirable confirmé qui menace ou compromet activement la Confidentialité, l'Intégrité ou la Disponibilité (CIA) d'un système.
- Le cycle de vie de la réponse à incident (**Incident Management Lifecycle**) :
 - a. **Préparation** : Former l'équipe (CSIRT), préparer les outils, les politiques et les plans de communication.
 - b. **Détection et Analyse** : Identifier l'incident via les alertes (SIEM/IDS), évaluer sa portée (Triage) et confirmer qu'il s'agit bien d'un incident.
 - c. Confinement (**Containment**) / Atténuation : Arrêter l'hémorragie. Isoler le système compromis du réseau pour empêcher l'attaque de se propager (sans forcément l'éteindre si l'on veut garder des preuves en RAM).
 - d. Éradication (**Remediation**) : Supprimer la cause racine. Effacer le malware, bloquer les comptes compromis, patcher la vulnérabilité exploitée.
 - e. Récupération (**Recovery**) : Restaurer les systèmes à partir de sauvegardes saines, les remettre en production sous haute surveillance pour s'assurer que l'attaquant n'est plus là.

- f. Leçons apprises (**Lessons Learned / Post-Incident**) : L'étape la plus critique pour l'amélioration continue. Réunion pour analyser ce qui a fonctionné, ce qui a échoué, et mettre à jour les politiques et défenses pour empêcher une récurrence.

Ne pas confondre

- Confinement (Containment) vs Éradication :
 - Le Confinement, c'est mettre un garrot sur une blessure (débrancher le câble réseau du serveur infecté).
 - L'Éradication, c'est extraire la balle et désinfecter (supprimer le rootkit et appliquer le patch de sécurité).
- Événement vs Incident : Un pare-feu qui bloque un ping est un événement. Un pare-feu qui s'éteint sous la charge d'un DDoS est un incident.

Moyens Mnémotechniques

- Les phases de l'incident : Préparer, Détecter, Contenir, Eradiquer, Récupérer, Leçons (PDC-ERL).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- L'objectif prioritaire de l'Incident Response : Contrairement à ce que pensent les techniciens, le but de la réponse à incident n'est pas de remonter l'IP de l'hacker pour "contre-attaquer". L'objectif CISSP est de contenir les dégâts et restaurer les opérations métiers normales (Business Continuity).
- Leçons apprises (Lessons Learned) : L'examen adore tester cette phase. Un processus de gestion des incidents n'est jamais terminé tant qu'un rapport "Post-Mortem" n'a pas été rédigé pour ajuster les contrôles de sécurité et améliorer le programme de gestion des risques.
- Ne pas détruire les preuves : Lors de la phase de confinement, si le technicien éteint brutalement l'ordinateur infecté au lieu de le déconnecter du réseau, il détruit irrémédiablement l'ordre de volatilité (RAM effacée). Le CISSP veille à équilibrer le confinement avec la préservation des preuves (Forensics).

7.7 - IMPLEMENTER DES MESURES DE DETECTION ET DE PREVENTION

Résumé Général

La défense moderne ne se contente plus d'ériger des murs (pare-feu). Elle combine des techniques proactives (analyse de code, sandboxing) et des pièges (technologies de leurre) pour détecter les attaques sophistiquées, retarder les attaquants et apprendre de leurs méthodes avant qu'ils n'atteignent les vraies données.

Concepts Clés à retenir

- Listes blanches et Listes noires (Allowlisting / Blocklisting) :
 - **Allowlisting** (Default Deny) : Tout est bloqué par défaut, sauf ce qui est explicitement autorisé. C'est la méthode la plus sécurisée (ex : n'autoriser que 3 applications à s'exécuter sur un serveur).
 - **Blocklisting** (Default Allow) : Tout est autorisé, sauf ce qui est explicitement interdit (ex : un antivirus classique qui bloque les signatures connues). Plus facile à gérer, mais vulnérable aux menaces Zero-Day.
- Sécurité des applications (**AppSec**) :
 - Validation des entrées (**Input Validation**) : Le contrôle le plus critique. Filtrer et nettoyer tout ce que l'utilisateur tape dans un formulaire pour empêcher les injections SQL, XSS ou les dépassements de tampon (Buffer Overflow). Doit toujours être fait côté serveur.
 - **Cookies sécurisés** : Utiliser les attributs Secure (le cookie ne voyage qu'en HTTPS) et HttpOnly (le cookie ne peut pas être lu par un script JavaScript, bloquant ainsi le vol par XSS).
 - Analyse de code statique (**SAST**) : Scanner le code source à la recherche de failles de sécurité avant la compilation.
 - Signature de code (**Code Signing**) : Utiliser un certificat numérique pour signer un logiciel ou un script. Garantit l'Intégrité (le code n'a pas été modifié) et l'Authenticité (il vient bien du bon développeur).

- **Sandboxing** (Mise en bac à sable) :
 - Exécuter un code suspect ou non testé dans un environnement virtuellement isolé (qui imite un vrai système) pour observer son comportement sans risquer d'infecter le réseau de production.
- Technologies de leurre (**Deception Technologies**) :
 - **Honeypot** (Pot de miel) : Un système factice conçu pour ressembler à une cible attrayante (ex : un faux serveur de base de données). Sert à détecter les intrus, les ralentir et analyser leurs techniques.
 - **Honeynet** : Tout un réseau composé de plusieurs honeypots.
 - **Honeyfile** : Un faux document nommé de façon alléchante (ex : salaires_2026.xlsx) surveillé par une alerte silencieuse. Dès qu'un attaquant l'ouvre, l'équipe de sécurité est prévenue.
 - **Honeytoken** : De faux identifiants (mots de passe, clés d'API) injectés dans le système. S'ils sont utilisés quelque part, c'est la preuve certaine d'une compromission.
- **Outils basés sur l'IA et le Machine Learning (AI/ML)** :
 - Utilisés pour l'analyse comportementale (UEBA) et le SIEM de nouvelle génération. Ils apprennent ce qu'est une activité "normale" et alertent sur les déviations (anomalies) plus vite qu'un humain. Attention au risque d'empoisonnement des données (Data Poisoning) par l'attaquant pour fausser l'apprentissage.

Protocoles, Cadres ou Technologies

- **OWASP Top 10** : La référence incontournable listant les failles d'applications web les plus critiques (Injection, Faille d'authentification, etc.) que les contrôles du domaine 7.7 doivent prévenir.

Ne pas confondre

- Validation côté Client vs Validation côté Serveur : La validation côté client (dans le navigateur Web) est juste là pour le confort de l'utilisateur (lui dire qu'il a oublié l'@ dans son courriel). Elle ne vaut

rien en sécurité car un attaquant peut la contourner. La vraie sécurité se fait via la validation côté Serveur.

- Honeypot vs IPS (Intrusion Prevention System) : L'IPS bloque activement le mauvais trafic. Le Honeypot attire le mauvais trafic pour l'étudier, il ne doit jamais être placé sur le même réseau local que les systèmes de production critiques.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La finalité du Honeypot : L'examen peut te demander pourquoi installer un Honeypot. La mauvaise réponse est "pour attraper et poursuivre le pirate en justice" (très difficile techniquement et légalement, risque de provocation - **Entrapment**). La bonne réponse CISSP est "pour étudier les tactiques des attaquants et améliorer nos propres défenses (Threat Intelligence)".

7.8 - GESTION DES VULNERABILITES ET DES CORRECTIFS

Résumé Général

La gestion des correctifs est le processus vital consistant à identifier, tester et déployer des mises à jour logicielles pour fermer les failles de sécurité. Le CISSP insiste sur le fait que l'application de patches ne doit jamais se faire à l'aveugle: la disponibilité (ne pas casser le système) est aussi importante que la sécurité.

Concepts Clés à retenir

- Le cycle de vie du Patch Management :
 - a. **Détection/Évaluation** : Scanner le réseau et suivre les bulletins de sécurité (CVE) pour identifier les systèmes vulnérables.
 - b. **Test** : C'est l'étape la plus testée à l'examen. Ne jamais patcher la production en premier. Toujours déployer le correctif dans un environnement de test ou de pré-production (Staging) pour s'assurer qu'il ne crée pas de plantage ou d'incompatibilité métier.
 - c. **Déploiement** : Appliquer le patch selon le processus de gestion des changements (pendant une fenêtre de maintenance).
 - d. **Validation** (Rescanning) : Relancer un scan de vulnérabilité ou un audit pour confirmer que la faille est bien fermée.
- Contrôles Compensatoires (**Compensating Controls**) :
 - Parfois, un patch ne peut pas être appliqué (ex : système médical Legacy certifié, Windows XP sur une chaîne de montage SCADA).
 - Il faut alors appliquer une segmentation du réseau (isoler la machine via un VLAN ou un pare-feu très strict), du Virtual Patching (WAF/IPS qui bloque l'exploit avant qu'il n'atteigne le système), ou la déconnecter complètement (Air-Gap).

- Exceptions et Exemptions :
 - Si un risque ne peut être corrigé techniquement (Patch) ou par un contrôle compensatoire, le système doit faire l'objet d'une Exception formelle.
 - L'exception doit inclure une analyse de risque, être formellement approuvée et signée par la direction, et posséder une date d'expiration pour forcer une réévaluation.

Ne pas confondre

- Patch de sécurité vs Mise à jour de fonctionnalité (Feature update) :
Le patch de sécurité corrige une faille (CVE) et doit être traité rapidement. La mise à jour de fonctionnalité ajoute de nouveaux outils, elle suit un cycle beaucoup plus long et prudent.

Moyens Mnémotechniques

- Les **4 T** du **Patching** : **Track** (Suivre), **Test** (Tester), **Target** (Déployer), **Troubleshoot/Verify** (Vérifier).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- L'urgence vs La disponibilité : L'éditeur de ton OS publie un patch classé "Critique" un vendredi après-midi. Que fais-tu ?
 - Piège : Le déployer immédiatement sur tous les serveurs de production pour bloquer les hackers.
 - CISSP Mindset : Le déployer d'abord dans l'environnement de test. La précipitation casse les systèmes. Même pour une urgence absolue, un test minimal de non-régression est exigé.
- La gestion du Legacy (**Obsolescence**) : Une question classique implique un vieil équipement industriel non-patchable. La réponse attendue est toujours l'isolation (Segmentation/Air-gap) de cet équipement du reste du réseau de l'entreprise.

7.9 - PROCESSUS DE GESTION DES CHANGEMENTS

Résumé général

La gestion des changements est le pilier de la stabilité et de la sécurité opérationnelle. Tout changement non documenté ou non approuvé (même s'il est censé corriger un bug) est considéré par le CISSP comme un incident de sécurité, car il introduit des variables inconnues qui peuvent détruire la disponibilité ou ouvrir des failles.

Concepts Clés à retenir

- L'objectif principal : Garantir que les modifications apportées à l'infrastructure informatique se font de manière contrôlée, documentée et sans perturber les opérations métiers (Disponibilité).
- Le processus structuré (Étapes vitales) :
 - a. Demande de changement (**RFC - Request For Change**) : Tout commence par un document formel expliquant ce qui doit être changé et pourquoi.
 - b. Analyse d'impact (**Impact Analysis**) : Évaluer ce qui pourrait mal tourner. Quels systèmes sont touchés ? Est-ce que cela affecte la sécurité ou les performances ?
 - c. Approbation (**CAB - Change Advisory Board**) : Un comité réunissant des représentants de l'IT, de la sécurité et du métier (Management). Ils examinent l'analyse d'impact et approuvent (ou rejettent) la RFC.
 - d. **Planification et Test** : Tester le changement hors production. Définir une fenêtre de maintenance.
 - e. **Déploiement** : Implémenter le changement.
 - f. **Validation et Documentation** : Vérifier que ça marche, mettre à jour les schémas réseau et la configuration de base (Baseline).

- Plan de retour en arrière (**Backout Plan / Rollback**) :
 - C'est l'élément le plus critique d'une RFC. Si le changement se passe mal en plein milieu de la nuit, comment fait-on pour remettre le système exactement dans l'état où il était avant ? Une RFC sans Backout Plan doit être systématiquement refusée.
- Propriété (**Ownership**) : Chaque changement doit avoir un responsable (Sponsor/Owner) clairement identifié qui endosse la responsabilité de son succès ou de son échec.
- Fenêtre de maintenance (**Maintenance Window**) : Une plage horaire pré-approuvée (généralement la nuit ou le week-end) où la perturbation des services aura le moins d'impact financier sur l'entreprise.

Protocoles, Cadres ou Technologies

- **ITIL** (Information Technology Infrastructure Library) : Le cadre de bonnes pratiques de gestion des services informatiques d'où est tiré ce modèle rigoureux de gestion des changements.

Ne pas confondre

- RFC (Demande) vs CAB (Comité) : La **RFC est le document** (le "Quoi" et le "Pourquoi"). Le **CAB est l'équipe humaine** (le "Oui" ou le "Non").
- Configuration Management vs Change Management : La gestion des configurations (7.3) identifie et stocke la version actuelle de l'infrastructure. La gestion des changements (7.9) est le processus humain/administratif pour obtenir le droit de la modifier.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- L'héroïsme est un défaut : Un administrateur système voit un serveur sur le point de planter et applique une modification rapide "à la volée" qui sauve le serveur.
 - Piège : L'examen te demande de juger cette action. Tu pourrais être tenté de le féliciter.
 - CISSP Mindset : Il a enfreint la politique. Un changement non autorisé est inacceptable, même avec de bonnes intentions, car il crée une dérive (**Configuration Drift**) qui nuira aux futurs dépannages. Il aurait dû suivre la procédure de "Changement d'Urgence" (**Emergency Change**) qui nécessite l'approbation du **manager de permanence (ECAB)**.
- L'absence du plan de repli (Rollback) : Si on te présente une demande de changement parfaitement planifiée mais sans plan de retour en arrière, la seule action possible pour un membre du CAB est de la rejeter immédiatement.

7.10 - STRATEGIES DE RECUPERATION

Résumé Général

L'objectif des stratégies de récupération est de concevoir une infrastructure capable d'encaisser les pannes (tolérance aux pannes) et de restaurer rapidement les données et les opérations métiers en cas de sinistre, tout en respectant le budget alloué par la direction.

Concepts Clés à retenir

- Sites de secours (Alternate Sites) :
 - **Hot Site** (Site Chaud) : Entièrement configuré avec le matériel, les logiciels et les données (répliquées en temps réel). Prêt à prendre le relais en quelques minutes/heures. Très cher.
 - **Warm Site** (Site Tiède) : Possède le matériel, le réseau et l'électricité, mais les données ne sont pas à jour et les serveurs doivent être configurés. Prêt en quelques jours. Compromis coût/efficacité.
 - **Cold Site** (Site Froid) : Un simple local avec l'électricité et la climatisation. Aucun équipement IT. Prêt en plusieurs semaines. Le moins cher, mais le plus long.
 - **Mobile Site** : Remorque ou camion équipé en data center mobile.
- **Haute Disponibilité (HA) & Tolérance aux Pannes** :
 - **Clustering** : Regrouper plusieurs serveurs (nœuds) agissant comme un seul. Si l'un tombe (failover), les autres prennent la charge de manière transparente.
 - **Load Balancing** (Répartition de charge) : Distribue le trafic entrant sur plusieurs serveurs pour éviter la surcharge et éliminer le point de défaillance unique (SPOF).

- **RAID (Redundant Array of Independent Disks) :**
 - **RAID 0 (Striping) : Répartit les données sur 2 disques.** Ultra rapide, mais AUCUNE tolérance aux pannes (si un disque meurt, tout est perdu).
 - **RAID 1 (Mirroring) : Copie exacte sur 2 disques.** Si un meurt, l'autre a tout.
 - **RAID 5 (Striping avec Parité) : Minimum 3 disques.** Les données et la parité sont réparties. Tolère la perte d'un seul disque.
 - **RAID 10 (1+0) : Combine le Mirroring et le Striping. Minimum 4 disques.** Haute performance et haute sécurité.
- **Stratégies de Sauvegarde (Backups) :**
 - **Complète (Full) :** Sauvegarde absolument tout. Archive Bit remis à zéro. Temps de sauvegarde : Très lent. Temps de restauration : Très rapide (1 seule bande).
 - **Différentielle (Differential) :** Sauvegarde tout ce qui a changé depuis la dernière sauvegarde complète. Ne remet PAS l'Archive Bit à zéro. Temps de restauration : Moyen (Bande Full + Dernière bande différentielle).
 - **Incrémentielle (Incremental) :** Sauvegarde tout ce qui a changé depuis n'importe quelle dernière sauvegarde. Remet l'Archive Bit à zéro. Temps de sauvegarde : Très rapide. Temps de restauration : Très lent (Bande Full + TOUTES les bandes incrémentielles dans l'ordre).
- **Escrow Logiciel (Software Escrow) :** Un tiers de confiance conserve le code source d'une application critique que tu as achetée. Si le fournisseur fait faillite, le tiers te donne le code source pour que tu puisses continuer à le maintenir.

Protocoles, Cadres ou Technologies

- **Règle du 3-2-1 :** La bonne pratique absolue pour les sauvegardes. Avoir au moins 3 copies des données, stockées sur **2 supports différents**, dont **1 copie conservée hors site** (offsite) ou dans le Cloud.

Ne pas confondre

- Différentielle vs Incrémentielle : Pour la restauration, la Différentielle nécessite seulement 2 éléments (La dernière complète + La dernière différentielle). L'Incrémentielle nécessite le puzzle entier (La dernière complète + l'incrémentielle de lundi + l'incrémentielle de mardi + l'incrémentielle de mercredi...).

Moyens Mnémotechniques

- RAID 0 : Le "0" signifie "Zéro tolérance aux pannes, Zéro donnée si ça casse".
- Cold Site : Un espace vide, "froid", sans ordinateurs pour te chauffer.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Sauvegarde vs Haute Disponibilité : Le RAID n'est PAS une sauvegarde. Si tu effaces accidentellement un fichier, le RAID 1 (Miroir) va instantanément effacer le fichier sur le deuxième disque. Seule une vraie sauvegarde permet de récupérer d'une erreur humaine ou d'un ransomware.
- Choix du site de secours : La décision d'opter pour un Hot Site (très cher) plutôt qu'un Cold Site ne se prend jamais sur un coup de tête technique, elle doit toujours être justifiée par l'analyse d'impact sur l'activité (BIA) et les exigences de temps de récupération (RTO).

7.11 - PROCESSUS DE REPRISE

APRES SINISTRE

Résumé Général

Le Plan de Reprise d'Activité (DRP - Disaster Recovery Plan) est le mode d'emploi tactique utilisé par les équipes IT pendant et juste après une catastrophe majeure (incendie, ransomware destructeur, inondation). Son but est de stabiliser la situation et de redémarrer les systèmes IT critiques sur un site alternatif.

Concepts Clés à retenir

- Les Métriques du Temps (Très testées) :
 - **MTD / MAO (Maximum Tolerable Downtime)** : Le temps maximum absolu pendant lequel l'entreprise peut survivre sans ce processus avant de faire faillite ou de subir des dommages irréparables.
 - **RPO (Recovery Point Objective)** : La tolérance à la perte de données (Mesuré vers le passé). Ex : Si RPO = 4 heures, il faut faire des sauvegardes toutes les 4 heures.
 - **RTO (Recovery Time Objective)** : Le temps ciblé pour redémarrer le système IT (Mesuré vers le futur).
 - **WRT (Work Recovery Time)** : Le temps nécessaire pour configurer le système IT restauré, tester les bases de données et remettre le service aux utilisateurs métiers.
 - **Règle d'or mathématique** : **RTO + WRT ne doit jamais dépasser le MTD.**
- Étapes du processus DRP :
 - a. **Réponse / Détection** : Évaluation initiale pour déclarer officiellement le "Sinistre" (Disaster).
 - b. **Personnel (Life Safety First)** : S'assurer que tout le monde est sain et sauf.
 - c. **Communications** : Informer les équipes de crise, les relations publiques et éventuellement les régulateurs (Call Trees).

- d. Restauration (**Recovery**) : Redémarrer les opérations IT critiques sur le site alternatif (Hot/Warm/Cold site) en suivant l'ordre de priorité défini dans le BIA.
- e. Reconstitution (**Reconstitution** / Salvage) : Ramener les opérations du site de secours vers le site principal (une fois le site principal réparé ou reconstruit).
- Ordre de restauration : On ne rallume pas tout au hasard. On restaure d'abord l'infrastructure réseau/pare-feu, puis l'Active Directory (IAM), puis les bases de données, puis les applications métiers.

Ne pas confondre

- RPO (Données) vs RTO (Temps IT) : Le RPO répond à "Combien d'heures de travail pouvons-nous perdre ?". Le RTO répond à "Dans combien de temps les serveurs doivent-ils être rallumés ?".
- Restauration (Recovery) vs Reconstitution (Salvage) : La restauration, c'est l'urgence (fuir l'incendie et allumer le site de secours). La reconstitution, c'est le retour à la normale, souvent des mois plus tard (quitter le site de secours pour revenir dans le nouveau bâtiment principal).

Moyens Mnémotechniques

- Point = Passé (RPO : Les données perdues avant le crash).
- Time = RTO : Le temps pour redémarrer après le crash.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Priorité absolue : L'examen te mettra dans une situation de panique (Le datacenter prend feu). Quelle est ta première action ? Appeler les pompiers ? Sauver le serveur de la base de données ? Sortir ton manuel DRP ? NON. La première action est toujours l'évacuation et la sécurité de la vie humaine.
- La déclaration formelle : Le basculement vers un site alternatif coûte extrêmement cher. Un technicien ne peut pas déclencher le DRP de son propre chef. La déclaration formelle d'un sinistre doit toujours venir d'un cadre supérieur désigné.

7.12 - TESTS DU PLAN DE REPRISE APRES SINISTRE

Résumé Général

Un plan DRP qui n'a jamais été testé n'est qu'une théorie dangereuse. Ce sous-domaine détaille les 5 méthodes pour s'assurer que le plan fonctionne vraiment, du simple contrôle de lecture à l'interruption complète de la production. L'objectif est de trouver les failles du plan de manière contrôlée, avant qu'une vraie catastrophe ne survienne.

Concepts Clés à retenir

- Les 5 niveaux de tests DRP (Du moins risqué au plus risqué) :
 - a. **Read-Through** (Revue sur table / Checklist) : Chaque manager lit sa partie du plan DRP de son côté pour vérifier s'il manque des éléments évidents (ex : un numéro de téléphone obsolète).
 - b. **Structured Walk-Through** (Exercice sur table / Tabletop) : L'équipe de crise se réunit dans une salle de conférence (ou sur Zoom). Un animateur donne un scénario (ex : "Il y a une inondation") et l'équipe discute étape par étape de ce qu'elle ferait, en utilisant le plan DRP. Aucun impact sur les systèmes IT.
 - c. **Simulation** : Va plus loin que l'exercice sur table. L'équipe réagit en temps réel à un scénario en simulant les actions (ex : faire semblant de contacter les fournisseurs, vérifier physiquement que les clés de la salle de secours sont là). Toujours aucun impact sur la production.
 - d. **Parallel Test** (Test en Parallèle) : Les systèmes de production continuent de tourner normalement sur le site principal. En parallèle, l'équipe DRP se rend sur le site de secours (Hot/Warm site), l'allume, et restaure les données à partir des sauvegardes pour s'assurer que le site de secours fonctionne réellement. Risque très faible pour le métier.
 - e. **Full Interruption Test** (Test d'interruption complète) : On débranche (littéralement ou logiquement) les systèmes de production du site principal ! L'entreprise entière bascule et

travaille sur le site de secours. Le test ultime, mais le plus dangereux. Peut causer une vraie catastrophe s'il échoue.

Ne pas confondre

- Tabletop (Walk-Through) vs Simulation : Le Tabletop est une discussion assise autour d'un café. La Simulation implique des actions physiques (vérifier le matériel, lancer un appel de test), mais sans toucher aux serveurs.
- Parallel Test vs Full Interruption Test : Dans le test parallèle, l'entreprise continue de gagner de l'argent sur le site A pendant que l'IT joue sur le site B. Dans le test d'interruption complète, on "tue" le site A pour forcer le site B à prendre le relais.

Moyens Mnémotechniques

- L'ordre de difficulté : Read, Walk, Simulate, Parallel, Full. (Restons Wifi Sans Perdre le Fil).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La gestion des risques lors des tests : Le CISSP insiste sur le fait que le test d'un plan ne doit jamais causer la catastrophe qu'il est censé prévenir. Le test d'interruption complète (Full Interruption) ne doit être programmé que si tous les autres tests précédents (Parallèle, Simulation) ont été réussis haut la main, et toujours avec l'approbation du plus haut niveau de direction (Board/CEO).
- Pourquoi tester ? Si une question te demande l'objectif principal d'un test DRP, ce n'est pas "vérifier que les serveurs s'allument", mais "identifier les lacunes du plan actuel pour pouvoir le mettre à jour et former le personnel".

7.13 - MAINTENANCE DU PLAN

Résumé Général

Un Plan de Continuité des Activités (BCP) ou un Plan de Reprise d'Activité (DRP) n'est pas un document que l'on rédige une fois pour le ranger dans un tiroir. C'est un document vivant. Ce sous-domaine aborde la nécessité vitale de maintenir ces plans à jour pour qu'ils reflètent fidèlement la réalité de l'entreprise lors d'une crise.

Concepts Clés à retenir

- **Intégration à la gestion des changements** : C'est le concept central. Chaque fois qu'une modification majeure est apportée à l'infrastructure informatique, aux processus métiers ou au personnel clé (via le processus formel de Change Management), le BCP/DRP doit être mis à jour en conséquence.
- **Revue régulières** (Periodic Reviews) : La direction et l'équipe de continuité doivent examiner le plan au minimum une fois par an, ou lors de chaque changement organisationnel majeur (fusion, acquisition, déménagement du siège social).
- **Mises à jour post-incident** (After-Action Updates / Lessons Learned) : Après chaque exercice de test (Simulation, Parallèle) ou après un vrai sinistre, l'équipe doit analyser ce qui n'a pas fonctionné et mettre à jour le plan immédiatement pour corriger ces lacunes.
- **Contrôle des versions** (Version Control) : Les anciennes versions du plan doivent être détruites ou archivées formellement pour éviter qu'un employé n'utilise des procédures obsolètes (ou de faux numéros de téléphone) en pleine situation d'urgence.
- **Distribution sécurisée et accessible** : Le plan contient des informations extrêmement sensibles (architecture du réseau, contacts des dirigeants). Il doit être protégé contre les fuites (Confidentialité). Cependant, des copies physiques (papier) doivent être stockées dans des endroits sûrs hors site (offsite) ou dans les domiciles des responsables, car en cas de panne de courant ou de ransomware total, la version numérique sera inaccessible.

Ne pas confondre

- Test du plan vs Maintenance du plan : Le test (7.12) sert à trouver les erreurs. La maintenance (7.13) est l'action de corriger ces erreurs dans le document officiel et de s'assurer que les numéros de téléphone sont toujours les bons.

Moyens Mnémotechniques

- Un plan DRP est comme un logiciel : s'il n'est pas patché (mis à jour) régulièrement, il plantera le jour où tu en auras le plus besoin.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La cause n1 d'échec d'un DRP : L'examen adore demander pourquoi la plupart des plans de reprise échouent lors d'une vraie catastrophe. La réponse est invariablement : "Parce que le plan n'a pas été maintenu à jour ou testé régulièrement" (ex : la liste d'appels d'urgence contient des employés qui ont quitté l'entreprise depuis 2 ans).
- Stockage du plan : Si une question te demande la meilleure façon de stocker le BCP, méfie-toi des réponses ultra-technologiques comme "Uniquement sur un serveur chiffré dans le cloud". Lors d'une panne réseau totale, tu ne pourras pas y accéder. Le CISSP exige toujours des copies physiques (Hard copies) sécurisées hors site.

7.14 - METTRE EN OEUVRE ET GERER LA SECURITE PHYSIQUE

Résumé Général

Alors que l'architecture (Domaine 3) a construit les murs et les portes, ce sous-domaine se concentre sur les opérations quotidiennes de sécurité physique. Il s'agit de s'assurer que les processus humains, la gestion des accès tangibles et la surveillance active fonctionnent correctement tous les jours pour protéger le personnel et les équipements.

Concepts Clés à retenir

- Gestion opérationnelle des **accès physiques** :
 - **Badges et Cartes d'identité** : Le processus de création, d'attribution et surtout de révocation immédiate en cas de perte, de vol ou de licenciement d'un employé. Un badge perdu non désactivé est une faille critique.
 - **Audits d'accès** : Vérifier régulièrement les journaux (logs) des lecteurs de badges pour s'assurer que personne n'accède au data center à 3h du matin sans autorisation valide (détection d'anomalies).
- Gestion des visiteurs (**Visitor Management**) :
 - Tous les visiteurs doivent être enregistrés dans un registre (**Logbook**), prouver leur identité et porter un badge visiteur visible et distinct (ex : d'une couleur différente).
 - **Escorte obligatoire** : Dans les zones sensibles, un visiteur ne doit jamais se promener seul.
 - **Contrôle d'accès temporaire** : Les badges visiteurs doivent expirer automatiquement à la fin de la journée.
- Le facteur humain et le contrôle :
 - Gardes de sécurité (**Security Guards**) : Le contrôle de sécurité physique le plus dynamique et flexible. Contrairement à une caméra, un garde peut faire preuve de jugement, intervenir physiquement et s'adapter à une situation imprévue. Inconvénients : Coûteux, sujets à la fatigue, à l'ingénierie sociale ou à la corruption.

- **CCTV** (Vidéosurveillance) : Utilisée pour la détection (si surveillée en direct) ou pour l'enquête post-incident (Determine/Delay). Les opérations exigent de vérifier régulièrement que l'angle des caméras n'a pas été dévié et que l'espace de stockage des enregistrements est suffisant.
- Prévention opérationnelle des intrusions :
 - **Tailgating** (Talonnage) : Un intrus se faufile juste derrière un employé autorisé sans badger.
 - **Piggybacking** : Un employé autorisé, par politesse, tient la porte ouverte à un inconnu (qui prétend avoir oublié son badge).
 - Parade opérationnelle : **Formation intensive à la culture de la sécurité** ("Ne tenez pas la porte") et contestation des personnes sans badge visible.
- Maintenance des contrôles environnementaux :
 - Faire le plein de carburant des générateurs de secours de façon régulière.
 - Tester périodiquement les onduleurs (UPS) pour s'assurer que les batteries fonctionnent encore.
 - Vérifier la pression des extincteurs.

Protocoles, Cadres ou Technologies

- Bien qu'il s'agisse de sécurité physique, les badges modernes utilisent souvent la technologie RFID ou NFC couplée à des protocoles chiffrés pour éviter le clonage de cartes (Skimming).

Ne pas confondre

- Domaine 3 (Conception) vs Domaine 7 (Opérations) : Installer un tourniquet à l'entrée, c'est de l'ingénierie (D3). Rédiger la procédure qui oblige l'agent d'accueil à vérifier l'identité de chaque personne passant le tourniquet, c'est de l'opération (D7).
- Tailgating vs Piggybacking : Dans le Tailgating, l'employé ne sait pas qu'il est suivi. Dans le Piggybacking, l'employé est complice par politesse ou naïveté.

Moyens Mnémotechniques

- Garde vs Caméra : Le garde est Dynamique (il agit). La caméra est Documentaire (elle enregistre).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La gestion d'un badge perdu : C'est un classique. Si un employé déclare avoir perdu son badge d'accès au bâtiment, la première action (avant même de lui en donner un nouveau ou de chercher le badge) est de désactiver immédiatement l'ancien badge dans le système.
- Le maillon faible de la sécurité physique : L'examen rappelle constamment que peu importe le prix de tes serrures biométriques, la courtoisie humaine (tenir la porte à quelqu'un qui a les bras chargés de cartons) est la principale faille exploitée par les auditeurs physiques et les attaquants (Ingénierie sociale). La solution CISSP est la formation continue (Awareness).

7.15 - SECURITE DU PERSONNEL

Résumé Général

Dans la hiérarchie des priorités de l'ISC2 et du CISSP, la vie et la sécurité humaine priment absolument sur tout le reste (matériel, données, réputation, argent). Ce sous-domaine encadre la protection des employés contre les menaces physiques, les situations de contrainte, et les risques liés aux voyages d'affaires.

Concepts Clés à retenir

- **Priorité à la vie humaine (Life Safety First)** : C'est le commandement numéro un. Les contrôles de sécurité (portes, pare-feu) ne doivent jamais entraver l'évacuation en toute sécurité des employés.
- **Systèmes de contrainte (Duress Systems)** : Mécanismes utilisés lorsqu'un employé est physiquement menacé (ex : un intrus braque une arme sur un gardien pour qu'il ouvre une porte sécurisée).
 - **Duress PIN** (Code sous la contrainte) : Un code spécial tapé sur le clavier de la porte. Il ouvre la porte (pour ne pas énerver l'agresseur) mais déclenche simultanément une alarme silencieuse à la police ou au centre de sécurité (SOC).
 - **Bouton d'urgence (Panic Button)** : Bouton discret sous un bureau.
- **Sécurité des voyages (Travel Safety)** : Les employés voyageant dans des pays à haut risque (espionnage industriel, cybercriminalité étatique) nécessitent des protocoles stricts.
 - **Appareils jetables (Burner Devices)** : Ne jamais emporter son ordinateur ou son téléphone professionnel principal. Fournir des "Burner laptops/phones" vides, contenant uniquement les données strictement nécessaires au voyage.
 - **Règles de connexion** : Interdiction absolue d'utiliser le Wi-Fi public gratuit ou les clés USB offertes lors de salons (risques de MITM ou de Juice Jacking). Utilisation obligatoire d'un VPN "Always-on".
 - **Nettoyage au retour** : À la seconde où l'employé rentre au pays, l'appareil de voyage doit être considéré comme compromis, confisqué, et son disque dur entièrement effacé (Wiped) avant toute reconnexion au réseau interne.

- Urgences et Évacuations :
 - **Fail-Safe** vs **Fail-Secure** : (Rappel critique) En cas de panne de courant ou d'alarme incendie, les portes électroniques doivent se déverrouiller automatiquement (Fail-Safe) pour permettre aux gens de fuir.
 - **Muster Point** (Point de rassemblement) : Zone sécurisée prédéfinie à l'extérieur du bâtiment où les employés se regroupent lors d'une évacuation pour permettre le comptage (Headcount).

Protocoles, Cadres ou Technologies

- VPN (Virtual Private Network) : Technologie obligatoire pour chiffrer les communications de tout employé travaillant en déplacement ou depuis un hôtel.

Ne pas confondre

- Fail-Safe vs Fail-Secure :
 - Fail-Safe = La serrure lâche, la porte s'ouvre (Protège la VIE humaine).
 - Fail-Secure = La serrure se bloque, la porte reste fermée (Protège les OBJETS de valeur). Pour les sorties de secours des employés, c'est toujours Fail-Safe.

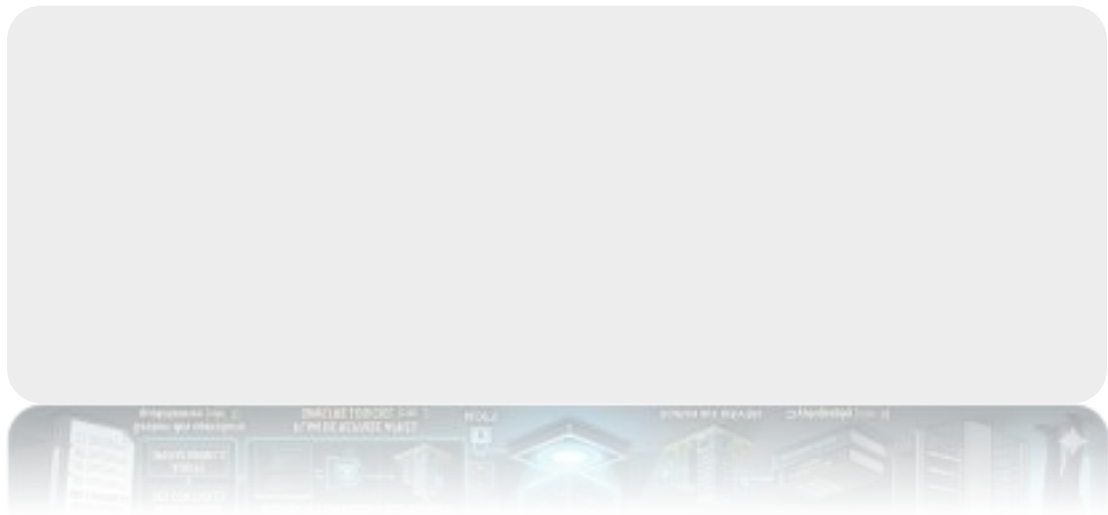
Moyens Mnémotechniques

- Duress (Contrainte) : "Dure stress". Quand tu es sous un "dur stress" avec une arme dans le dos, tu utilises le code d'alarme silencieuse.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La règle absolue : Si une question d'examen te propose un scénario où le data center est en feu, contenant des données non sauvegardées valant des milliards de dollars, et qu'un technicien est coincé à l'intérieur. Que fais-tu ?
 - A. Lancer le système anti-incendie au gaz Halon pour sauver les serveurs.
 - B. Sauvegarder les données à distance.
 - C. Lancer l'évacuation et aider le technicien à sortir.
 - Réponse CISSP (et seule réponse possible) : C. La vie humaine passe avant n'importe quel actif de l'entreprise.
- Le retour de voyage : Un cadre dirigeant revient d'une conférence dans un pays connu pour l'espionnage d'État. Il veut rebrancher son "ordinateur de voyage" sur le réseau de l'entreprise pour télécharger ses courriels. L'action du CISSP est de le lui interdire formellement et de mettre l'appareil en quarantaine pour un effacement complet.

DOMAINE 8 : SECURITE DU DEVELOPPEMENT LOGICIEL



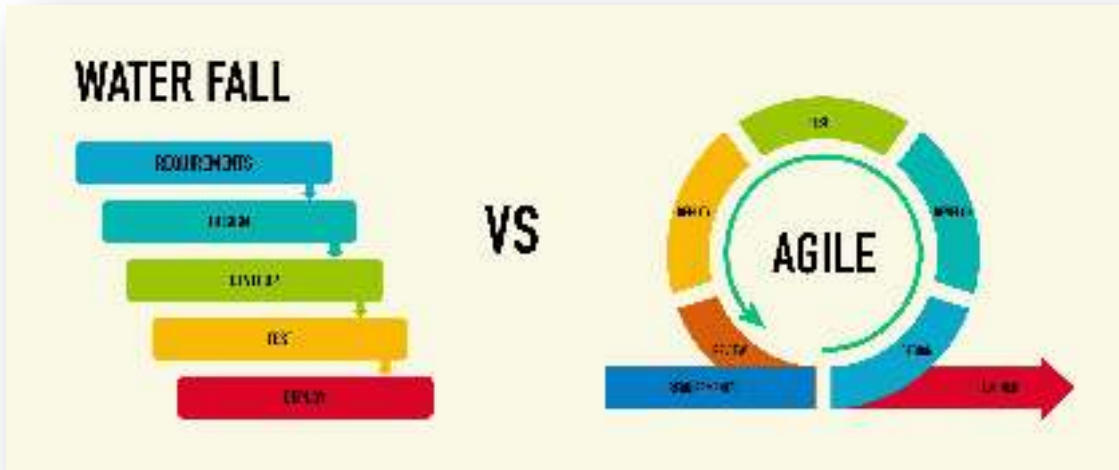
8.1 - SECURITE DANS LE SDLC

Résumé Général

Le SDLC (Software Development Life Cycle) est le processus standard de création et de maintenance des logiciels. Historiquement, la sécurité était testée à la toute fin du cycle, ce qui coûtait très cher en cas de faille. L'objectif moderne est le "Shift Left" (Décalage à gauche): intégrer la sécurité dès la phase de conception et tout au long du cycle.

Concepts Clés à retenir

- Les phases classiques du SDLC :
 - a. Exigences (**Requirements**) : Définir ce que le logiciel doit faire (C'est ici que l'on doit définir les exigences de sécurité !).
 - b. Conception (**Design**) : Modélisation des menaces (Threat Modeling) et architecture.
 - c. **Développement** / Codage : Écriture du code avec des pratiques sécurisées.
 - d. **Tests** : Recherche de bugs et de vulnérabilités.
 - e. **Déploiement** : Mise en production sécurisée.
 - f. **Opérations** et **Maintenance** : Gestion des correctifs (Patching) et retrait final (Disposal).
- Modèles de développement :
 - Modèle en cascade (**Waterfall**) : Approche séquentielle très rigide. Une phase doit être terminée pour passer à la suivante. Difficile de revenir en arrière pour corriger une faille de sécurité découverte tardivement.
 - **Agile** : Approche itérative et incrémentale (sprints de 2 à 4 semaines). Flexibilité maximale, collaboration constante. Cadres courants : Scrum, SAgile (Agile à grande échelle), IPT (Integrated Product Team). Le défi est de maintenir la rigueur de la sécurité face à la vitesse de développement.



- **DevOps** : Fusion des développeurs (Dev) et des administrateurs systèmes (Ops) pour automatiser et accélérer les déploiements.
- **DevSecOps** : Intégration native de la Sécurité au cœur du DevOps. La sécurité devient la responsabilité de tous et est automatisée dans le pipeline CI/CD.
- **Pipeline CI/CD** (Continuous Integration / Continuous Deployment) :
 - **CI (Intégration)** : Les développeurs fusionnent leur code plusieurs fois par jour dans un dépôt central. Des tests automatisés (SAST) se lancent instantanément.
 - **CD (Déploiement/Livraison)** : Le code testé est automatiquement empaqueté et déployé en production.
- Modèles de Maturité (Mesurer la qualité du processus) :
 - **CMMI (Capability Maturity Model Integration)** : 5 niveaux pour évaluer la maturité des processus d'une entreprise :
 - i. **Initial** : Chaotique, réactif, pas de processus.
 - ii. **Managed** (Géré) : Processus de base, géré au niveau du projet.
 - iii. **Defined** (Défini) : Processus standardisé pour toute l'entreprise.
 - iv. **Quantitatively Managed** : Mesures statistiques et métriques précises.
 - v. **Optimizing** (Optimisation) : Amélioration continue proactive.

- **SAMM (Software Assurance Maturity Model)** : Modèle open-source de l'OWASP pour aider les entreprises à implémenter une stratégie de sécurité logicielle mesurable.

Protocoles, Cadres ou Technologies

- Threat Modeling (Modélisation des menaces) : Se fait lors de la phase de Conception. Cadres populaires : STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege), DREAD, PASTA.

Ne pas confondre

- DevOps vs DevSecOps : DevOps optimise la vitesse de livraison. DevSecOps s'assure que cette vitesse ne se fait pas au détriment de la sécurité en automatisant les tests (Shift Left).
- Agile vs Waterfall : Waterfall est un marathon (on voit le résultat à la fin). Agile est une série de sprints (on livre des petits morceaux fonctionnels en continu).

Moyens Mnémotechniques

- STRIDE (Modélisation des menaces de Microsoft) = Toutes les choses horribles qu'un attaquant peut faire à ton logiciel (Usurpation, Falsification, Répudiation, Fuite, Dénier de service, Élévation de privilèges).
- Niveaux CMMI : I Must Do Quality Optimization (Initial, Managed, Defined, Quantitatively Managed, Optimizing).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Le coût d'une faille : L'examen adore ce principe. Plus une vulnérabilité est découverte tard dans le SDLC (ex : en production), plus elle coûte cher à réparer (jusqu'à 100 fois plus cher). La réponse est donc toujours d'intégrer la sécurité lors de la phase des Exigences (Requirements) ou du Design.
- Le concept de "Shift Left" : Si on te demande comment améliorer un pipeline de développement non sécurisé, la réponse managériale est de "**décaler la sécurité vers la gauche**" (tester le code au moment de l'écriture, et non juste avant la mise en ligne).

8.2 - CONTROLES DE SECURITE

DANS L'ECOSYSTEME DE DEVELOPPEMENT

Résumé Général

Ce sous-domaine se concentre sur l'environnement technique utilisé par les développeurs pour créer le logiciel: les langages de programmation, les compilateurs, les bibliothèques et les dépôts de code (Repositories). Sécuriser l'écosystème empêche les attaques de la chaîne d'approvisionnement (Supply Chain attacks).

Concepts Clés à retenir

- Générations de langages de programmation :
 - **1GL (Langage Machine)** : Binaire (0 et 1). Directement exécuté par le processeur. Incompréhensible pour l'humain.
 - **2GL (Langage Assembleur)** : Utilise des mnémoniques courts (ex : ADD, SUB). Spécifique au matériel. Nécessite un Assembleur pour devenir du code machine.
 - **3GL (Langages de Haut Niveau)** : C, C++, Java, Python. Indépendants du matériel, compréhensibles par l'humain. C'est ici que s'écrivent les logiciels modernes.
 - **4GL (Langages Spécifiques)** : Langages conçus pour un but précis, très proches du langage naturel (ex : SQL pour les bases de données).
 - **5GL (Langages Visuels/IA)** : Basés sur la résolution de contraintes ou la logique pure (ex : Prolog).
- Traduction du code (3GL) :
 - **Compilateur (Compiler)** : Traduit tout le code source en un fichier exécutable (binaire) en une seule fois avant l'exécution. Plus rapide à l'exécution, cache le code source (difficile à rétro-ingénierier). Ex : C++.
 - **Interpréteur (Interpreter)** : Traduit et exécute le code ligne par ligne en temps réel. Plus lent, mais le code source est visible et facilement modifiable. Ex : Python, JavaScript.

- Référentiels de code (**Code Repositories & Versioning**) :
 - Outils (ex : Git, SVN) permettant de stocker le code source, de suivre chaque modification (historique), de gérer les branches (Branching) et de collaborer.
 - Contrôles de sécurité vitaux :
 - Authentification stricte (MFA) pour les développeurs.
 - Règles de protection des branches (ex : interdire de "pousser" du code directement sur la branche de production main sans l'approbation d'un autre développeur - Four-eyes principe).
 - Signatures des "**Commits**" avec des clés GPG pour garantir l'authenticité de l'auteur.
- Gestion des Secrets (Secrets Management) :
 - Règle absolue : Ne jamais coder en dur (**Hardcode**) des mots de passe, des clés d'API ou des jetons cryptographiques directement dans le code source ou dans GitHub.
 - Utiliser des coffres-forts dédiés (**Vaults**) ou des variables d'environnement injectées dynamiquement au moment de l'exécution.

Ne pas confondre

- Compilateur vs Interpréteur : Le compilateur livre un gâteau tout fait (le binaire), tu ne vois plus les ingrédients. L'interpréteur te donne la recette et prépare les ingrédients sous tes yeux ligne par ligne.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- Les fuites de code source : Un attaquant trouve des clés AWS valides dans un dépôt Git public de ton entreprise. C'est une erreur classique de l'écosystème. Le contrôle CISSP attendu est l'utilisation d'outils d'analyse des secrets (**Secret Scanning**) dans le pipeline CI/CD pour bloquer tout commit contenant un mot de passe.
- Séparation des environnements : Le code écrit par les développeurs (Environnement de Dev) doit obligatoirement passer par un environnement de Test/QA, puis de Staging (Pré-prod), avant d'atteindre la Production.

8.3 - ÉVALUER L'EFFICACITE DE LA SECURITE LOGICIELLE

Résumé Général

Une fois le code écrit, comment prouver qu'il est sécurisé? Ce sous-domaine détaille l'arsenal d'outils de tests permettant d'identifier les vulnérabilités du logiciel. Le CISSP exige une combinaison de plusieurs méthodes pour couvrir tous les angles morts.

Concepts Clés à retenir

- **SAST** (Static Application Security Testing) :
 - **Tests en Boîte Blanche** (White-Box).
 - **Analyse le code source** (ou les binaires) au repos, sans l'exécuter.
 - Avantages : Trouve les failles très tôt, montre exactement la ligne de code posant un problème.
 - Inconvénients : Ne peut pas trouver les failles liées à l'environnement ou à l'exécution (ex : mauvaise configuration serveur), génère beaucoup de faux positifs.
- **DAST** (Dynamic Application Security Testing) :
 - **Tests en Boîte Noire** (Black-Box).
 - **Teste l'application en cours d'exécution** (Runtime), de l'extérieur, comme le ferait un hacker (ex : en tentant des injections SQL dans des formulaires web).
 - Avantages : Trouve les vulnérabilités réelles (XSS, défauts d'authentification), très peu de faux positifs.
 - Inconvénients : Trouvé tard dans le cycle, ne pointe pas la ligne de code exacte.
- **IAST** (Interactive Application Security Testing) :
 - **Tests en Boîte Grise** (Gray-Box).
 - Le meilleur des deux mondes. Place des agents (instrumentation) directement à l'intérieur de l'application

pendant qu'elle s'exécute (DAST) pour surveiller le comportement du code source (SAST) en temps réel.

- **SCA (Software Composition Analysis) :**
 - Les logiciels modernes sont composés à 80% de bibliothèques Open Source gratuites.
 - Le SCA **scanne toutes ces dépendances tierces** (le SBOM - Software Bill of Materials) pour vérifier si l'une d'elles contient des vulnérabilités connues (CVE) ou des licences restrictives.
- **Fuzzing** (Tests de robustesse / Fuzz Testing) :
 - **Injecter massivement des données aléatoires**, malformées ou inattendues dans les champs de saisie de l'application.
 - Objectif : Provoquer un plantage (**Crash**), révéler un dépassement de tampon (**Buffer Overflow**) ou des fuites de mémoire. Très efficace contre les logiciels qui ne font pas de Validation des entrées.
- **RASP (Runtime Application Self-Protection) :**
 - Ce n'est pas un test, mais une protection. Un module intégré à l'application qui la surveille en production. S'il détecte une attaque, il peut **bloquer l'exécution de la requête malveillante** de l'intérieur.

Protocoles, Cadres ou Technologies

- **SBOM (Software Bill of Materials) :** Une **liste formelle** (inventaire) de **tous les composants, bibliothèques et modules tiers** inclus dans un logiciel. C'est l'outil indispensable pour permettre au SCA d'effectuer son travail.

Ne pas confondre

- SAST vs DAST : SAST = Statique = Scanner le code source à l'arrêt (comme un correcteur orthographique). DAST = Dynamique = Attaquer l'application pendant qu'elle tourne (comme un crash-test de voiture).
- DAST vs Fuzzing : Le DAST envoie des attaques spécifiques et intelligentes (un bout de code SQL). Le Fuzzing envoie des millions de caractères aléatoires stupides juste pour voir si l'application s'étouffe.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La vulnérabilité log4j (Supply Chain) : L'examen adore tester les risques liés aux composants tiers. Si un logiciel acheté ou développé utilise une vieille bibliothèque Open Source vulnérable, le SAST/DAST ne la verra peut-être pas. L'outil spécifique exigé par le CISSP est le SCA (Software Composition Analysis), appuyé par un SBOM.
- Le moment du test : Le SAST se fait lors de la phase de Développement (sur la machine du codeur ou dans le pipeline CI). Le DAST se fait lors de la phase de Test/QA (une fois l'application compilée et hébergée).

8.4 - ÉVALUER L'IMPACT DES LOGICIELS ACQUIS SUR LA SECURITE

Résumé Général

Aujourd'hui, aucune entreprise n'écrit 100% de son code. L'intégration de logiciels tiers, de composants Open-Source ou de services Cloud permet de gagner du temps et de l'argent, mais introduit des risques majeurs liés à la chaîne d'approvisionnement (Supply Chain). La règle d'or du CISSP: on peut externaliser le développement, mais on ne peut jamais externaliser la responsabilité (Accountability).

Concepts Clés à retenir

- Les types de logiciels acquis :
 - **COTS (Commercial Off-The-Shelf / Sur étagère)** : Logiciels achetés tout faits (ex : Microsoft Office, un ERP standard).
 - Avantages : Déploiement rapide, support garanti par l'éditeur.
 - Risques : C'est une "boîte noire". Tu n'as pas accès au code source. Si l'éditeur fait faillite, tu ne peux plus corriger les failles (d'où l'importance de l'Escrow logiciel vu au 7.10).
 - **Logiciels Open Source (OSS)** : Code gratuit et public (ex : Linux, bibliothèques Apache).
 - Avantages : Transparence totale, communauté réactive, coût nul.
 - Risques : Les projets peuvent être abandonnés par leurs créateurs (plus aucun patch). Risque d'intégration de code malveillant par un contributeur anonyme. Nécessite une veille stricte via des outils SCA (Software Composition Analysis).
 - **Logiciels Tiers (Third-Party / Sous-traitants)** : Logiciels développés sur mesure par une entreprise externe. Exige des contrats stricts (SLA) définissant les normes de sécurité de codage que le sous-traitant doit respecter.

- Services Gérés (**Managed Services / SaaS**) : Hébergement et gestion complète par un tiers (ex : Salesforce). Le risque principal est la perte de contrôle sur les données et la dépendance au fournisseur (Vendor Lock-in).
- Risques de la chaîne d'approvisionnement (**Supply Chain Risks**) :
 - Un attaquant ne te vise pas directement, il pirate ton fournisseur de logiciel (plus vulnérable) pour insérer une porte dérobée (backdoor) dans une mise à jour légitime que tu vas installer aveuglément (ex : l'attaque SolarWinds).
- Contrôles d'atténuation :
 - Évaluation des risques fournisseurs (Vendor Risk Management) : Auditer le fournisseur avant l'achat (exiger un rapport SOC 2 Type II, vérifier ses pratiques de codage sécurisé).
 - Droit d'audit (**Right to Audit**) : Clause contractuelle indispensable permettant à ton entreprise d'auditer la sécurité du code du sous-traitant.
 - **Gouvernance de l'Open Source** : Interdire aux développeurs de télécharger des bibliothèques au hasard sur internet. Créer un dépôt interne approuvé.

Protocoles, Cadres ou Technologies

- SBOM (Software Bill of Materials) : L'inventaire (la "liste des ingrédients") de tous les composants tiers et Open Source utilisés dans un logiciel. C'est le seul moyen de savoir si tu es vulnérable lorsqu'une nouvelle faille (ex : Log4j) est découverte dans le monde.

Ne pas confondre

- COTS vs Custom (Sur mesure) : Le COTS est figé, testé par le marché, mais intraversable de l'intérieur. Le Custom est fait pour toi, tu peux exiger le code source, mais il n'a pas été éprouvé par des milliers de clients (plus de bugs probables).

Moyens Mnémotechniques

- L'achat d'un logiciel est un mariage : le SLA est le contrat de mariage, le Right to Audit est ton droit de regard sur les comptes, et le SBOM est l'inventaire des biens partagés.

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La responsabilité ultime : Si ton entreprise achète un logiciel RH COTS qui contient une faille, et que les données de tes employés sont volées... c'est ton entreprise (le CISO / le PDG) qui est responsable devant la loi et les employés, pas l'éditeur du logiciel.
- Le piège de la confiance aveugle : Ne jamais accepter l'affirmation d'un vendeur disant "Notre logiciel est 100% sécurisé". Le CISSP exige des preuves indépendantes (Pentests externes, certification ISO, rapport SOC).

8.5 - DIRECTIVES ET STANDARDS DE CODAGE SECURISE

Résumé Général

Écrire du code fonctionnel ne suffit pas; il doit être résilient face aux attaques. Ce sous-domaine explore les vulnérabilités de code les plus courantes, les pratiques pour les éviter (OWASP), et la manière de sécuriser les API et l'architecture logicielle globale.

Concepts Clés à retenir

- Vulnérabilités logicielles classiques :
 - Validation des entrées (**Input Validation**) : Le manque de validation est la cause #1 des vulnérabilités. Ne JAMAIS faire confiance aux données saisies par l'utilisateur.
 - **Injection SQL (SQLi)** : L'attaquant tape du code SQL dans un formulaire (ex : ' OR 1=1 ; --) pour contourner l'authentification ou lire la base de données. Parade : Requêtes paramétrées (Prepared Statements) et Stored Procedures.
 - **XSS (Cross-Site Scripting)** : L'attaquant injecte un script malveillant (JavaScript) dans un site web, qui sera exécuté par le navigateur des autres victimes. Parade : Encodage des sorties (Output encoding) et validation stricte.
 - Dépassement de tampon (**Buffer Overflow**) : L'attaquant envoie plus de données que la mémoire allouée (le tampon) ne peut en contenir. Les données débordent et écrasent la mémoire adjacente, permettant d'exécuter du code malveillant avec les privilèges de l'application. Parade : Utiliser des fonctions sécurisées, ASLR (Address Space Layout Randomization) et DEP (Data Execution Prevention).
 - Condition de concurrence (**Race Condition / TOC/TOU**) : Une faille temporelle. L'attaquant modifie une ressource juste après que le système a vérifié ses droits (Time of Check), mais juste avant que le système n'utilise la ressource (Time of Use). Parade : Verrouillage des fichiers (File locking) pendant l'opération.

- Gestion des erreurs et exceptions (**Error Handling**) : Une application qui plante ne doit jamais afficher un message d'erreur détaillé (Stack trace, version du serveur de BDD) à l'utilisateur, car cela donne des indices à l'attaquant. Parade : Afficher un message d'erreur générique (ex : "Une erreur est survenue") et journaliser (log) les détails techniques en interne de manière sécurisée (Fail Securely).
- **Sécurité des APIs** (Application Programming Interface) :
 - Les APIs sont les portes d'entrée invisibles des logiciels modernes.
 - Risques : Manque d'authentification, absence de limitation de débit (Rate Limiting) permettant le DDoS, exposition excessive de données (BOLA - Broken Object Level Authorization).
 - Contrôles : Authentification forte (clés d'API, OAuth 2.0, JWT chiffrés), limitation de requêtes (Throttling), et utilisation de passerelles d'API (API Gateways).
- **OWASP Top 10** (2021) : Les risques majeurs (à connaître).
 - a. **Broken Access Control** (Contrôle d'accès défaillant - L'utilisateur accède aux données d'un autre).
 - b. **Cryptographic Failures** (Défaillances cryptographiques - Données en clair).
 - c. **Injection** (SQL, NoSQL, OS).
 - d. **Insecure Design** (Conception non sécurisée - Manque de Threat Modeling).
 - e. **Security Misconfiguration** (Mauvaise configuration - Mots de passe par défaut).
 - f. **Vulnerable and Outdated Components** (Le besoin d'un SBOM).
- **SDS (Software-Defined Security)** : L'abstraction des contrôles de sécurité (pare-feu, IDS, segmentation) du matériel vers le logiciel, pilotés par des APIs (souvent utilisés dans le Cloud et les architectures SDN/NFV).

Protocoles, Cadres ou Technologies

- OWASP (Open Worldwide Application Security Project) : La référence incontournable en matière de sécurité applicative web.
- **CWE (Common Weakness Enumeration)** : Dictionnaire communautaire des types de faiblesses logicielles (ex : CWE-89 pour l'injection SQL).

Ne pas confondre

- XSS vs Injection SQL : Le XSS attaque le navigateur du client (l'utilisateur cible). L'injection SQL attaque le serveur et la base de données de l'entreprise.
- TOC (Time of Check) vs TOU (Time of Use) : Le contrôle des droits se fait au TOC. L'exécution réelle se fait au TOU. La faille (Race Condition) réside dans la fraction de seconde entre les deux.

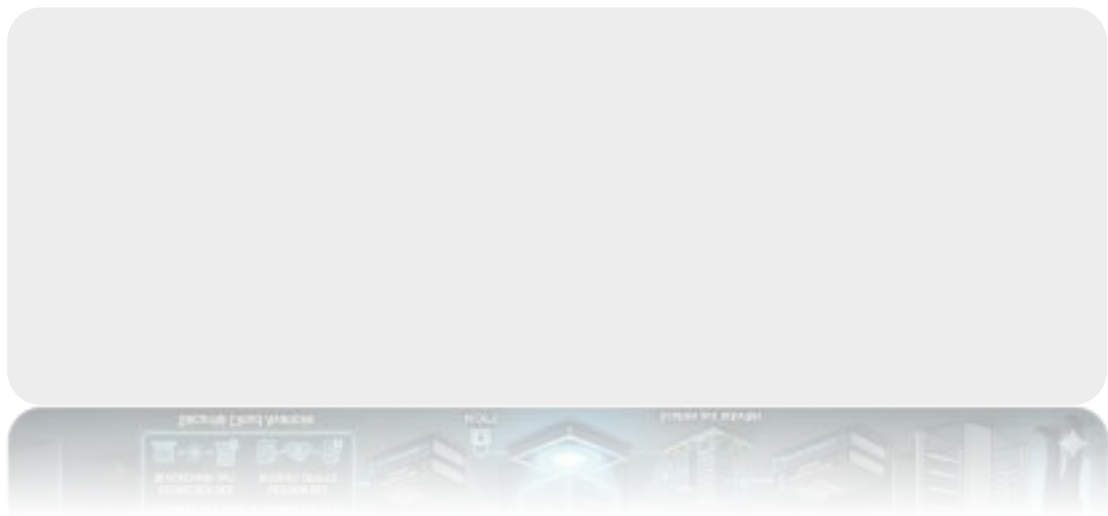
Moyens Mnémotechniques

- SQLi : On attaque le Serveur.
- XSS : On attaque le Client X
- TOC/TOU : Le braqueur de banque montre un faux badge au garde (TOC), puis dégaine son arme une fois à l'intérieur (TOU).

Ce qui va tomber à l'examen (CISSP Mindset & Pièges)

- La règle absolue de la validation : La validation des entrées doit TOUJOURS se faire côté serveur (**Server-side**). La validation côté client (JavaScript dans le navigateur) n'est qu'une commodité pour l'utilisateur et peut être désactivée ou contournée trivialement par un attaquant (ex : via un proxy comme Burp Suite).
- **Fail Securely** (Échec sécurisé) : C'est un principe de design fondamental. Si une application bancaire plante ou perd sa connexion à la base de données, elle ne doit pas "s'ouvrir" ou bloquer sur un état inconnu. Elle doit fermer la session, verrouiller l'accès et afficher une erreur générique.

BONUS : FICHES DE DERNIERE MINUTE



BONUS 1 - PENSER COMME UN MANAGER

Résumé Général

Le CISSP n'est pas un examen technique, c'est un examen de gestion des risques. Si tu réponds aux questions comme un ingénieur ou un technicien système, tu vas échouer. L'examen évalue ta capacité à prendre des décisions stratégiques qui protègent l'entreprise tout en permettant au métier (le Business) de fonctionner.

Principes Fondamentaux

- La vie humaine avant tout (Life Safety) : C'est la priorité absolue. Aucun actif, aucune donnée et aucun serveur ne vaut une vie humaine.
- Le Business dicte la sécurité : La sécurité n'est pas là pour tout bloquer. Elle est là pour soutenir les objectifs de l'entreprise. Si une mesure de sécurité empêche l'entreprise de gagner de l'argent, c'est une mauvaise mesure.
- Fixer les processus avant la technologie : On n'achète pas un pare-feu pour régler un problème. On identifie le risque, on crée une politique, puis on achète la technologie qui applique cette politique.
- Ne jamais agir seul : Un CISSP ne déconnecte pas un serveur en urgence ou n'installe pas un patch sans passer par le Change Management ou avertir la direction.
- Le risque ne peut être éliminé : On ne supprime pas le risque. On le réduit à un niveau acceptable pour la direction (Acceptable Risk Level).

Les Pièges Classiques

- Le piège du "Fix it now" (Technicien) : Face à un serveur infecté, la réponse "Lancer l'antivirus" est souvent fausse. La réponse CISSP est "Isoler le serveur" ou "Informer la direction".
- Le piège du "Meilleur outil" : Choisir la réponse qui propose la technologie la plus chère ou la plus récente (ex : IA, Blockchain). Le CISSP préfère toujours un processus robuste à un outil brillant.

Moyens Mnémotechniques

- P.P.T : People (Les gens d'abord), Process (Les règles ensuite), Technology (Les outils en dernier).

Application à l'examen (CISSP Mindset)

- Si la question demande le "MEILLEUR" (BEST) choix, cherche la réponse qui englobe les autres ou qui représente une étape de planification/politique (ex : "Faire une analyse de risque" bat toujours "Installer un IDS").
- La sécurité commence par la Direction (Top Management). Si une réponse implique d'obtenir l'approbation du conseil d'administration ou du PDG, c'est très souvent la bonne.

BONUS 2 - LE CODE D'ÉTHIQUE DE L'ISC2

Résumé Général

Le code d'éthique est le fondement moral du CISSP. Tu seras testé dessus. Si une question présente un conflit moral, légal ou professionnel, tu dois utiliser ces canons, strictement dans l'ordre, pour prendre ta décision.

Principes Fondamentaux (Les 4 Canons dans l'ordre d'importance)

1. Protéger la société, le bien commun et l'infrastructure, ainsi que préserver la confiance du public. (La vie, la loi, la sécurité du pays passent avant tout. Si ton entreprise fait quelque chose d'illégal ou de dangereux pour le public, tu dois la dénoncer, les "Whistleblowers" sont protégés).
2. Agir de manière honorable, honnête, juste, responsable et légale. (Ne pas mentir, ne pas cacher des failles de sécurité, respecter les lois locales).
3. Fournir des services diligents et compétents aux supérieurs. (Protéger ton employeur, respecter les contrats, garder les informations confidentielles - sauf si cela viole les canons 1 ou 2).
4. Faire progresser et protéger la profession. (Ne pas tricher à l'examen, partager ses connaissances, mentorer les plus jeunes, ne pas associer l'ISC2 à des activités criminelles).

Les Pièges Classiques

- Conflit de loyauté : Ton patron te demande de cacher une fuite de données massive qui met en danger les citoyens.
 - Piège : Tu obéis par loyauté (Canon 3).
 - Réponse : Tu refuses et dénonces, car la société et la loi (Canon 1 et 2) sont supérieures à l'employeur (Canon 3).
- Mentir sur son CV : Prétendre avoir un diplôme que l'on n'a pas violé le Canon 2 (Honnêteté).

Moyens Mnémotechniques

- PAPA : Protect Society (Société) > Act Honorably (Honnêteté) > Provide Service (Employeur) > Advance Profession (Profession).

Application à l'examen (CISSP Mindset)

- L'ordre est absolu. Si deux canons sont en conflit dans une question d'examen, celui qui a le plus petit numéro (1 est plus fort que 2) gagne TOUJOURS.

BONUS 3 - STRATEGIE DE L'EXAMEN

Résumé Général

L'examen CISSP est adaptatif (CAT - Computerized Adaptive Testing). Il s'adapte à ton niveau. Les questions sont réputées pour être ambiguës, subjectives et verbeuses. Il faut savoir "décoder" ce que l'examineur attend de toi.

Principes Fondamentaux

- Comprendre les mots-clés : Fais très attention aux mots en majuscules ou en gras :
 - FIRST (En premier) : Cherche une action de planification, d'analyse de risque, de confinement ou de sécurité humaine.
 - BEST / MOST (Le meilleur / Le plus) : Il y a probablement 3 bonnes réponses techniquement. Cherche celle qui résout le problème à la racine (processus) plutôt que le symptôme.
 - LEAST / NOT (Le moins / Pas) : Attention aux doubles négations.
- Technique d'élimination :
 - Si deux réponses disent la même chose avec des mots différents, elles sont probablement fausses toutes les deux.
 - Élimine les réponses "trop absolues" qui utilisent les mots Toujours, Jamais, Tous (Always, Never, All).
 - Élimine les réponses purement tactiques ou spécifiques à un vendeur (ex : "Installer Cisco Firepower"). L'examen est neutre.
- Gestion du temps et du stress :
 - Tu as entre 100 et 150 questions en 3 heures.
 - Tu ne peux PAS revenir en arrière. Une fois la réponse validée, c'est définitif. Prends le temps de relire la question.
 - Si tu arrives à la question 101 et que l'examen continue, ne panique pas. Cela signifie que tu es toujours dans la course ! Respire et continue.

Les Pièges Classiques

- L'expérience personnelle : "Dans mon entreprise, on fait comme ça...". Oublie ton entreprise. Réponds comme si tu travaillais dans un monde utopique régi par les livres de l'ISC2.
- Trop lire dans la question : Ne présume pas d'informations qui ne sont pas écrites dans le texte. Tiens-t'en strictement aux faits fournis.

Moyens Mnémotechniques

- L.I.S.T : Lis la question, Identifie le mot clé (FIRST/BEST), Supprime 2 mauvaises réponses, Tranche comme un Manager.

Application à l'examen (CISSP Mindset)

- Rappelle-toi : La réponse "A" est techniquement parfaite, mais la réponse "C" est une politique qui englobe "A". Choisis "C". Le manager écrit la politique, l'ingénieur configure le routeur. Sois le manager.

BONUS 4 - FORMULES ET METRIQUES

Résumé Général :

Le CISSP demande de connaître quelques formules mathématiques simples pour évaluer quantitativement les risques, dimensionner la cryptographie ou mesurer la précision de la biométrie et des plans de reprise (DRP).

Principes Fondamentaux :

- Gestion Quantitative des Risques :
 - AV (Asset Value) : Valeur de l'actif (en \$).
 - EF (Exposure Factor) : Pourcentage de perte si la menace se réalise (%).
 - SLE (Single Loss Expectancy) : Coût d'un seul incident. $SLE = AV \times EF$
 - ARO (Annualized Rate of Occurrence) : Nombre de fois où l'incident se produit par an.
 - ALE (Annualized Loss Expectancy) : Coût total par an. $ALE = SLE \times ARO$
 - CBA (Cost Benefit Analysis) : Valeur de la protection. $ALE \text{ avant contrôle} - ALE \text{ après contrôle} - \text{Coût annuel du contrôle}$ (Si le résultat est positif, l'achat est justifié).
- Continuité et Reprise (BC/DR) :
 - MTD (Maximum Tolerable Downtime) : Temps de survie de l'entreprise.
 - L'équation vitale : $RTO \text{ (Temps de restauration IT)} + WRT \text{ (Temps de test/validation métier)} \leq MTD$.
- Clés Cryptographiques (Pour N utilisateurs) :
 - Chiffrement Symétrique : Formule de complexité. $N(N-1) / 2$ clés totales.
 - Chiffrement Asymétrique : Formule simple. $2N$ clés totales.

- Biométrie :
 - CER (Crossover Error Rate) : Le taux d'erreur croisé. C'est le point exact où l'erreur de Type 1 (FRR - Faux Rejet) croise l'erreur de Type 2 (FAR - Fausse Acceptation).

Les Pièges Classiques :

- Calculer le ROI de la sécurité : L'examen te donnera plein de chiffres inutiles pour te perdre. Reste concentré sur la formule du CBA. Si le pare-feu coûte 100 000 \$/an et qu'il ne sauve que 50 000 \$ de pertes estimées, l'action CISSP est de rejeter l'achat (accepter le risque coûte moins cher).

Moyens Mnémotechniques :

- $ALE = SLE \times ARO$: La "Bièrre" (Ale) = "Dormir" (SLE) avec un "Anneau" (ARO).
- Symétrique : Si on est 100, $100 \times 99 / 2 = 4950$ clés. C'est le cauchemar de la scalabilité.

Application à l'examen (CISSP Mindset) :

- Pour la biométrie : Si tu dois choisir le "MEILLEUR" système biométrique parmi 4 options, ne regarde ni le prix, ni la technologie. Choisis toujours celui qui a le CER le plus bas.

BONUS 5 - LOI, REGLEMENTATIONS ET PROPRIETE INTELLECTUELLE

Résumé Général :

Le CISSP est un examen mondial, mais très ancré dans le droit américain. Il faut connaître les grandes lois de protection des données, de la vie privée, et les mécanismes légaux pour protéger les créations de l'entreprise (Propriété intellectuelle).

Principes Fondamentaux :

- Propriété Intellectuelle (Intellectual Property - IP) :
 - Copyright (Droit d'auteur) : Protège l'expression d'une idée (code source, livre, musique). Dure la vie de l'auteur + 70 ans.
 - Patent (Brevet) : Protège une invention ou un processus unique. Dure 20 ans. Exige de rendre le secret public.
 - Trademark (Marque déposée) : Protège un logo, un nom, un slogan (ex : le M de McDonald's). Dure indéfiniment si renouvelée.
 - Trade Secret (Secret commercial) : Protège des informations vitales (ex : la recette de Coca-Cola). N'expire jamais, mais exige des mesures de sécurité féroces et des NDA (Non-Disclosure Agreements) pour rester valide devant un juge.
- Lois et Réglementations (Majoritairement US) :
 - HIPAA : Protection des données de santé (PHI).
 - SOX (Sarbanes-Oxley) : Transparence financière et gouvernance des entreprises cotées en bourse (pour éviter les scandales type Enron). Les dirigeants (CEO/CFO) sont pénalement responsables.
 - GLBA (Gramm-Leach-Bliley Act) : Protection des données personnelles dans les banques et assurances.
 - CIPA : Protection des enfants sur Internet (filtrage web dans les écoles).

- GDPR (RGPD) : Loi européenne sur la vie privée. Impose le "Droit à l'oubli", le consentement, et des amendes massives (jusqu'à 4% du CA mondial).
- Exportation de la cryptographie :
 - Arrangement de Wassenaar : Accord international limitant l'exportation d'armes conventionnelles et de technologies à double usage, incluant les algorithmes cryptographiques forts.

Les Pièges Classiques :

- Brevet vs Secret Commercial : Si une entreprise veut protéger un algorithme exclusif sans jamais révéler comment il fonctionne, elle ne doit surtout pas déposer de brevet (le brevet rend la formule publique). Elle doit utiliser le Secret Commercial (Trade Secret).

Moyens Mnémotechniques :

- HIPAA = Hôpital.
- SOX = Sous (Argent/Finance d'entreprise).
- GLBA = Guichets (Banques).

Application à l'examen (CISSP Mindset) :

- L'examen teste la Due Care (Diligence raisonnable). La conformité légale (Compliance) n'est pas optionnelle, elle surpasse toutes les politiques internes de l'entreprise.

BONUS 6 - CADRES DE GOUVERNANCE

Résumé Général :

Pour ne pas réinventer la roue, les entreprises utilisent des cadres standardisés. L'examen teste ta capacité à sélectionner le BON cadre en fonction du besoin de l'entreprise (Gouvernance, Opérations IT, Architecture, Sécurité).

Principes Fondamentaux :

- Cadres de Sécurité (Security Frameworks) :
 - ISO 27001 : Le standard international pour mettre en place un SMSI (Système de Management de la Sécurité de l'Information). Orienté processus et amélioration continue (PDCA - Plan Do Check Act).
 - ISO 27002 : Le catalogue des bonnes pratiques/contrôles qui accompagnent ISO 27001.
 - NIST CSF (Cybersecurity Framework) : Cadre américain très populaire divisé en 5 fonctions clés : Identifier, Protéger, Détecter, Répondre, Récupérer.
- Gouvernance IT (IT Governance) :
 - COBIT : Framework de gouvernance globale. Aide à aligner les objectifs informatiques sur les objectifs métiers de l'entreprise.
- Gestion des Services IT (IT Service Management) :
 - ITIL : Framework axé sur la gestion des services IT au quotidien (Support, Incidents, Gestion des changements, Gestion des configurations, SLAs).
- Architecture d'Entreprise (Enterprise Architecture) :
 - TOGAF : Sépare l'architecture en 4 domaines : Métier, Données, Application, Technologie (BDAT).
 - SABSA : Cadre d'architecture spécifique à la sécurité. Utilise une matrice 6x6 basée sur la chaîne de traçabilité (De l'idée métier abstraite jusqu'au code technique).

- Zachman : Cadre global utilisant une matrice (Qui, Quoi, Où, Quand, Pourquoi, Comment) croisée avec les rôles (Planificateur, Propriétaire, Concepteur, etc.).

Les Pièges Classiques :

- COBIT vs ITIL : COBIT dit quoi faire pour s'aligner sur le Business (Gouvernance stratégique). ITIL dit comment le faire techniquement au jour le jour (Gestion des tickets, des changements).

Moyens Mnémotechniques :

- NIST CSF : Il Pleut Des Renards Rouges (Identify, Protect, Detect, Respond, Recover).
- SABSA : Sécurité Architecture. (C'est le seul framework orienté 100% sécurité globale).

Application à l'examen (CISSP Mindset) :

- Si le Conseil d'Administration veut un standard pour auditer et prouver que la sécurité soutient les objectifs financiers de l'entreprise, choisis COBIT. S'ils veulent certifier le processus de sécurité au niveau international, choisis ISO 27001.

BONUS 7 - LE DICTIONNAIRE DES ACRONYMES "PIEGES"

Résumé Général :

Le CISSP regorge d'acronymes qui se ressemblent ou qui partagent les mêmes lettres pour des concepts totalement différents. Une lecture trop rapide de la question peut te faire tomber dans le piège.

Principes Fondamentaux :

- Les 3 "MAC" :
 - Mandatory Access Control : Contrôle d'accès militaire basé sur des étiquettes (Top Secret, Secret). (Domaine 5)
 - Media Access Control : L'adresse physique matérielle d'une carte réseau sur la Couche 2 OSI. (Domaine 4)
 - Message Authentication Code : Un petit bloc de données chiffré ajouté à un message pour prouver son intégrité et son authenticité (Cryptographie). (Domaine 3)
- Les 2 "DAC" :
 - Discretionary Access Control : Modèle où le propriétaire du fichier décide de qui y accède. (Domaine 5)
 - Data Access Control : Terme générique (rarement la bonne réponse, souvent mis là pour confondre avec Discretionary).
- Les Chiffrements (A retenir) :
 - AES / DES / 3DES / RC4 : Symétriques (1 seule clé partagée). Rapides.
 - RSA / ECC / Diffie-Hellman : Asymétriques (Clé Publique/Privée). Lents.
- Les Signatures & Hashs :
 - SHA / MD5 : Intégrité (Hachage). Ne chiffrent rien, font juste une empreinte.
- BIA vs BPA :

- BIA (Business Impact Analysis) : Document identifiant les processus critiques et les pertes financières maximales tolérables. L'étape #1 du plan de continuité (BCP).
- BPA (Business Partnership Agreement) : Accord légal entre deux entreprises décidant comment elles partagent les bénéfices et les pertes.

Les Pièges Classiques :

- L'examen demandera par exemple : "Lequel de ces mécanismes garantit l'intégrité d'un paquet sur un réseau local ?" et proposera "MAC" parmi les réponses. Il faut comprendre d'après le contexte de la phrase de quel "MAC" l'examineur parle.

Moyens Mnémotechniques :

- Prends toujours le temps de traduire mentalement l'acronyme dans la question avant de lire les 4 choix de réponses.

Application à l'examen (CISSP Mindset) :

- Si une question te donne un scénario de gouvernance et te propose une soupe d'acronymes (ex : ALE, SLE, ARO) dans les réponses, identifie d'abord si la question parle de Risque Quantitatif (Argent/Chiffres) ou Qualitatif (Couleurs/Niveaux Haut-Bas). Si c'est qualitatif, élimine directement tous les acronymes mathématiques (SLE/ALE).

BONUS 8 - LES MODELES DE SECURITE

Résumé Général :

L'examen adore tester ces modèles théoriques des années 70/80 qui définissent comment les systèmes d'exploitation gèrent la confidentialité et l'intégrité. C'est du par coeur pur et dur.

Principes Fondamentaux :

- Bell-LaPadula (Confidentialité) :
 - Conçu pour l'armée. Le but est d'empêcher les fuites de secrets.
 - Règle No Read Up (Simple Security Property) : Un sujet (Secret) ne peut pas lire un objet d'un niveau supérieur (Top Secret).
 - Règle No Write Down (-Star Property) : Un sujet (Top Secret) ne peut pas écrire/copier des données vers un niveau inférieur (Secret) pour éviter les fuites.
- Biba (Intégrité) :
 - L'inverse exact de Bell-LaPadula. Conçu pour le monde médical/financier. Le but est d'empêcher la corruption des données par des sources non fiables.
 - Règle No Read Down (Simple Integrity Property) : Un sujet (Fiabilité Haute) ne doit pas lire un objet (Fiabilité Basse) pour ne pas être corrompu par de fausses données.
 - Règle No Write Up (-Star Integrity Property) : Un sujet (Fiabilité Basse) ne peut pas modifier un objet (Fiabilité Haute).
- Clark-Wilson (Intégrité Commerciale) :
 - Basé sur des transactions bien formées et la séparation des tâches. Les utilisateurs ne touchent jamais les données directement ; ils passent par un programme (Interface) qui valide l'action.
- Brewer-Nash (Muraille de Chine / Chinese Wall) :

- Conçu pour prévenir les conflits d'intérêts (Cabinets de conseil, avocats). Si tu accèdes aux données du Client A, le système te bloque dynamiquement l'accès aux données du Client B (son concurrent).

Les Pièges Classiques :

- L'examen va te décrire une situation hospitalière où un interne (bas niveau) modifie le dossier d'un patient critique (haut niveau) et te demander quel modèle a été violé. C'est une question d'Intégrité : la réponse est Biba (No Write Up).

Moyens Mnémotechniques :

- Bell-LaPadula = Boîte secrète (Confidentialité).
- Biba = Bonnes données (Intégrité). L'astuce : Biba lit de bas en haut (i avant a).
- Brewer-Nash = Barrier (Muraille de Chine / Conflit d'intérêts).

Application à l'examen (CISSP Mindset) :

- Si tu vois les mots "Séparation des tâches" (Separation of Duties) couplés à "Transactions", cherche immédiatement Clark-Wilson. Si tu vois "Conflit d'intérêts", coche Brewer-Nash.

BONUS 9 - LE MODELE OSI

Résumé Général :

Le Domaine 4 repose entièrement sur le modèle OSI. Tu dois savoir instantanément à quelle couche appartient un protocole, un équipement réseau, ou une attaque spécifique.

Principes Fondamentaux :

1. Couche 1 (Physique) : Câbles, Hubs, Répéteurs, Radio. Attaques : Coupure de câble, Brouillage (Jamming), Écoute physique (Wiretapping). Unité : Bit.
2. Couche 2 (Liaison de données) : Switchs (Commutateurs), Adresses MAC, ARP, VLANs. Attaques : ARP Spoofing, MAC Flooding, VLAN Hopping. Unité : Trame (Frame).
3. Couche 3 (Réseau) : Routeurs, Adresses IP, ICMP, IPSec. Attaques : Ping of Death, IP Spoofing, Smurf Attack (DDoS). Unité : Paquet (Packet).
4. Couche 4 (Transport) : TCP (Fiable/Connecté), UDP (Rapide/Non-connecté), Pare-feu Stateful, Ports. Attaques : SYN Flood (DDoS TCP), Port Scanning. Unité : Segment (TCP) / Datagramme (UDP).
5. Couche 5 (Session) : NFS, RPC, SQL, établissement et fermeture des sessions. Attaques : Session Hijacking (Détournement de session).
6. Couche 6 (Présentation) : Chiffrement (SSL/TLS - partiellement partagé avec la couche 4/7), Compression, Formats (JPEG, ASCII). Attaques : Attaques cryptographiques (Downgrade).
7. Couche 7 (Application) : HTTP, FTP, SMTP, DNS, Pare-feu applicatifs (WAF). Attaques : Phishing, XSS, Injection SQL, DNS Poisoning. Unité : Donnée (Data).

Les Pièges Classiques :

- L'examen demandera : "Quel équipement segmente les domaines de diffusion (Broadcast domains) ?". La réponse est le Routeur (Couche 3). S'il demande "Quel équipement segmente les domaines de collision ?", c'est le Switch (Couche 2).

Moyens Mnémotechniques :

- De bas en haut (1 à 7) : Pour Le Réseau, Tu Sais Parler Anglais (Physique, Liaison, Réseau, Transport, Session, Présentation, Application).
- De haut en bas (7 à 1) : All People Seem To Need Data Processing (Application, Présentation, Session, Transport, Network, Data link, Physical).

Application à l'examen (CISSP Mindset) :

- L'examen adore tester ta capacité à placer un contrôle de sécurité à la bonne couche pour contrer une attaque. Contre un SYN Flood (Couche 4) ? Un pare-feu Stateful (Couche 4). Contre une Injection SQL (Couche 7) ? Un WAF (Couche 7).

BONUS 10 - L'ORDRE DES PROCESSUS CHRONOLOGIQUES

Résumé Général :

Le CISSP pose souvent des questions du type: "Quelle est la PROCHAINE étape?" ou "Quelle est la TOUTE PREMIÈRE étape?". Si tu confonds l'ordre du Plan de Continuité (BCP) avec celui de la Réponse à Incident (IR), tu as faux.

Principes Fondamentaux :

- Ordre du BCP (Business Continuity Plan) :
 - a. Déclaration de politique / Lancement du projet (Approbation de la direction).
 - b. BIA (Business Impact Analysis) - L'étape la plus testée, toujours en premier avant de concevoir quoi que ce soit.
 - c. Identification des contrôles préventifs.
 - d. Développement des stratégies de récupération (Choisir le site de secours).
 - e. Développement et implémentation du plan (Rédaction).
 - f. Test, Formation et Maintenance.
- Ordre de la Réponse à Incident (NIST) :
 - a. Préparation.
 - b. Détection et Analyse.
 - c. Confinement (Containment) / Éradication / Récupération.
 - d. Activités post-incident (Lessons Learned).
- Cycle de vie du renseignement sur les menaces (Threat Intelligence) :
 - a. Planification et Direction.
 - b. Collecte.
 - c. Traitement.
 - d. Analyse et Production.

- e. Dissémination (Partage de l'info).
- f. Feedback (Retour d'expérience).

Les Pièges Classiques :

- Si une question demande "Quelle est la première étape du DRP/BCP ?" et que le BIA n'est pas dans les réponses, cherche "L'approbation de la direction (Management approval)" ou "Création de la politique". Le BIA ne vient qu'après l'accord des chefs.

Moyens Mnémotechniques :

- Incident Response : Pirate Détecté, Confinement Exigé, Réseau Lavé (Préparation, Détection, Confinement, Éradication, Récupération, Leçons).

Application à l'examen (CISSP Mindset) :

- Règle absolue du Mindset : On ne conçoit jamais une solution (choix d'un Hot Site, achat d'un logiciel) avant d'avoir analysé le besoin (BIA, Risk Assessment). "Analyse" bat "Action" dans 90% des questions d'ordre chronologique.